

The Shadow Files

Том 3

Тверді Цілі

YEHOR SELIN

Зміст

Перш ніж почати	4
Коли слід похований	6
Як влаштований Том Третій	9
Місток із Томів Першого й Другого	12
Привид у кеші	16
Реконструкція видаленого акаунта	35
Читання фотографії на місці	53
Читання фотографії на час	70
Домени та історія реєстрації	85
Прозорість сертифікатів	103
Від інфраструктури — назад до людини	121
Пасивний DNS і відбитки	141
Повна тверда ціль	163
Що ти можеш зараз	190
Додаток А — Робочий інструментарій (2026)	193
Додаток В — Шаблони	199

Додаток С — Червоні лінії	210
Додаток D — Забери назад	214
Глосарій	219

Перш ніж почати

Це третій том «The Shadow Files» — практичного курсу з розвідки за відкритими джерелами, OSINT. Він прямо продовжує Томи 1 і 2. Якщо ти не читав основ — петлі, драбини впевненості, дисципліни зупинки на межі — та роботи між платформами — проведення людини крізь інтернет так, щоб не втратити, — прочитай їх спершу. Ця книга спирається на обидві.

Тут усе вигадане

Кожне ім'я, юзернейм, поштова адреса, номер телефону, фотографія, домен, IP-адреса, WHOIS-запис, сертифікат, координата і кейс у цій книзі — повністю вигадані. Кожен приклад побудований, щоб навчити методу — а не описати реальну людину, реальний сайт чи реальне місце. Будь-яка схожість із реальною особою, акаунтом, доменом чи подією — чистий збіг.

Оскільки кожна деталь вигадана, приклади показані повністю — цілісні на вигляд записи замість затертих символів — щоб ти бачив, як насправді поводить себе слід, і при цьому ніщо з цього не торкалося реальної цілі.

Правила, одним рядком

Тільки відкриті джерела. Нічого, що вимагає логіну, пароля чи обходу пейволу. Поважай приватність людей і закон. Це вся рамка, і вона не послаблюється від того, що ця книга стає складнішою.

Дві речі, які варто тримати в голові. Том 3 навчає тебе читати те, що люди вважали стертим, і розміщувати їх у світі за речами, які вони ніколи не підписували. І перше, і друге здається новачкові вторгненням — і таке воно і є, якщо використовувати неправильно. Знай закон там, де працюєш: читати публічний архів — це не те саме, що ошукати сервіс і витягти приватні дані, а геолокувати знімок, який хтось виклав публічно, — не те саме, що стежити за пересуваннями людини. По-друге, більшість шкоди в цьому ремеслі завдають людям, які ніколи не були об'єктом розслідування — сусідові, що потрапив у тінь, родичеві за відредагованим WHOIS, дитині на задньому плані знімка. Бери лише те, що відповідає на твоє питання, і на цьому зупиняйся.

Професіонал — це не той, хто здатен знайти найбільше. Це той, хто знає, коли зупинитися.

Коли слід похований

Що змінюється в Томі Третньому

У Томі 1 ти навчився тягнути одну нитку. У Томі 2 — сплітати нитки з багатьох платформ в одну впевнену ідентичність. Обидві книги припускали одне й те саме: людина, або акаунт, або фото — *там*. Тобі треба було лише знайти й уважно прочитати.

Том 3 — про випадки, коли цього там немає. Принаймні не там, де шукав би звичайний пошук.

Акаунт видалили три роки тому, і платформа каже, що профіль «не існує». Фотографія без підпису, без метаданих, без явного орієнтира, і людина, яка її виклала, не відповідатиме на питання. Домен за проксі приватності, а реєстрант — рядок з іксів. Операція взагалі не в Instagram — вона на сервері десь у стійці, і єдине, що на неї вказує, — сертифікат, який машина видала о 3-й ранку минулого квітня.

Тут новачки здаються, а професіонали починають. Бо ніщо з цього насправді не зникло. Воно *зміщене* — відсунуте з очевидної поверхні на іншу: в архів, у тінь на землі, в лог прозорості сертифікатів, у геш фавікону. Треба знати, що інша поверхня існує, і треба вміти її прочитати.

Для кого ця книга

Для тебе — якщо перші два томи для тебе як друга натура, і ти хочеш працювати кейси, де прості півоти закінчуються. Не треба бути мережевим інженером чи фотографом. Треба терпіння, смак до повільної роботи і склад думки, який будували перші дві книги. Якщо якесь технічне слово тебе спіткнить — у кінці є глосарій, звертайся будь-коли.

Що ти вмітимеш у кінці

Реконструювати акаунт після його видалення. Розмістити фото на карті за тіннями в кадрі. Датувати його за погодою і сонцем. Провести домен від його першого WHOIS-запису до того, хто у 2016-му забув себе відредагувати. Читати лог прозорості сертифікатів так, як читаєш стрічку коментарів. Перетворювати інфраструктуру назад на людей. І — навичка, що зв'яже все це, — досі точно знати, коли зупинитися.

Чим цей том не є

Це не посібник із злому систем. Ніщо тут не потребує логіну, пароля чи обходу замка. Кожна техніка читає записи, які світ уже зробив публічними — з адміністративних причин, з міркувань безпеки чи випадково, — і читає їх правильно. Професійний світ due diligence, звітів із ланцюгом зберігання, контррозвідки й автоматизації чекає на Том 4. Тут ми опановуємо одне як слід: важкі цілі.

*Якщо ти не бачиш ціль напряду — подивись, що
зафіксував світ навколо неї.*

Як влаштований Том Третій

Серія, ця книга, і як побудована кожна глава.

«The Shadow Files» — серія з чотирьох томів. Кожен піднімає тебе на рівень вище, і кожен спирається лише на те, чого навчив попередній.

- Том 1 — Основи. Склад думки, правила й твої перші справжні навички.
- Том 2 — Крос-платформна атрибуція. Проведення однієї людини через соцмережі, месенджери, фото й витоки — до єдиної впевненої ідентичності.
- Том 3 — Важкі цілі. Видалені акаунти, геолокація, хронолокація й інфраструктура за операціями. *(Ця книга.)*
- Том 4 — Професіонал. Корпоративна робота, звіти, контррозвідка й перетворення навичок на ремесло.

Кілька слів про обсяг: цей том нарешті виходить за межі профілю. Половина його все ще про людей — про тих, хто вважав, що стер себе, і про тих, кого ти розміщуєш крізь вікно, яке вони ніколи не підписали. Інша половина — про те, що люди будують і забувають сховати: домени, хости, сертифікати, трекери. Але навіть інфраструктурні глави

закінчуються там, де закінчується кожна глава цієї серії, — на людині.

У цьому томі

1. Привид у кеші 2. Реконструкція видаленого акаунта 3. Читання фотографії на місці 4. Читання фотографії на час 5. Домени й історія реєстрації 6. Прозорість сертифікатів 7. Від інфраструктури назад до людини 8. Пасивний DNS і відбитки 9. Повна важка ціль

Як побудована кожна глава

Той самий ритм, що у Томах 1 і 2, — щоб ти завжди знав, де перебуваєш:

- Ідея — простими словами, без жаргону.
- Метод — як професіонал насправді думає й працює, крок за кроком.
- Розібраний кейс — коротке вигадане розслідування, яке можна пройти, з залишеними тупиками.
- Вправа — щось безпечне й законне, що ти робиш сам.
- Підсумок — кілька речей, які варто запам'ятати.

Одна обіцянка про інструменти

Як і раніше: метод перший, інструменти другі. Деякі згадані тут інструменти можуть зникнути до того, як ти це прочитаєш, а на їхньому місці з'являться нові. Це нормально. *Мислення* не змінюється. Опануй метод — і будь-який інструмент стане просто швидшим способом зробити те, що ти вже розумієш. Том 3 за своєю природою більш інструментоорієнтований, ніж Том 2, — ти читатимеш логи сертифікатів і бази реверсного DNS, а це буквально сервіси, — але *питання*, які ти несеш до цих сервісів, — ті самі три питання, які ти ставиш ще з Тому 1: що є відкритим слідом, від чого можна робити півот, кому я що атрибутую.

Місток із Томів Першого й Другого

Основи на одну сторінку, перш ніж піти глибше.

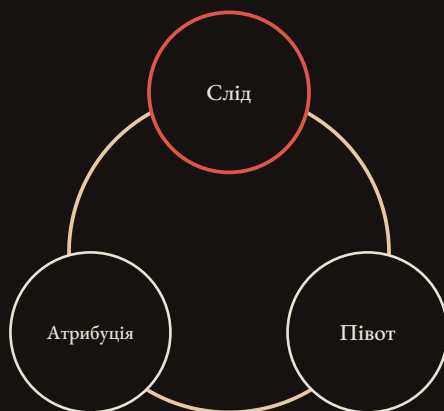
Перш ніж ми підемо кудись новим, дай мені швидко вкласти основи тобі в руку. Якщо щось із цього видасться незнайомим — це знак повернутися до попередніх книг, перш ніж рухатися далі тут. Усе в цьому томі спирається на ці чотири речі.

Петля

Кожне розслідування, хоч би яка дивна була поверхня, — це ті самі три ходи, замкнені в коло.

Відкритий слід → півот → атрибуція.

ЦИКЛ



одна зачіпка, кружляй колом, поки не вкаже на людину

Три ходи йдуть циклом — атрибуція живить наступний відкритий слід.

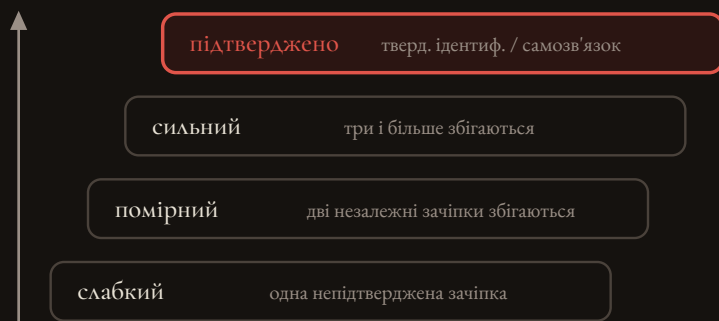
Відкритий слід — це слід, який хтось чи щось лишили на видноті. Півот — це перетворення цього сліду на наступний. Атрибуція — це коли достатньо слідів вишиковується так, що вказують на одну реальну ідентичність — людину, групу, оператора. У Томі 3 відкритий слід часто історичний (знімок, запис у лозі, старий запис), а не живий. Петлі байдуже. Ти прокручуєш її так само.

Драбина впевненості

Збіг — це не факт. Ми завжди говоримо, *наскільки* ми впевнені, чотирма фіксованими словами:

- слабкий — одна непідтверджена підказка. Зачіпка, ніколи не висновок.
- помірний — дві незалежні підказки збігаються.
- сильний — кілька незалежних сигналів, які разом важко пояснити будь-якою конкурентною гіпотезою. Зазвичай три або більше. Двоє важких, діагностичних можуть самі досягти сильного. Три слабких, поширених — можуть і ні.
- підтверджено — жорсткий унікальний ідентифікатор або справжнє самопосилання, незалежно прибите так, що кожен може перевірити.

ДРАБИНА ВПЕВНЕНOSTI



Чотири щаблі, на які піднімаєшся лише за незалежними сигналами: слабкий, помірний, сильний, підтверджено.

Драбина важить у Томі 3 більше, ніж будь-де. Ти читаєш сліди, які ніколи не проєктувалися когось ідентифікувати — тінь, серійник у WHOIS-записі, геш фавікону, — і дуже легко сплутати наштовхуючу форму з доказом.

Незалежність, і чому вона тут важка

Два факти з того самого підмурового джерела рахуються як один голос. У Томі 2 це переважно було про те, щоб не рахувати двічі самопов'язаний нік. У Томі 3 пастка більша: WHOIS-запис, реверсний DNS того самого хоста і сертифікат, який цей хост віддає, — це часто *три вигляди того самого файлу*, налаштування одного оператора, а не три незалежні сигнали. Навчись щоразу питати: *чи були б обидва ці факти правдою, якби моя теорія була хибною?* Якщо відповідь «ні» — у тебе один сигнал, а не два.

Межа, і де зупинятися

Тільки відкриті джерела. Ніяких логінів, ніяких обходів, ніякого скрапу за пейволом чи robots.txt, ніяких розмов з ціллю під фальшивим ім'ям. Методи Тому 3 дуже полегшують «йти далі» — від домену до хоста, від хоста до клієнта, від клієнта до будинку, — тож назви легітимне питання, на яке ти відповідаєш, одним простим реченням, перш ніж робити перший півот. Якщо не можеш — у тебе цікавість, а не кейс.

Основи в руках? Добре. Ходімо в поховані місця.



РОЗДІЛ ПЕРШИЙ

Привид у кеші

Коли ціль тисне «видалити», вона видаляє лише ту копію, якою володіє.

Член міської ради вичищає передвиборну сторінку в п'ятницю ввечері. До неділі післяобідні сторінки вже немає в жодному місці, де він додумався подивитися, і він спить трохи спокійніше. Він вбиває власне ім'я у пошуковий рядок і бачить лише чисті результати. Каже голові свого штабу, що проблему залагоджено.

Він помиляється, і не тому, що пропустив якесь налаштування. Він помиляється, бо контролював лише одну копію.

Новачок відкриває той самий URL у понеділок, бачить 404, пише «видалено» в нотатках і закриває вкладку. Саме тут вмирає більшість кейсів — не тому, що робота важка, а тому, що слово *видалено* звучить остаточно, а інтернет привчив нас йому довіряти.

Професіонал відкриває той самий URL, бачить той самий 404 — і майже нічого не відчуває. Сторінка під його контролем — не цікава сторінка. Цікаві сторінки — ті, якими він ніколи не володів: знімок з архіву за 2020-й, блог прихильника, що процитував три абзаци дослівно, новинний агрегатор, який кешував прев'ю-картку, сусід, що зробив скріншот поста, щоб з ним посперечатися, RSS-стрічка, яка витягнула заголовок у базу, що її ніхто не чистив шість років. Кожна копія має свого власника, свій графік, свою криву занепаду. Жодна з них не чула про видалення в п'ятницю ввечері.

Цей розрив між тим, у що вірить ціль, і тим, що пам'ятає екосистема, — і є вся тема цієї глави.

Ідея: твоє «видалити» торкається лише твоєї копії

Публікація в сучасному вебi ближча до чхання в переповненій кімнаті, ніж до писання в приватному щоденнику. Тієї миті, коли ти постиш, інші системи тягнуться і беруть копії з причин, які не мають до тебе жодного відношення: щоб проіндексувати, щоб показати прев'ю, щоб заархівувати, щоб вбудувати, щоб процитувати, щоб посперечатися. Кожна копія живе за чужим графіком. Коли ти тиснеш «видалити», ти говориш лише з тим одним сервером, що довіряє твоєму логіну. Інші не отримують повідомлення, а більшість із них і не діяли б, якби отримали.

Це принцип. Усе інше в цій главі впливає з нього.

Видалення під контролем користувача — не є видалення в екосистемі.

Корисна ментальна модель — розпад кешу. Кожна копія сторінки має період напіврозпаду — деякі короткі, деякі абсурдно довгі. Прев'ю-текст пошуковика може оновитися за дні. Великий вебархів може тримати знімок десятиліття або довше. Скріншот у друга не має терміну придатності взагалі; він живе, доки друг не почистить телефон, а це фактично назавжди. Якщо ти розумієш криві розпаду — ти розумієш, де шукати і скільки в тебе є часу.

THE CACHE TREE



delete removes the trunk — the branches keep their own lives

Одна видалена сторінка розгортається у шари з дико різними періодами напіврозпаду — одні вимірюються годинами, інші десятиліттями, — а твоя кнопка «видалити» дістає лише до стовбура.

Із цього випливає дві речі. Жоден окремий шар не є повним — якщо ти нічого не знайшов у Wayback, ти не шукав, ти шукав в одному місці. І шари старіють з різною швидкістю, тож кейс, холодний у 2026-му, ще може бути теплим усередині агрегатора, який ніхто не чистив із 2019-го.

Де копії реально живуть у 2026-му

Є сім шарів, які варто перевірити, перш ніж називати щось зниклим. Вивчи їх як чек-лист. Не пропускай шар лише тому, що минулий кейс його не потребував — різні цілі проступають у різні шари.

- **Загальні вебархіви.** Wayback Machine і archive.today — робочі коники. Wayback працює на масштабі й автоматизації; archive.today працює на людях, які зберігають сторінки вручну, і ловить речі, які Wayback часто пропускає (пейволні новини, окремі твіти, сторінки, які власник сайту попросив Wayback приховати). Різні інструменти, різне покриття — перевіряй обидва.
- **Цільове архівування дослідниками й активістами.** Малі кільця знімків, які тримають академіки, журналісти й ентузіасти, — монітори політичної реклами, трекери екстремізму, дзеркала імідж-бордів, дзеркала судових документів. Вузькі, але глибокі, і часто зберігають те, чого великі архіви ніколи не торкалися.
- **Кеші пошуковиків.** Оператор Google cache: тихо припинено у 2024-му, а посилання на кешовану сторінку більше не з'являється у результатах. Bing довше тримав версію фічі, але зрідив її. Стався до кешу пошуковика як до бонусного шару, а не надійного, — у більшості днів він порожній.
- **Фронтенд-дзеркала і read-only фронтенди.** Кілька років існували легкі read-only фронтенди для великих платформ — патерн Nitter для Twitter, Bibliogram для Instagram, Invidious для YouTube. Більшість публічних інстансів мертві до 2026-го, оскільки платформи зтягнули свої API. *Патерн* усе ще повторюється: коли платформа ворожа до читання без логіна, хтось буде

скрапер-дзеркало. Деякі з цих дзеркал тихо зберігають контент, який джерело з того часу видалило.

- Синдикація й RSS-агрегатори. Новинні скрапери, читалки стрічок і сервіси email-дайджестів тягнули сторінку в момент публікації і зберігали заголовок, прев'ю-текст і часто перші абзаци у власній базі. Багато з них побудовані у 2011-му і ніколи не збиралися сміттярем. Їхні пошукові поля старі й повільні, і вони — золоті жили.
- Треті сторони, які цитували або скріншотили. Блог прихильника копіює три абзаци. Критик вставляє все у гілку форуму, щоб з цим посперечатися. Журналіст скріншотить твердження для матеріалу. Ніщо з цього не видаляється, коли видаляється джерело, — у них свої власники і свої причини тримати копію.
- Згадки, до яких видалення не дістало. Коментарі, які ціль лишила під чужими постами. Фото, на яких ціль позначили. Треди відповідей. Цитати-пости на інших платформах. Кеші вбудовувань на новинних сайтах, які підтягли віджет. URL-и шейрів, розіслані у груповий чат два роки тому. Ціль видалила сторінку; вона не видалила власних слідів на чужих сторінках, і ніщо в натисканні «видалити» на стовбурі не торкається листя.

Що досі працює у 2026-му, а що тихо померло

Старіші посібники — включно з першим виданням цієї книги — спиралися на жменю ходів, які більше не поводяться так, як раніше. Швидше за погану стрижку старить розслідувача те, що він упевнено запускає хід, який платформи закрили роками тому. Тож вивчи ідею під кожним мертвим трюком і йди шукати сучасний еквівалент.

- **Google cache:** зник. Двадцять років ти міг набрати `cache:example.com/page` і прочитати копію сторінки, яку зберігав Google. Посилання зникло з результатів пошуку на початку 2024-го, а сам оператор більше не працює.

Принцип тримається: пошуковики все ще пожирають сторінки і все ще тримають внутрішні копії для ранжування. Те, що ти досі бачиш, — це *сниппет*: два рядки під синім посиланням, часто попередній перегляд тексту, який сайт уже прибрав. Читай сниппети уважно; це кеш у мініатюрі.

- **Іменовані фронтенд-дзеркала переважно мертві.** Публічні інстанси Nitter, які передавалися по Slack-каналах у 2022–2023-му, здебільшого зникли; останні інстанси Bibliogram відгнали тоді ж. **Принцип тримається:** коли платформа замикає читання без логіна, хтось будує легший фронтенд, який скрапить публічні частини. Не запам'ятовуй назву сервісу, запам'ятовуй *форму* — «read-only дзеркало платформи X» — і йди шукати те, що вижило цього року.

- Wayback не є повним, і він не вічний. Два припущення, від яких треба відучитися. Wayback має не кожен сторінку — багато сайтів виключено, і його покриття соцплатформ тонке і тоншає. Покриття також розпадається з причин, які не мають нічого спільного з robots.txt — Internet Archive припинив дотримуватися його ретроактивно ще у 2017-му. Знімки зникають тому, що власники сайтів заповнюють форму виключення, тому що DMCA й аналогічні тейкдауни знімають конкретні кепчури, і тому що великі платформи борються з краулерами достатньо жорстко, щоб навіть ті знімки, що існують, часто були JavaScript-оболонкою, стіною логіна чи помилкою рендеру, вбраною в сторінку. Принцип тримається: архіви пам'ятають те, що ціль забула. Але не все, і не назавжди — перевіряй сестринські архіви й записуй те, що знайшов, поки ще можеш це побачити.

Перш ніж дивитися

Два стоп-знаки, обидва варті поваги.

Архіви не пасивні. Wayback логуює запити. archive.today логуює запити. Обмеження швидкості існують і кусатимуть, якщо їх молотити, а спалений ІР може коштувати кейсу. Рухайся людською швидкістю. Якщо у сторінки три знімки — завантаж три знімки, не скрап весь календар. І ніколи не запитуй свіжий кепчур сторінки живої цілі, якщо ти не подумав добре про те, що робиш. Три причини. По-перше,

це *тел* — деякі архівні сервіси тягнуть URL з IP, який сайт цілі логує, деякі тригерять краулери прев'ю-посилань, які впливають в аналітиці цілі, а уважний суб'єкт, що дивиться на логи реферерів, бачить незнайомця, який питає про нього поіменно. По-друге, ти назавжди зберігаєш контент, на розпад якого ціль, можливо, розраховувала; у контексті охоронного припису, захисту джерела чи протидії сталкінгу це не нейтрально, це дія, яку ти вчинив під запис. По-третє, у деяких юрисдикціях навмисне збереження матеріалу живої особи в справі про переслідування чи заборонний припис може розглядатися як втручання в її права над власними даними. Не юридична порада; робоче правило те саме в обох випадках. Читай те, що вже існує; не викликай нових доказів у буття без реальної причини.

Другий стоп-знак — OPSEC на твоєму боці. Використовуй чистий дослідницький браузер без залогіненого Google — суміжні з кешем продукти Google логують кожен URL, який ти забираєш, під твою ідентичність, а історія досліджень, змішана з особистою пошуковою історією, — це витік, що чекає свого дня. Вимкни синхронізацію. Використовуй профіль, який не носить твоїх справжніх кукі. Нудна гігієна, і найбільше вона важить у той день, коли ти про неї забув.

Метод, крок за кроком

Крок 1 — зафіксуй форми URL. У сторінки більше адрес, ніж ціль колись про це думає. Канонічна форма (example.com/post/1234), «вітринна» (example.com/@dale/purnell-for-district-4), форма шейра (example.com/s/aB3xQ), форма вбудовування (example.com/embed/1234), мобільний піддомен (m.example.com/...), варіант AMP чи режиму читання, глибоке посилання на конкретний коментар. Різні кеші індексували різні форми. Запит у Wayback на канонічний URL може повернути нічого; той самий запит на share-URL — п'ять знімків. Випиши всі правдоподібні форми, перш ніж робити будь-який запит.

Крок 2 — пройди таймлайн Wayback. Відкрий web.archive.org/web/*/<url> і прочитай увесь календар, не лише останній кепчур. Найсвіжіший знімок часто найменш корисний — його могли зробити *після* видалення, і він показує 404. Старіші знімки зазвичай багатші, зроблені тоді, коли ціль ще публікувалась відкрито. Записуй *час зняття* кожного збереженого знімка; саме ця мітка часу важлива, а не сьогоднішня дата.

Спробуй (2026). Візьми будь-який публічний акаунт, за яким стежиш, — свій підійде. Відкрий web.archive.org/web/*/<URL їхнього профілю> і прочитай таймлайн зверху донизу. Помічай, як покриття скупчується

навколо подій (вірусний пост, згадка в новинах) і рідшає в тихі місяці. Позначай останній кепчур перед тим, як в акаунті сталося щось значуще, — перейменування, переписування біо, перехід у приватний режим. Саме той «останній перед зміною» знімок був би тобі потрібен у реальному кейсі, і знаходити його має відчуватися рутинним, а не хитрим.

Крок 3 — перевір сестринські архіви. Спершу archive.today — він ловить те, що Wayback відмовляє чи пропускає, особливо окремі соцпости і пейволні новини. Далі, залежно від країни й теми цілі, перевір спеціалізовані архіви: Perma.cc — на щось, що міг зберегти юрист чи академік, UK Web Archive — для .uk-доменів і британських публічних органів, Arquivo.pt — для португаломовного контенту, вебархіви національних бібліотек в інших країнах. Згадую їх тут як *форму*, не як рекомендацію, — суть у тому, що «вебархів» — це не один сервіс, це родина, і різні члени зловили різне.

Крок 4 — читай те, що лишили за собою пошуковики. Посилання cache: мертво. Сніппет — ні. Запусти site:example.com "<рідкісна фраза з видаленої сторінки>" і прочитай двохрядкові прев'ю під кожним результатом. Прев'ю-текст генерується з внутрішнього знімка, який рушій не обов'язково оновив. Якщо у цілі був характерний зворот — гасло, незвичайне ім'я, дивно конкретне число, —

цитатний пошук по відкритому вебу покаже, де ще воно приземлилось. Рідкісна фраза — це відбиток; поширена — це шум.

Крок 5 — іди за третіми сторонами, які цитували. Якщо публічна фігура сказала щось цитовне — хтось процитував. Реверс-пошук зниклого аватара, щоб знайти блоги і форумні пости, які його вбудували. Цитатний пошук характерного речення, яке ти пам'ятаєш зі сторінки, — зі скріна в новині, з власних нотаток, з розбору критика. Сайти-агрегатори, блоги думок і форуми однієї теми — неprestижні і багаті.

Крок 6 — обмети екосистемні копії. Видалення не торкнулося коментарів, які ціль лишила під чужими постами, помічених фото, цитат-відповідей чи URL-ів шейрів, вставлених у публічні групові чати. У соцмережах шукай *хендл* цілі, а не її профіль, — отримаєш кожну згадку, і кожна згадка — фрагмент сторінки, яку вона знесла.

Крок 7 — дисципліна свіжості. Для кожного твердження в нотатках записуй URL *конкретного знімка*, з якого ти його взяв, і його *час зняття*. Не «знайдено на Wayback». URL знімка з міткою часу — це посилання; «Wayback» — це чутка. Коли ти ставиш твердження на драбину — слабкий / помірний / сильний / підтверджено — переконайся, що кожен опірний сигнал вказує на знімок, а не на пам'ять.

Розібраний кейс, з тупиками включно

Дейл Пернелл — вигаданий, зі середнього заходу, четвертий округ міської ради — програв перевибори 2019-го на сторінці Facebook «Purnell for District 4». Після скандалу на початку 2026-го щодо контрактного рішення часів його старого терміну сторінка тихо видалена разом із його особистим акаунтом. Репортерка місцевого тижневика, полюючи на те, що Пернелл насправді обіцяв виборцям у 2019-му про той контракт, питає, чи можна відновити хоч частину передвиборної сторінки. URL, який у неї є, — facebook.com/purnellfordistrict4.

Тупик Google cache. Перший інстинкт — стара м'язова пам'ять — `cache:facebook.com/purnellfordistrict4`. Google повернув сторінку «немає результатів». Оператор мертвий; м'язова пам'ять — це погана звичка. Далі.

Тупик Wayback. У Wayback було три знімки. Два — JavaScript-оболонка: Facebook рендериться на клієнті, і знімок захопив спінер завантаження, і більше нічого. Третій — свіжіший за інші й ударився в іншу стіну: коли краулер Wayback дістався до сторінки, антикраулерна оборона самого Facebook повернула запрошення логіна і рендер-оболонку, і саме це збереглося. Ранніші кепчури на цьому домені порідшали і зі звичайних причин — виключення власника сайту і тейкдауни працюють ретроактивно, навіть коли `robots.txt` — ні.


```
wayback listing for purnellforddistrict4
```

```
-----
```

```
* facebook.com/purnellforddistrict4
```

```
snapshots found: 3
```

```
2019-10-14 captured (JS shell)
```

```
2019-11-02 captured (JS shell)
```

```
2023-04-18 unusable (auth wall)
```

```
-----
```

```
0/3 usable
```

Три знімки, три стіни.

Тупик archive.today. У archive.today був один знімок, з жовтня 2019-го. Цей реально відрендерився — справжня сторінка, справжні пости, справжній закріплений контент угорі. От тільки знімок був вигляду профілю, а не окремого поста, і закріплені коментарі під кожним постом — де у 2019-му Пернелл відповідав виборцям на питання про контракт, іноді розлого, — були згорнуті і не захоплені. Знімок зберіг стіну і втратив розмови.

Поворот. У репортерки було одне, з чим працювати: вона пам'ятала фразу з промов Пернелла — «розумне господарювання дровами округу» — яка на сторінці з'являлася дослівно не раз. Цитатний пошук цієї фрази, обмежений блогами і новинами, — це і була щілина.

dork: "prudent stewardship of the district's dollars"

1. citizenswatch-oakhaven.blog 2019-09
"quoting Purnell's page in full below..."
2. district4-neighbors forum 2019-11
thread: "what did he actually promise"
3. oakhaven-weekly.com/rss.xml 2019-10
preview: "...prudent stewardship..."

3 hits, all 2019, all outside FB

Фраза пронесла там, де URL — ні.

Перший результат — громадянський вотчдог-блог, який у вересні 2019-го вставив три абзаци з контракт-політичного поста Пернелла повністю: блогер хотів посперечатися з ними рядок за рядком і в процесі зберіг їх рядок за рядком. Другий — сусідська форумна гілка «що він насправді обіцяв», у якій учасник скріншотнув пост, а хтось інший переписав під ним текст. Третій — RSS-стрічка власного агрегатора місцевого тижневика, який тягнув пости Пернелла з Facebook у бічний віджет ще у 2019-му і ніколи не чистив базу; прев'ю-тексти шести постів досі лежали там, адресовні за URL, якщо ти знав патерн.

Ранжування. Цитата з блогу сама по собі — сильний для тих абзацив, які вона цитує: це дослівно, це датовано вереснем 2019-го в архіві самого блогу, а у блогера не було мотиву фабрикувати цілі, яку він і так критикував своїми словами. Скріншот з форуму плюс переклад у текст — помірний (скріншот можна відредагувати, а переклад

вводить другу точку відмови), але там, де він перекривається з блог-цитатою, — підтверджено, а там, де він виходить у закріплені коментарі, яких блог не торкався, лишається помірним. RSS-агрегатор — помірний для прев'ю-тексту, і не більше: прев'ю — це фрагмент, а фрагменти без сусідніх абзаців бувають оманливими.

Репортерка отримала часткову реконструкцію видаленої сторінки з посиланнями на три незалежні джерела з часами зняття і чітку лінію про те, які абзаци вона може цитувати як *написане Пернеллом* (сильний), а які — як *що він, схоже, написав* (помірний). Видалення Пернелла дістало до стовбура. Воно не дістало до блогу, форуму й агрегатора і ніколи не дістане.

Другий кейс: той, що не закривається

Інший запит того самого місяця. Приватний акаунт Instagram, видалений у середині 2022-го, начебто належить свідку в цивільній справі. Ніякого архівного покриття — у Wayback нуль знімків на вітринному URL і нуль на числовому ID; у archive.today немає; спеціалізовані кільця, що дзеркалять контент Instagram, ніколи не бачили цього хендла. Аватар кешовано в одному стороннім аналітичному інструменті на публічному прев'ю, але зображення — стоковий захід сонця, і реверс-пошук вертає тільки сток. Ніхто акаунт не цитував. Скріншотів у відкритому вебi не сплило. Район, з якого акаунт постив, малий настільки, що форумний пошук мав би підняти *щось*, — і не підняв.

Звіт клієнту: атрибутувати не вдалося. Жоден шар не заплатив. Я дав їм список шарів, які перевірів, запитів, які прогнав, і часів зняття негативних результатів, — щоб, якщо кейс потім відкриється, було відомо, що вже пробували. Безлад — це робота, а не помилка.

Безпечна вправа

Візьми публічну новинну статтю, яку пам'ятаєш, за три і більше роки тому — національна подія, місцеві вибори, будь-що з реальною журналістикою. Відкрий Wayback і пройди таймлайн кепчурів статті. Прочитай найраніший кепчур, середній і найсвіжіший. Помічай виправлення, змінені заголовки, редаговані абзаци, фото, що поміняли або прибрали. Записуй час зняття кожного. Ти не розслідуєш нікого; ти тренуєш око бачити, як один URL — це насправді сім'я версій, і що версія, яку ти знаходиш сьогодні, може бути не тією, яку хтось читав у день, коли це важило. Той рефлекс — *яку версію я бачу і коли її зняли* — це вся дисципліна в мініатюрі.

Підсумок

- Видалення під контролем користувача — не є видалення в екосистемі; копії, якими ти не володів, лишаються копіями.
- У кожної копії своя крива розпаду; одні шари оновлюються за дні, інші тримаються десятиліттями.
- Перевіряй усі сім шарів, перш ніж назвати сторінку зниклою; не пропускай шар лише тому, що минулий кейс його не потребував.
- Google cache: мертвий, фронтенд-дзеркала здебільшого теж, Wayback не є ні повним, ні вічним. Вчи принцип, а не

інструмент.

- Рухайся людською швидкістю в архівах; ніколи не запитуй свіжий знімок сторінки живої цілі, якщо не знаєш, чим торгуєш.
- Зафіксуй усі форми URL перед запитами; різні кеші індексували різні форми.
- Записуй *час зняття* кожного знімка у нотатках і посилайся на конкретний URL знімка, а не на головну сторінку архіву.
- Деякі кейси не закриваються, і звіт «атрибутувати не вдалося» з переліком перевірених шарів — це реальний результат.

Що далі

Наступна глава переходить від видалених *сторінок* до видалених *акаунтів* — акаунтів, закритих, перейменованих чи вичищених самою людиною за ними, — і від того, скільки людини залишається стояти після того, як зникає її акаунт.



РОЗДІЛ ДРУГИЙ

Реконструкція видаленого акаунта

Акаунт залишає платформу. Людина не залишає екосистему.

Ти вбиваєш хендл у адресний рядок, і сторінка вантажиться пів секунди, перш ніж платформа вирішує. *Sorry, this page isn't available.* Ні аватара. Ні банера. Ні 404 з дружнім мультиком. Просто типова стіна, яку сайт показує, коли акаунт видалений, деактивований чи вичищений командою довіри.

Більшість людей закривають вкладку. Дехто пробує інший регістр хендла. Кілька додумуються перевірити кеш,

отримують один результат — і на цьому спиняються.

Ти зробиш більше, бо стіна, яку ти щойно зустрів, — це стіна на *одній* вітрині. За нею людина, що тримала цю вітрину, була позначена на весільних фото, процитована в місцевій газеті, додана до групи старим колегою і згадана у пості до вечері торгової палати. Ніщо з цього не жило на її профілі. Воно жило на профілях інших людей, на серверах інших людей, у кешах, які нікому з її знайомих не підзвітні. Акаунта немає. Людини — є.

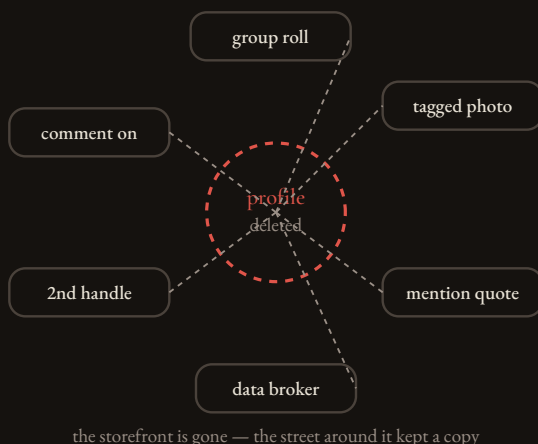
Ця глава — про перебудову людини з того, що зберегла екосистема. Це інша робота, ніж у Главі Першій. Там ти рятував конкретний *пост*, який хтось зніс. Тут ти рятуєш *ідентичність*, яку хтось намагався закрити. Техніки римуються. Тертя важче, і етика теж.

Ідея: людина — не профіль

Уяви видалений акаунт як орендовану вітрину на жвавій вулиці. Поки орендар був там, він висувався у вікно, махав сусідам, приєднався до розсилки вулиці, з'являвся на задньому плані фото інших крамарів, посварився з покупцем, який про це написав у місцеву газету. Коли він віддає ключі, орендодавець зафарбовує вивіску. Ось що означає «акаунт видалено»: крамниця порожня, вивіски немає.

Усе інше лишається. Сусіди досі мають свої фото. Розсилка досі має стару адресу. Газета досі має статтю. Клієнти досі пам'ятають. Орендодавець — платформа — може вирішувати лише щодо самої крамниці. Він не може пройти вулицею і стерти пам'ять кожного.

THE DELETED RING



Центр — зачинена вітрина: профіль, який більше не резолвиться. Навколо, все ще підсвічені, — стіни сусідів, що позначали цю крамницю, реєстри груп, які її називали, архіви, які її знімали, брокери даних, які продали копію її вивіски роки тому, і другий акаунт нижче по кварталу, який ніхто не додумався закрити.

Видалити вітрину — це не видалити вулицю. Твоя робота — пройти нею.

Що виживає, коли профіль помирає

Точний перелік плаває від платформи до платформи і від року до року, але форма тримається. Коли самого профілю немає, у тебе зазвичай лишається якась підмножина такого.

- Помічені фото на чужих стінах. Фото, на якому цю людину позначили, живе на сторінці *автора*. Позначка перетворюється на «user unavailable» після видалення, але підпис автора часто досі називає людину відкритим текстом, а обличчя досі в кадрі.
- Коментарі, які ціль лишала під публічним контентом. Треди на публічних сторінках новин, у постах брендів, на спільнотних сторінках і у створювачів контенту часто зберігають старі коментарі цілими після смерті акаунта коментатора. Ім'я користувача згортається до плейсхолдера; текст — і часто кешована мініатюра аватара — лишається.
- Реєстри членства груп і сторінок. Списки учасників, RSVP на подіях, списки модераторів сторінок, адмінські логи живуть на боці групи. Чистка після видалення користувача нерівномірна — ім'я досі буде в «past attendees», у старих кредитах адмінів і на фото з подій.
- Крос-постингові цитати і вбудовування. Твіт, вбудований у пост блога 2019-го, — це копія цього твіта, віддана блогом, а не платформою. Шейр із YouTube community tab, який канал перевиклав у розсилку, — це

копія в розсилці. Видалення оригіналу не дістає до вбудовування.

- Витоки платформних даних, що передували видаленню. Скрап Facebook 2019-го, скрап LinkedIn 2021-го, різні дампи форумних баз, що ходять на ринках витоків: якщо людина була на платформі на ту дату, її запис у цьому дампі і там і лишиться. Поводься обережно і лише в законних цілях.
- Знімки брокерів даних. Люди-пошуковики, дзеркала бізнес-реєстрацій і директорні скрапери роками захоплювали публічні профілі і ніколи не перевіряли повторно. Профіль, видалений у 2024-му, можна ще відтворити зі знімка брокера 2019-го, часто зі старою біо, старим роботодавцем і старим фото.
- Залишки френд-графа на чужих акаунтах. Власного списку друзів цілі немає разом з нею, але на платформах, де списки друзів можна лишати публічними, вона досі з'являється всередині *чужих* списків — як безіменний плейсхолдер або як старе відображуване ім'я, збережене у кешованих копіях. Кластер відкритих профілів, які всі мовчки містять того самого зниклого друга, — це відбиток.
- Другі й старі акаунти на крос-платформах, про які людина забула. Люди видаляють гучний акаунт і лишують тихі: старий DeviantArt з арт-школи, Goodreads під псевдонімом, Strava, Letterboxd, старий блог на

неіснуючому хості. Це рідко потрапляє під зачистку «видали мою присутність».

Що тихо припинило працювати

Три ходи, яких старіші посібники впевнено вчили, більше не роблять роботу, яку робили. Вивчи, що вмерло, а що — ні.

- **Facebook Graph Search.** Роками ти міг перелічувати друзів названої особи, фото, зроблені в місці, пости, які лайкав користувач, — через структуровані пошукові запити. Facebook прибрав Graph Search у 2019-му.

Принцип тримається: френд-граф досі найкоротша мапа від видаленого акаунта до реального життя людини.

Просто не можна більше запитати централізовано. До нього дістаєшся, ходячи відкритими друзями руками.

- **Публічні сторінки «people you may know» LinkedIn.**

Раніше їх можна було краулити без логіну, і вони давали 2-й ступінь мапи цілі напряду. Тепер вони за

акаунт-стіною, а пробування їх із залогінованого акаунта зливає тебе в сітку рекомендацій цілі (двонаправлена

РҮМК-пастка, розглянута у Томі 2). **Принцип**

тримається: 2-е коло досі видає прихований 1-й. Просто його треба будувати з інших публічних сигналів, а не зі скрапленої сторінки.

- **Масові скрапери списків друзів.** Технічно можливі на деяких платформах, категорично — порушення їхніх умов сервісу, і в суді безкорисні. Ми так не робимо. **Принцип**

тримається: ціль з'являється знову у відкритих списках людей, які її знали. До цього ти дістаєшся ручним читанням того, що ці люди самі вирішили лишити публічним, а не скриптом-жаткою. Будь-який інструмент чи сервіс, що обіцяє інакше, продає тобі позов.

Якщо якась техніка в цій главі називає конкретний сайт чи endpoint, вважай, що він може бути мертвим до того, як ти це прочитаєш. Форма ходу переживає двері.

Перш ніж дивитися

Перебудова видаленої ідентичності лишає більше слідів на більшій кількості людей, ніж майже будь-яка інша робота в цій книзі. Друг, чий альбом весілля ти завантажив десять разів, побачить сплеск у лічильнику переглядів. Старий блог, який ти тягнеш тричі з трьох різних знімків, покаже у своїх логах маленький патерн. Якщо твоя робота чутлива, стався до кожного запиту як до видимої події на чужій власності і поведься як гість, що знає, що його помічають.

Використовуй нормальний дослідницький браузер — окремий профіль, ніяких особистих логінів, ніякої синхронізації контактів, ніякого доступу до адресної книги, ніякої телеметрії до твоєї реальної ідентичності.

Двонаправлена «people you may know» проблема з Тому 2 діє тут на повну силу: пробування старого кола цілі з залогіненого дослідницького акаунта може винести *твій* дослідницький акаунт саме до тих родичів і колег, яких ти

тихо читаєш. Так помирають сок-акаунти і горять кейси.

І етика. Людина, яка видалила акаунт, під запис у платформи обрала, щоб та її забула. Скасовувати цей вибір — не нейтрально. Май реальну причину, яку можеш назвати вголос, — законне розслідування, суспільно важливий матеріал, шахрайство, яке ти документуєш, людина, яку ти намагаєшся возз'єднати з членом родини, — і бери лише те, що відповідає на це питання. Видалений профіль — сильніший сигнал приватності, ніж закритий, і заслуговує сильнішого виправдання, перш ніж його обходити.

Метод, крок за кроком

Крок 1 — заякори те, що вже знаєш. Запиши: справжнє ім'я цілі у формах, які ти бачив написаними, останній хендл, під яким ти її знав, обличчя, якщо є, місто, роботодавця, відомого спільника, приблизну дату, коли акаунт погас. Це твій пошуковий набір. Усе нижче обертається навколо нього, і кожен збіг, який ти знайдеш, звіряється з ним. Заякорюй першим, завжди.

Крок 2 — прохід по кешу. Перш ніж щось важке, прожени URL видаленого профілю через архіви — Wayback Machine, кеші пошуковиків, менші дзеркала, розглянуті у Главі Першій. Це дешева перевірка, яка іноді відповідає на все питання за десять секунд. Зроби її і йди далі; не проводи тут день.

Крок 3 — реверс-пошук останнього відомого аватара. Якщо можеш дістати *будь-яку* копію старого аватара — позначку друга, кешовану членську картку групи, знімок брокера з 2020-го, останню архівовану версію профілю, — прожени її реверсом у двох-трьох рушіях. Свіжий акаунт під іншим ім'ям з тим самим обличчям — один із найпоширеніших патернів «я видалив свою присутність» у реальному житті: люди рідко роблять нове фото просто тому, що взяли новий хендл.

Крок 4 — обійди коло згадок. Пошукай справжнє ім'я цілі відкритим вебom з відкиданням платформ: "Ilse Vroeg"-site:facebook.com -site:instagram.com. Читай, що про неї писали інші, — цитати преси, пости блогів, форумні треди, місцеві новини, протоколи спільнот. Якщо знаєш рідкісну фразу з її старої біо — цитатний пошук. Якщо у неї було рідкісне по батькові чи рідкісне місце роботи — вмикай.

Спробуй (2026). Візьми людину, яку ти особисто знаєш і яка роками тому видалила соцакаунт, — і яка нормально ставиться до того, що ти зробиш це як вправу. Зроби на ній лише Крок 4. У чистому браузері прожени її справжнє ім'я плюс місто у лапках з фільтрами -site: для платформ, які вона покинула. Прочитай перші дві сторінки результатів і випиши кожну згадку про неї на *чужій* власності: пост блогу друга, шкільна розсилка, результат забігу, весільне оголошення, довідник палати. На цьому спини. Покажи їй

список. Спитай, що вона вважала зниклим, а що здивувало. Ця реакція — зазвичай тихе «ой» — і є вся суть уроку.

Крок 5 — реєстри з боку групи. Ціль може вийти з групи; *фото, яке вона виклала* до спільного альбому групи, і *коментар, який вона лишила* під чужим постом усередині групи — дуже часто лишаються. Перевір кожну групу і сторінку, з якою можеш її пов'язати: списки минулих учасників на сторінках подій, кредити «засновників» на сторінках спільнот, треди коментарів під оголошеннями групи за рік її активності. Метадані членства ведуться на боці групи і чистяться нерівномірно.

Крок 6 — мапа 2-го ступеня. Візьми двох-трьох відомих спільників, чиї власні зв'язки досі публічні. Прочитай *їхні* списки контактів руками і зазнач тих, хто повторюється. Кластер із п'яти людей, які всі, здається, знають людину, у якої більше немає акаунта, і чиї коментарі до старих постів згадують її по імені, — сильний підпис реального кластеру. Тільки ручний огляд. Ніяких скриптів, ніяких перетинів, ніяких скраперів. Те, що уважний читач може тримати в голові, — це рівно та кількість роботи, яку правила дозволяють.

Крок 7 — читання старих брокерів даних.

Люди-пошуковики і директорні дзеркала часто зберігають знімок профілю задовго до видалення. Читай їх на те, що ціль колись публічно казала про себе: біо, роботодавець,

місто, пов'язані адреси, пов'язані телефони. Стався до кожного поля як до зачіпки, а не факту. Брокери славляться помилками — не той ініціал, не те місто, «відомий спільник», який насправді незнайомець з тим самим прізвищем, — і весь файл часто зшитий із трьох людей із схожими іменами. Збіг брокера дає тобі гіпотезу, яку треба перевірити деінде. Він не дає тобі висновок.

Крок 8 — ранжуй кожен фрагмент на драбині. Вишикуй те, що знайшов, зваж і будь чесним. Позначка на весільному фото — помірний. Позначка плюс запис брокера, що називає того самого роботодавця, плюс цитата біо на сайті палати — сильний. Три брокери, що повторюють один одного, — це один брокер: вони всі купили в того самого оптовика. Зважуй перш ніж писати.

Розібраний кейс, з тупиками включно

Регіональна газета в маленькому європейському містечку попросила допомогти з матеріалом про раду благодійної організації, яка публічно скандалом у середині 2022-го виключила свою скарбничку. Вигадані імена, реальний метод. Скарбничка, Ілзе Врох, видалила свій Facebook та Instagram того ж тижня, коли голосування потрапило в місцеву газету. Питання репортерки було вузьким і відповідним: до скандалу, як Врох публічно позиціонувала свою професійну кваліфікацію? Конкретно, чи описувала її стара біо її як дипломованого бухгалтера чи як фінансового консультанта? Різниця важила, бо перше — регульований титул у її країні, а друге — ні.

Якір. Повне ім'я, місто, благодійна організація, місяць видалення і один відомий спільник — колега по раді, названий у газеті. Відомого фото поки немає. Запиши.

Прохід по кешу. У Wayback був один знімок її профілю Facebook, зроблений на початку 2022-го. Відкрився. Це була HTML-оболонка приватного перегляду платформи — стіна «you must log in to see this content», захоплена в момент знімка. Ні біо. Ні тексту. Нічого.


```
Wayback lookup: facebook.com/ilse.vroeg
```

```
-----  
snapshots 1  
  2022-03-14  captured  
opening 2022-03-14 ...  
  HTML = platform login shell  
  bio   = not present in capture  
  posts = not present in capture  
-----  
snapshot exists, content does not
```

Знімок стіни — це все ще стіна.

Тупик два. Вона була в списку учасниць публічної місцевої бізнес-групи. Реєстр учасників групи досі існував на її власній сторінці. Її рядок був цілий — але поле імені читалося *user deleted*, а посилання на профіль мертве. Доказ членства, біо — ні.

Тупик три. URL LinkedIn під її ім'ям, кешований у старому результаті пошуку, робив 302-редирект на «*profile not found*». Не знімок, просто заглушка сторінки, яка колись існувала.

Що реально втрималось. Обхід кола згадок по її справжньому імені плюс місто, з двома платформами відкинутими, дав три корисні речі.

Перше — регіональний скрапер бізнес-довідника, брокер, який пасе сайти палат і перевидає біо, — досі мав сторінку з її іменем і благодійною організацією, останнє оновлення 2021. Сторінка відтворювала те, що виглядало як копія її

старого «About» з Facebook слово в слово, включно з двохреченневим самоописом. Дані брокера, тож я поставився до цього як до зачіпки. Але я пошукав точну фразу в лапках по відкритому вебу, щоб побачити, чи це формулювання з'являється десь, де вона писала сама.

```
Mention ring, quoted phrase
```

```
-----  
QUERY  "financial consultant to  
        several non-profits in"  
        "Vroeg"
```

```
results  3
```

- 1) business-directory scraper
 (broker copy, 2021)
- 2) charity's own 2020 newsletter
 (PDF on their website)
- 3) local blog "chamber notes"
 (2020 post, quoted her bio)

```
-----  
same wording in three places, two  
of them non-broker sources
```

Дві незалежні неброкерські копії того самого точного формулювання.

Власна розсилка благодійної організації за 2020-й — PDF, досі розміщений на її сайті, — дослівно цитувала її біо в розділі «meet the board». Місцевий блог, що покриває події торгової палати, у 2020-му цитував той самий абзац у нотатці про подію, приписуючи його її самопрезентації з трибуни. Обидва вжили слово «фінансовий консультант». Жоден не вжив «дипломований бухгалтер». Копія брокера збігалася.

Друге — фотоальбом на сайті палати з вечері 2019-го, викладений іншим членом, позначив її повним іменем у підписі. Вона була в друкованому бейджі у першому ряду. Обличчя захоплене, ім'я захоплене, подія захоплена — усе на чужій власності, усе досі онлайн.

Третє — старий блог, що вів колишній колега по раді, мав «прощальний» пост 2018-го, який вітав її з вступом на посаду скарбнички і описував її попередню роль в одному рядку: *«консультантка, що допомогла кільком нашим сестринським благодійним організаціям»*. Узгоджено.

Куди це ставить драбину. Питання репортерки було вузьким: дипломований бухгалтер чи фінансовий консультант? Два незалежні неброкерські джерела — власна розсилка організації і місцевий блог — цитували те саме формулювання, а копія брокера збігалася. Фото з палати підтвердило, що це та сама Ілзе Врох, з якою мала справу організація, — на випадок, якщо хтось спробує оборону «однофамільниці». Сильний на конкретному твердженні. Я не пішов копати, *за що* саме її видалення, бо репортерка не питала, а весільні фото її кузини кузини не навчили б мене нічого корисного для роботи. Зупиняйся, коли відповідь приземляється.

Другий кейс: той, що не закривається

Інший запит, тижнем пізніше. Обличчя, витягнуте зі скріншота, нік, твердження, що людина тримала невеликий вендорський акаунт на маркетплейсі, який закрився у 2023-му. Акаунт видалено ще до оголошення про закриття. Ніяких архівів. Ніяких помічених фото у жодній сторонній стрічці, до якої я дістався. Реверс-пошук по обличчю не вертав нічого над тонким шумом. Два правдоподібні кандидати на ім'я впливли з дзеркал брокерів — обидва реальні люди, обидва приблизно правильного віку, обидва приблизно з правильного регіону, — і нічого їх не розділяло.

Я написав чесно. *Атрибутувати не вдалося; правдоподібних кандидатів на ім'я — два, розрізнити не можу; жодна незалежна нитка не достатньо сильна, щоб когось із них підняти.* Клієнту хотілось ім'я. Докази його не несли. Не закрити кейс — це робота, а не провал; а неправильне ім'я, дане впевнено, — це шкода, яку не забрати назад.

Безпечна вправа

Зроби це на собі. Візьми свій акаунт, який ти видалив роки тому, — старий MySpace, мертвий хендл ICQ, померлий форумний профіль, ранній Twitter, який ти знищив у свої двадцять, блог на хості, що збанкрутував. У чистому браузері прожени метод на собі: прохід по кешу, коло згадок по імені плюс епосі, перевірка брокерів, крихти 2-го ступеня від друзів, чиї списки досі відкриті. Подивись, що виживає. Запиши, що здивувало.

Ти знайдеш речі. Більшість людей знаходять. Тоді вирішуй пункт за пунктом, чи хочеш пробувати щось із цього прибрати, — і оціни, що людина на іншому кінці твоїх розслідувань дістає те саме відчуття у зворотньому боці.

Підсумок

- Акаунта немає. Людини — є. Те, що виживає, живе на чужій власності.
- Заякорюй те, що знаєш, перш ніж дивитися, — ім'я, обличчя, місто, спільник, дата видалення.
- Прохід по кешу — перший, дешевий і час від часу виграшний.
- Реверс-пошук будь-якого вцілілого аватара; свіжий акаунт під новим іменем — найпоширеніша самоміграція.
- Обходь коло згадок відкритим вебом з відкинутими власними платформами цілі.

- Реєстри груп, сторінки подій і треди коментарів ведуться на боці групи і чистяться нерівномірно.
- Знімки брокерів — зачіпки, не факти, а три брокери, що повторюють одне одного, — це один брокер.
- 2-й ступінь руками, ніколи скриптом; скрапнуті списки друзів порушують ToS і псують кейс.
- Зважуй усе на драбині; дві помірні нитки — це не сильна.
- Май названу причину, перш ніж перебудовувати видалену ідентичність, і бери лише те, що ця причина потребує.

Розділ третій проходить від одного впливлого фрагмента назад до цілого життя — перетворюючи одне вдале влучення на документоване, зважене портфоліо, не перечитуючи знайдене.



РОЗДІЛ ТРЕТІЙ

Читання фотографії на місце

Кожен знімок, який включає зовнішній світ, — це координата, що чекає, коли її прочитають.

Фотографія падає тобі в скриньку об 11:14 у вівторок. Без підпису. Без метаданих файлу — відправник зробив із неї скріншот, двічі, з застосунку, який усе зачищає по дорозі. Ти маєш кут балкона, пластиковий стілець, смугасту чашку, смужку неба кольору слабкого чаю і діагональний край іншого будинку, що нахилився в кадр. Жінку тримають десь проти її волі. Її сестра надіслала тобі знімок з бернера. Хтось

на іншому кінці телефона питає, де вона.

Ти не збираєшся вгадувати. Вгадують ті, кому картинка здається надто малою, щоб говорити. Ця картинка не мала. Ця картинка гучна. Вона гучна мовою, яку більшість людей не читає, і вся дисципліна цієї глави — навчитися її читати: пройти кадр елемент за елементом і дати кожному елементу викидати місця, якими це бути не може. Правильний настрій для роботи — *звужувати*. Не шукати. Звужувати. Ти починаєш з усієї Землі і віднімаєш.

Ідея: звужуй, не вгадуй

Геолокація за фотографією — це не удачне вгадування і не трюк на вечірці. Це контрольоване звуження. Кожен елемент, який ти можеш прочитати в кадрі, або *виключає* багато місць на Землі, або *концентрує* увагу на кількох. Дорожня розмітка виключає пів континентів. Номер на припаркованому скутері виключає пів того, що лишилось. Дерево у цвіті виключає пів решти. Зроби це десять разів терпляче — і Земля стискається до району. Зроби ще двічі — стискається до кварталу.

Одна рамка, яку ти маєш уміти сказати назад одним реченням: кожен видимий елемент або *виключає* місця, або *концентрує* на них увагу; робота — знімати виключення шар за шаром, доки не лишиться маленький набір. Усе нижче — техніка на службі цьому реченню.

Що фотографія насправді тобі каже

Перш ніж торкатися будь-якого інструмента, тобі треба знати, на що ти дивишся. Треноване око читає фото так, як механік слухає двигун — як стек незалежних сигналів, і кожен звужує поле.

- **Тіні й сонце.** Тінь показує від сонця. Її довжина відносно об'єкта, що її кидає, обмежує висоту сонця, а це обмежує час доби для даної дати і широти. У Північній півкулі вище Тропіка Рака сонце опівдні на півдні; у Південній нижче Тропіка Козерога — на півночі; між тропіками полуденне сонце може бути з обох сторін залежно від сезону, і сама ця неоднозначність — сигнал. Одна чітка тінь дає тобі півкулю і, з правильною астрономією, — широтну смугу.
- **Профіль рельєфу.** Далекі піки, плаский горизонт, лінія узбережжя, як пагорб піднімається за дахами — рельєф вперто локальний. Зубчаста снігова лінія над багатоквартирками виключає більшу частину планети. Дуже плаский горизонт виключає решту.
- **Дорожня розмітка і ширина смуг.** Колір фарби, малюнок пунктиру, співвідношення штриха і проміжку, ширина смуги, колір бордюру — усе варіює за країною і часто за десятиліттям перекладення. Жовті центральні лінії означають одне коло місць; білі — інше. Яскраво-білі пунктирні лінії узбіччя з шевроном вказують на

конкретний набір ПДР.

- **Знаки.** Знак «стоп» — восьмикутник майже всюди, але слово на ньому, товщина рамки, світловідбивна підкладка і кріплення різняться. Регуляторні знаки конкретним шрифтом і обмеженим алфавітом за секунди звузять до регіону всередині країни.
- **Автомобільні номери.** Колір фону, пропорції, набір символів, чи є синя бічна смуга в стилі ЄС, одно- чи дворядковий, чи є префікс штату чи області. Номери — найщільніший на піксель геолокаційний сигнал у більшості вуличних знімків.
- **Автомобілі й орієнтація.** Модель авто каже, у які ринки її продавали. Але найгучніший біт — з якого боку кермо. Правий кермо стискає світ до конкретного набору країн. Лівий кермо в правокермовій країні майже завжди означає, що авто імпортували з дуже конкретної причини — і це вже сигнал.
- **ЛЕП, стовпи, ліхтарі.** На диво регіональні. Дерев'яні проти бетонних стовпів. Колір і форма ізолятора. Скільки фаз тримає стовп — три чи одну. Ліхтарні світильники йдуть від невеликого числа виробників, чиї регіональні контракти стабільні десятиліттями.
- **Флора і сезон.** Джакаранда в фіолетовому цвіті бракетує кліматичну зону і місяць. Оливковий гай виключає більшу частину Північної півкулі. Клени в осінньому кольорі

звужують календар до тижнів. Навіть газонна трава читається регіонально тренованому оку.

- **Архітектура.** Ухил даху відповідає снігостійкості (крутий — під важкий сніг, пологий — без нього). Балкони читаються локально — іберійська плитка, французьке ковальство, радянсько-епохальні бетонні консолі, затінювальні екрани Затоки. Дивись саме куди кріплять кондиціонери — решітка в стіні під вікном, компресор на даху, спліт-система на спеціальній полиці: кожне — регіональна звичка.

- **Скрипт і мовні фрагменти.** Дволітерна аббревіатура на поштовій скриньці, кутик крейдяної дошки, вивіска в куті кадру, наліпка на ліхтарному стовпі. Навіть одне слово в характерному алфавіті звужує сильніше за сотню загальних підказок.

- **EXIF-залишки.** Якщо файл вижив із метаданими — читай їх *останніми*. Виробник камери, мітка часу і GPS можуть бути присутні, відсутні, зачищені або підроблені. Стався до будь-якого числа як до твердження, що треба звірити з усім іншим у кадрі, — ніколи як до факту, що перебиває те, що кажуть очі.

Читай знімок у три проходи

Дисципліна — це три проходи, і якщо пропустиш перший — ти упереджиш себе так сильно, що ніяким інструментарієм кейс не витягти.

Перший прохід — на голе око, без інструментів. Відкрий картинку на весь екран. Не відкривай вкладку браузера. Не завантажуй її нікуди. Запиши простим списком кожен елемент, який бачиш. «Блакитна плитка, шестикутний узор. Пластиковий стілець, білий. Фрагмент крейдяної дошки, ліворуч. Тент через вулицю, червоно-білі вертикальні смуги. Провід над головою, одна жила, дерев'яний стовп з ізолятором зверху». Список нудний. Нудність — це суть. Ти будуєш інвентар, перш ніж формувати теорію.

Другий прохід — сортування за виключенням. Для кожного елемента постав питання, що він *виключає*. Одножильний надземний кабель на дерев'яних стовпах виключає більшість новіших міських кварталів Західної Європи. Фрагмент крейдяної дошки з латинським скриптом виключає більшість Азії. Пластиковий стілець не виключає нічого — пиши «без сигналу» біля нього і більше на нього не дивись. Ти не намагаєшся ще нічого ідентифікувати. Ти стискаєш мапу.

Третій прохід — вибирай важелі. Тепер витягни два-три елементи з найвищим сигналом — ті, які, якщо їх пошукати, стиснуть величезну площу. Шукай *їх*, а не всю фотографію. Уся фотографія — поганий запит. Тісний кроп конкретного крейдяного почерку, конкретної смуги тенту, конкретного номера скутера — кожен з них хороший запит. Ось тут ти нарешті береш браузер.

Метод, крок за кроком

Крок 1 — залогуй картинку. Зазнач джерело, людину, яка надіслала, і будь-яке твердження про час зняття, яке вона зробила («вона надіслала це у вівторок вранці»).

Твердження — це твердження; тінь у кадрі — свідок. Може, доведеться погоджувати одне з другим пізніше.

Крок 2 — читай кадр голим оком. Пиши інвентар.

Опирайся спокусі реверс-пошуку — запустиш його зараз, і твоє свіже читання підмінить те, що трапилось в індексі рушія, і ти проведеш годину, ганяючись за влученнями, які тобі не були потрібні.

Крок 3 — континент і півкуля. З тіні, рослинності та скриптових фрагментів самих постав картинку на пів планети. Сонце на північній стіні опівдні ставить тебе на південь від екватора. Кроп фрагмента крейдяної дошки дає тобі родину скрипту. Листяне листя у грудні ставить тебе на південь від екватора чи в маленьку тропічну смугу. Зроби це, перш ніж торкатись країни.

Крок 4 — країна. Тепер формат номера, дорожня розмітка, з якого боку йде рух у кадрі, шрифт знаків і мовні фрагменти. Звір щонайменше три незалежні осі, перш ніж назвати країну. Якщо номер каже одне, а дорожня фарба — інше, у тебе прикордонне місто, імпортоване авто чи помилка — і жодне з цього не розв'язується вибором

улюбленої відповіді.

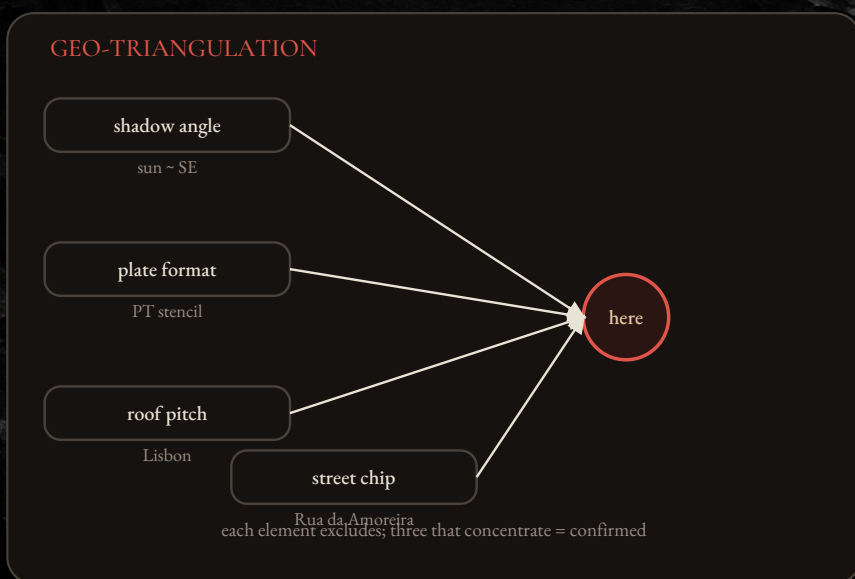
Спробуй (2026). Візьми публічне новинне фото з країни, яку погано знаєш, — вуличний знімок від агентства зі схованим підписом. Працюй лише країну з кадру: номери, фарба, знаки, один скриптовий фрагмент. Запиши свою відповідь, потім відкрий підпис. Зроби це десять разів — і ти відчуєш, як росте м'яз виключення. Роби раз на тиждень — не зменшуватиметься.

Крок 5 — регіон. Маючи країну, звужуй до регіону. Рельєф (гори, море, рівнина, дельта). Архітектура (північна крута кришка проти південної пласкої). Флора (Середземномор'я проти Альп проти степу). Друга мова на вивісках, якщо у країні є регіональні мови. Регіональні мережі — логотип супермаркета, який ти можеш прочитати, хрест аптеки конкретного кольору, паливний бренд, що торгує лише в одній частині країни.

Крок 6 — реверс-пошук зараз, з цільовим кропом. Реверс-пошук цілим кадром — хід новачка, і він майже завжди не повертає нічого корисного. Обріж до єдиного найхарактернішого елемента — конкретного знаку, унікального шматка архітектурного оздоблення, муралу, номерованого люка — і реверсь його. Пробуй кілька рушіїв: їхні індекси різко розходяться. Реверс-пошук — це пошук у

довіднику, не відкриття: ти питаєш «чи цей самий об'єкт колись сфотографували і проіндексували десь ще», а не «що це».

Крок 7 — прогулянка у стріт-в'ю. Коли маєш кандидат-вулицю чи район, пройди її в супутнику і вуличній зйомці. Ти зіставляєш кути, а не «атмосферу». Конкретний кут, під яким сусідська будівля врізається в кадр. Фарба перил балкона. Візерунок кахлю на підлозі. Конкретне дерево — вид, висота, положення відносно кута.



Три незалежні осі перетинаються на одному балконі: точний кут лінії даху сусіда, позиція однієї квітучої джакаранди у дворі і характерна коробка кондиціонера, змонтованого над конкретним вікном. Одна вісь збігається з багатьма місцями. Усі три збігаються одночасно — з одним.

Крок 8 — підтверджуй на незалежних осях.

Локація-кандидат *підтверджена* лише коли принаймні дві — краще три — незалежні осі вирівнюються. Силует будівлі плюс дворове дерево плюс кондиціонер сусіда. Не «балкон виглядає правильно і у мене є відчуття». Ранжуй результат на драбині чесно: правдоподібний район — слабкий, збіжна вулиця — помірний, три незалежні осі на одній будівлі — сильний, а *підтверджено* — це щабель вище: він для випадку, коли незалежне джерело (підпис на іншому фото того самого балкона, оголошення про нерухомість, сам суб'єкт) замикає петлю.

Розібраний кейс, з тупиками включно

Журналістка пересилає тобі фото. Маленький кафе-балкон. Синьо-білі шестикутні кахлі на підлозі. Один білий пластиковий стілець. Смугаста чашка — червоно-біла. Половина крейдяної дошки видима зліва, верхнє слово обрізано, і в фрагменті крейдяного курсиву: *...e uma cerveja*. Через вулицю, справа, кут тенту — червоно-білі вертикальні смуги. Один скутер припаркований унизу, задній номер напіввидимий. Питання: де.

Прохід голим оком. Ти пишеш. Сині кахлі, геометричні. Пластиковий білий стілець, стандартний. Крейдяна дошка, латинський скрипт, курсивний почерк. Фрагмент читається як «і пиво» португальською або чимось близьким. Тент, червоно-білі смуги, глясовий. Скутер, номер трафарет —

білі символи на світлому фоні. Над головою: провід не видно, міська забудова. Небо: імлисте, тепле, пізній ранок за кутом тіні. Тінь на підлозі балкона: коротка, кинута до південної стіни, тож сонце десь на півночі — ти перевіряєш себе двічі, бо південне сонце поставило б тебе в Півдennу півкулю, а спиратись на неправильну півкулю наступну годину не хочеться.

Перший тупик. За звичкою ти кидаєш увесь кадр у реверс-пошук.

```
Query: cafe_balcony_full.jpg
-----
Top matches (3 engines pooled):
- "Blue tile terrace, Lisbon"          weak
- "Riad rooftop, Marrakesh"          weak
- "Salvador da Bahia colonial house"  weak
- "Andalusia, azulejo balcony"       weak
- 40+ stock images, blue tile floors  noise
-----
No exact match. All near-matches
scatter across four countries.
```

reverse-image search — full frame

Марно. Синя плитка — це синя плитка; у рушія їх тисячі, індексовані з ріелторів, туристичних блогів, Airbnb. Закриваєш вкладку.

Другий тупик. Обрізаєш червоно-білий тент і шукаєш його.

Query: awning_stripe_crop.jpg

Chain-café brand matched:

- franchise operates in PT, BR, ES, MZ, AO — five countries.
- Roughly 1,400 outlets total.

Signal: cafe brand family.

Location: any of five countries.

reverse-image search — awning crop

Краще — сигнал, — але це все ще п'ять країн. Тент звужує до *мережі*, а мережа торгує в кожному португаломовному ринку плюс Іспанії. Ти зберігаєш назву мережі і йдеш далі.

Читання мови. Фрагмент крейдяної дошки *e ima cerveja* — португальська, не іспанська. Іспанія випадає. Лишається Португалія, Бразилія, Мозамбік, Ангола — чотири країни.

Третій тупик. Ти передчасно вкладаєшся в Португалію, бо найкраще знаєш Лісабон. Шукаєш «azulejo balcony blue geometric» і починаєш ходити вулицями Лісабона в супутнику. За пів години помічаєш, що щось не так: конкретний шестикутний узор кахлю в кадрі незвичний для Лісабона — там на балконах здебільшого квадратне азулежу. Твої кандидати-дахи в Алфамі не збігаються. Ти відступаєш і перестаєш спиратися на улюблене місто.

Четвертий тупик. Ти переходиш до Бразилії, бо узор кахлю ближчий до того, що ти бачив у Салвадорі. Але профіль ЛЕП у кадрі — точніше *відсутність* конкретного

бразильського візуального хаосу з надземних проводів — не збігається з бразильськими міськими вулицями, де майже завжди безлад кабелів різає небо. У тебе чисте небо. Бразилія випадає — принаймні, її демотовано.

Півот. Ти повертаєшся до номера скутера. Трафарет однозначний, коли наближаєш: білі символи на світлому фоні, конкретний португальський національний формат, з маленькою бічною смугою в кольорі, який Португалія використовує, а лусофонні країни Африки — ні. Ангола і Мозамбік — вниз. Ти повертаєшся в Португалію, але не в Лісабон.

Дивишся ще раз на архітектуру: ухил даху видимий на сусідній будівлі — пологий, але не плаский. Кондиціонер над сусідським вікном змонтований на маленькому настінному кронштейні у стилі, який твоєму оку читається радше як Порту, ніж Лісабон, але ти не довіряєш здогадці й ідеш шукати три референсні фото обох міст, щоб перевірити. Стиль кронштейна поширений у метрополії Порту, менше в Лісабоні. Слабкий сигнал, але узгоджений з узором кахлю.

Цільовий реверс-пошук, друга спроба. Ти обрізаєш тент мережі *плюс* смужку номерованої будівлі над ним — на будинку є маленький, ледь видимий кахель з номером будинку, номер частково читається. Цей кроп тепер конкретний запит.

Candidate: Porto district, café
chain outlet register lists
four Porto-area outlets on
small residential streets.

Walking each in street imagery:

- Rua A: awning wrong colour
- Rua B: awning right, but
balcony opposite is glass
- Rua C: no awning visible
- Rua D (Rua da Amoreira, 21-23):
awning stripes match,
balcony opposite matches
tile pattern, house-number
tile matches, jacaranda in
courtyard matches the tree
visible at the frame edge.

Four independent axes align on
Rua da Amoreira, 21-23. Confirm.

street-view scan for Rua da Amoreira

Чотири осі: смуга тенту, узор кахлю, кахель номера будинку, дерево у дворі. Це сильний на драбині. Він лишається сильним, не підтвердженим — кожна вісь інференційна, а публічний реєстр адрес мережі, який називає ту саму вулицю, підтверджує знахідку, але не дає жорсткого унікального самопосилання (ніхто на фото не заявляє адресу; жоден першоджерельний документ її не називає). Підтверджено — це щабель, на який заходиш через унікальний ідентифікатор чи першоджерельне твердження, а не складанням незалежних інференцій, як би чисто вони не сходились. Ти пишеш це з ланцюгом міркування, включаючи кожен тупик вище, щоб той, хто читає твій звіт, бачив не

тільки, куди ти дійшов, а й чому ранні кандидати були відкинуті — і як мав би виглядати *підтверджений* сигнал.

Другий кейс: той, що не закривається

Інший день, інша картинка: крупний план засніженого стовбура сосни, смуга сірого неба, один слід чобота. Ні структур. Ні знаків. Ні скрипту. Кожна вісь, яку в тебе є, звужує однаково — Північна півкуля, хвойний ліс, зима, ймовірно бореальна. Ти вивчаєш зернистість кори, узор опалих голок, точну ширину сліду чобота, конкретну зернистість снігу. Ніщо не розділяє два регіони-кандидати: Карелія на північному заході Росії і східний Квебек однаково підходять під кожну вісь, яку ти читаєш. Ти не можеш віддати перевагу одному над іншим за доказами. Тож ти чесно доповідаєш: два регіони-кандидати, порівнянна ймовірність, ось осі, які я прочитав, і ось осі, яких у мене немає. Безлад — це робота. Геолокатор, який ніколи не повертає вердикту «не можу розділити», — це геолокатор, що вгадує.

Про етику розміщення людей на мапах

Геолокація — це координати, а координати — це влада. У контексті домашнього насильства, у справі про сталкінг, на війні речення «я знаю, де ти зняв це» — зброя, іноді на добро, іноді ні. Май легітимне питання, перш ніж почати; публікуй лише те, що це питання насправді потребує; і ніколи не публікуй точних координат приватного будинку, якщо суспільний інтерес неспірний і ціль — публічний актор у своїй публічній якості. «Фото з Порту» — часто вся відповідь, яка потрібна зовнішньому світу. Квартал, вулиця, номер — для тебе і клієнта, не для трансляції.

Безпечна вправа

Візьми публічне новинне фото з протесту чи мітингу, на якому ти не був і не міг бути. Прикрий підпис. Опрацюй геолокацію з кадру самого — країна, регіон, вулиця, якщо дійдеш. Порівняй свою відповідь з підписом, коли закінчиш. Це законно, це нікому не шкодить, це тренує кожен м'яз цієї глави і показує, які насправді твої чесні межі похибки.

Підсумок

- Геолокація — це звуження, не вгадування. Кожен видимий елемент або виключає місця, або концентрує на них увагу; знімай виключення шар за шаром.
- Читай кадр у три проходи: інвентар голим оком, сортування за виключенням, потім цільовий пошук

двох-трьох елементів з найвищим сигналом.

- Вивчи граматику кадру: тіні, рельєф, дорожня фарба, знаки, номери, сторона керма, стовпи, флора, архітектура, скрипт, EXIF-останнім.
- Роби континент–країна–регіон звуження, перш ніж робити реверс-пошук.
- Реверс з кропом, ніколи цілим кадром; використовуй кілька рушіїв, бо їхні індекси розходяться.
- Ходи вуличною зйомкою за кутами, не «атмосферою» — зіставляй кути, оздоблення, конкретні дерева, конкретні кондиціонери.
- Підтверджуй на незалежних осях. Одна вісь — здогад, дві — кандидат, три — сильний. Усе, що назване «підтверджено», потребує джерела поза самою картинкою.
- Доповідай тупики, а не лише відповідь. Геолокація без відкинутих гіпотез — не геолокація, а заява.
- Публікуй лише те, що питання потребує. Район зазвичай досить для світу; номер дверей — для файлу.

Розділ 4 повертається до тієї ж фотографії і питає інше: *коли*.



РОЗДІЛ ЧЕТВЕРТИЙ

Читання фотографії на час

Сонце і пори року — два найчесніші годинники в будь-якій картинці.

Клієнт повернувся наступного ранку з коротшим питанням. У Главі Третій ми розмістили кав'ярню — балкон на Rua da Amoreira в Порту, кахляний фасад через вулицю, трамвайні драти, що заспокоюють кадр. Це відповіло на *де*. Але *де* ніколи не було справжнім питанням. Справжнє питання було *коли*. Фотографію переслали без підпису, і людина в кадрі заперечувала, що була на цьому балконі того місяця, коли клієнт вважав знімок зробленим. Отож — та сама картинка, те саме міркування, інший стовпчик інформації.

Ми вже прочитали знімок на місці. Тепер читатимемо його на час.

Геолокація і хронолокація — сестринські дисципліни. Вони їдуть тією ж петлею — спостерігай, гіпотезуй, перевір, тримай — і підіймаються тією ж драбиною від *неперевіреного* через *правдоподібний, підкріплений, сильний*, до *підтверджено*. Але вони читають різні якорі. Там де геолокація живе в узорах кахлю, бордюрах і геометрії скайлайна, хронолокація живе в сонячному світлі, листі, погоді і маленькому датованому смітті, яке лишає в кадрі людське життя. Настінний календар. Край плаката. Телефон у руці.

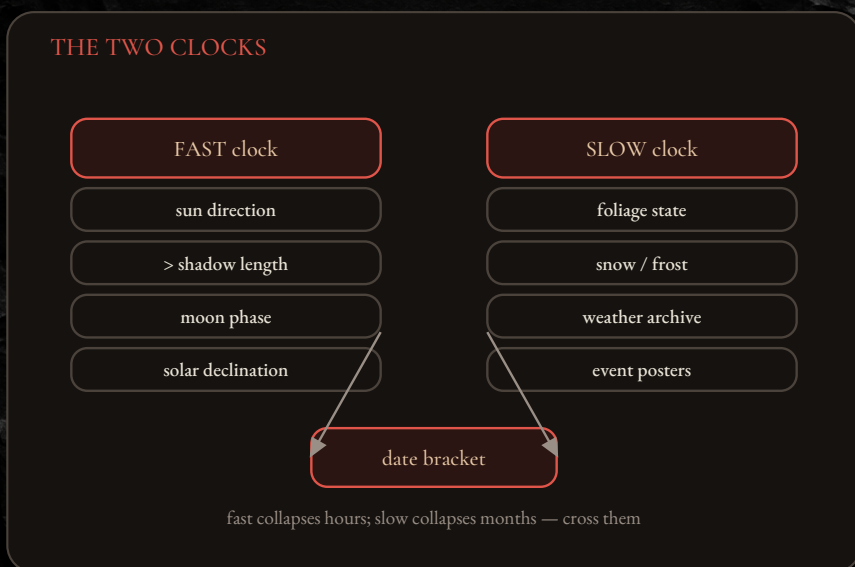
Ідея: картинка — це годинник

Кожна вулична фотографія несе два годинники, і обидва косяють чесно, якщо ти вмієш їх читати.

Швидкий годинник — астрономічний. Положення сонця залежить від широти, довготи і моменту. У будь-який день у будь-якому місці сонце сходить під конкретним азимутом, підіймається до конкретної максимальної висоти і кидає тіні конкретної довжини та напрямку. Місяць має свій цикл — фаза, схід, захід, — і коли він з'являється в кадрі, він безкоштовно дає тобі бракет кількох днів. Видиме часткове затемнення, якщо тобі коли-небудь так пощастить, — одна дата.

Повільний годинник — фенологічний і сезонний. Древа голі, у бруньках, у повному листі, у сенесценції або скинули листя. Поля розорані, засіяні, ростуть, зжаті або стерня. Сніг є, немає, свіжий чи старий. Ці сигнали рухаються повільно, але за рік — в одному напрямку, і в поєднанні з широтою вони звужують знімок до одного-двох місяців календаря.

Фотографія, що показує обидва годинники — тінь і лист, кут і снігову лінію, — дуже швидко стягує відповідь.



Швидкий годинник вгорі кадру, повільний внизу, а датоване людське сміття — плакати, телефони, авто — тягнеться серединою.

Що знімок насправді каже тобі про час

- **Напрям сонця і довжина тіні.** Компасний напрям тіні каже тобі азимут сонця. Співвідношення довжини тіні до висоти об'єкта каже тобі висоту сонця. Разом, за відомої широти й довготи, вони стискаються до невеликого набору кандидатів «дата–час».
- **Стан листя.** Голі гілки, розкриття бруньок, повний намет, осінній колір, скинуте листя. У помірній зоні лише це вже бракує тебе до кількох тижнів. Зазнач, чи це листопадне дерево — вічнозелені нічого сезонного не кажуть.
- **Сніговий покрив.** Наявність, відсутність, свіжість (чіткі краї проти сталої кірки), глибина проти відомого референса, як бордюра. Свіжий сніг після теплого періоду означає снігопад за останній день чи два.
- **Стадія сільського господарства.** Розорана коричнева, зелені паростки, високий стоячий пшеничний колос, скошений і у валках, стерня зі соломою в тюках, знову розорана коричнева. Кожна стадія — конкретне вікно у місцевому фермерському календарі.
- **Погода в кадрі.** Тип хмар — високий перистий проти низького шаруватого проти купчастого, що будується. Земля ще мокра після дощу. Іній на дахах у ранковому світлі. Конденсат на вікнах, який утворюється лише коли повітря надворі дуже холодне.

- Рукотворні календарні сигнали. Настінний календар на офісній стіні за кимось. Крейдяна дошка магазину «до Різдва 6 днів». Футбольний матч на барному телевізорі, де читається рахунок і команди. Сезонна акція browарні.
- Датування за модою і технологіями. Форма iPhone в руці — кожне покоління має характерний блок камер. Модель авто чи рестайлінг року на вулиці. Конкретна колаборація streetwear з задокументованою датою дропу.
- Сигнали з боку платформи. Формулювання застосунку «posted 2h ago» — рядок, що дрейфує до *yesterday*, потім до *3 Jun* за дні. Скріншотни, перш ніж змінюється. Час зняття у Wayback Machine сторінки, що хостить зображення, — жорстка верхня межа: знімок існував до цієї дати.
- Астрономічні додатки. Фаза Місяця, видима в кадрі, дає бракет у кілька днів через місячний цикл. Рідкісні події — сонячне затемнення, яскрава комета в відому дату, пік метеорного потоку — прикріплюють до однієї ночі.
- Конденсаційні сліди і літаки. Видимий літак чи свіжий контрейл характерної форми можна звірити з історією відстеження польотів у цьому регіоні на кандидат-дні. Конкретні трекери, доступні сьогодні, можуть не існувати через п'ять років; став техніку як тривалу, а інструмент — як тимчасовий.

Два годинники, що працюють разом

Два годинники важать, бо кожен з них окремо неоднозначний. Положення сонця 15 червня о 14:00 на 41°N майже ідентичне його положенню 27 червня о 13:50. Хронолокація лише за тінню майже завжди лишеа тебе з двома кандидат-вікнами, іноді одним навесні і одним восени, симетричними навколо сонцестояння.

Повільний годинник цю неоднозначність згортає. Повний намет на дереві в кадрі виключає березневе дзеркало вересневої дати. Сніг на землі виключає червневе дзеркало грудневого. Мокре покриття в день, який архів погоди показує сухим, виключає той день.

Ти майже ніколи не отримуєш хронолокацію з одного годинника. Ти отримуєш її, змусивши два годинники узгодитись.

Метод, крок за кроком

Крок 1 — заморозь походження. Збережи зображення з ім'ям файлу і URL. Скріншотни *сторінку*, що його хостить, включно з написом «posted N hours ago». Цей напис — текстовий рядок, а не точка даних, і він за ніч зміниться. Зазнач історію знімків Wayback Machine для сторінки-хоста — найраніший знімок, що містить зображення, — жорстка верхня межа дати.

Крок 2 — читай кадр голим оком на підказки повільного годинника. Перш ніж відкривати будь-який інструмент — дивись. Листя? Сніг? Стоячі культури? Калюжі? Тіні чіткі чи розмиті? Запиши, що бачиш, словами, у нотатках. Це змушує помічати те, що інакше проскочив би поглядом, коли вже на пів дорозі до гіпотези.

Крок 3 — читай кадр на підказки швидкого годинника. Куди показує тінь? Наскільки вона довга відносно того, що її кидає? Місяць видимий? Взагалі є хоч якийсь небесний референс? Записуй напрями кардинально спершу — «тінь показує приблизно на північ-північний схід», — бо саме такою мовою до тебе говоритиме сонячний калькулятор.

Крок 4 — звір із погодою. Якщо Розділ третій дав тобі локацію — витягни місцевий погодні архів на кандидат-дати. Дощ у кадрі плюс сухий кандидат-день виключає той день. Чисте небо в кадрі плюс кандидат-день, записаний як повністю похмурий, — теж.

Спробуй (2026). Для будь-якого міста публічний погодні архів дасть тобі похвилинну хмарність, температуру й опади за роки назад. Візьми своє фото з відомої дати, знайди архів на цю годину і подивись, чи запис збігається з тим, що показує твоє фото. Якщо ні — ти дізнався щось про розташування своєї місцевої станції: корисне

калібрування.

Крок 5 — листя і фенологія. Дати розкриття бруньок для виду на даній широті варіюють від року до року, але публічно доступні фенологічні записи дають бракет.

Листопадне дерево в помірній зоні у свіжому світло-зеленому листі, чіткі краї, без пилу — двохтижневе вікно навесні. Повний намет, притлумлений літнім пилом, — набагато ширше вікно, червень–серпень.

Крок 6 — календарні та контентні сигнали. Футбольний матч на пабному телевізорі з читаним рахунком — жорсткий якір на один вечір. Наліпка «Merry Christmas» на вікні, ще не вивітрена, бракує грудень. Плакат концерту з читаною датою — золото. Читай кадр на датоване сміття буденного життя.

Крок 7 — датування за технологією. Телефон чи модель авто, випущені в травні 2023-го, виключають усе до травня 2023-го. Це підлога, а не стеля — той самий телефон досі існує сьогодні. Комбінуй з усім іншим.

Крок 8 — ранжуй на драбині. Однодоба хронолокація рідкісна і майже завжди потребує астрономічного якоря або датованої події в кадрі. Бракет у кілька днів — хороший результат. Бракет у місяць — часто чесний. Кажі чесну відповідь. Клієнт радше отримає *останній тиждень травня 2025, сильний, ніж 17 травня 2025, сподіваємось.*

Розібраний кейс, з тупиками включно

Назад до балкона на Rua da Amoreira, у Порту. Клієнт вірив, що фото зроблено в серпні. Фотограф казав ні. Знімок був зачищений від EXIF тим месенджером, через який пройшов, — реверс-пошукові сайти не повертали ранніх копій, файл був чистий.

Тупик один. Без метаданих. Без попередніх завантажень. Нічого не витягнути з самого файлу.

Тупик два. Напря́м сонця, прочитаний голим оком за тінню ліхтарного стовпа, видимою на тротуарі під балконом, показував приблизно на північ-північний захід. Звірено з формою сонячної позиції — для широти Лісабона цей напрям тіні відповідає ранковому вікну навесні або влітку. Той самий напрям тіні з'являється у смузі квітень–травень і дзеркальний смузі липень–серпень. Отже, серпнева гіпотеза клієнта була узгоджена з сонцем. Так само як і імпліцитне «не серпень» фотографа. Швидкий годинник нічого не робив.

Тупик три. Листя в кадрі — це вазон з лимоном на балконі. Вічнозелений. Мовчазний. Одне вуличне дерево, видиме на краю кадру, — платан, але обрізаний так тісно, що видно лише смужку листа, не достатньо, щоб сказати, чи це повний намет, чи ранній листоблиск.

Тупик чотири. Погодний звір для запропонованої клієнтом дати — конкретного полудня в серпні — показав запис архіву Порту про важкий купчастий хмаровий бій і грозу о 16:00. Знімок показував пласке, високе, імлисте небо і сухе покриття. Той полудень виключено.

day/hour	cover	temp	precip
14 / 15	OVC	28C	0.0
14 / 16	OVC	27C	4.2 mm
14 / 17	BKN	24C	1.1 mm

weather archive readout — Porto

Тоді картинка почала віддавати.

Вздовж стіни кав'ярні через вулицю, на лівому краю кадру, маленький паперовий плакат був наклеєний поверх старішого. Верхній шар був майже нечитабельний, але два рядки прочитались при збільшенні: назва фестивалю і слова *5–7 Junho*. Сайт самого фестивалю підтверджував, що він проходив у цей вихідний одного конкретного року. Той рік плюс ранкове вікно тіні, сумісне з початком червня на цій широті, — двохдобовий бракет.

Full canopy typically established by late May. On 5–7 June: full leaf, dust not yet accumulated. Frame edge shows this exact state – consistent, not distinctive.

phenology bracket — Porto plane tree

Фенологія на краю платана була узгоджена з червневим бракетом — повне листя, ще свіже, — але сама по собі не

відділила б червень від пізнього травня чи раннього липня. Підкріплення, не якір.

Рука самого фотографа була видима внизу кадру, тримала телефон. Блок камер — характерне розташування моделі, випущеної у травні того самого року. Це виключило ті самі дати в будь-якому ранішому році — тож фестивальний плакат, що повторюється щороку, тепер вказував на один конкретний вихідний.

Остаточна відповідь: *ранок 5, 6 або 7 червня того року, сильний*. Не підтверджено — ми не сфотографували годинник у кадрі, — а сильний: два незалежні якорі (плакат, модель телефона) плюс два узгоджені прочитання (сонце, листя), і ніяких протиріч. Клієнт просив місяць і очікував, що йому скажуть який. Отримав вихідний.

Хроолокація відео

Відео — це фотографія, що йде. Воно додає безперервність, а безперервність дає більше якорів.

Годинний кут сонця змінюється приблизно на п'ятнадцять градусів на годину — це чиста астрономічна константа. Видимий азимут (компасний напрям) рухається зовсім з іншою швидкістю: біля місцевого полудня влітку на високих широтах він може пройти десятки градусів за хвилини, а при низьких кутах сонця взимку азимут ледь рухається. Що саме показує твоє відео, залежить від геометрії кімнати — тінь на

стіні зазвичай читає азимут; світлова пляма, що йде підлогою ближче до полудня, читає суміш. Роби арифметику для конкретної дати, широти і години, перш ніж вкладатися в «один градус за п'ять хвилин». Пляма сонячного світла помітно рухається в кліпі, тривалість якого — мала частка години; точна швидкість — це те, що треба перевірити, а не припустити. Хмарні тіні рухаються в тому самому напрямі, у якому рухається вітер на висоті основи хмар, зі швидкостями, які записує місцевий погодний архів. Кліп, у якому тінь перетинає садок за вісім секунд на відомій відстані, можна звірити зі швидкістю вітру на тій висоті для кандидат-годин.

Контрейли — друзі відео-хронологатора. Пара пересічних контрейлів, свіжо покладених, у відомому компасному напрямі, у відомий момент кліпу, можна звірити з історією відстеження польотів для регіону на кандидат-дні.

Конкретний сервіс, який ти використовуєш для архіву, може не існувати через п'ять років — став техніку як тривалу, а інструмент як тимчасовий. Міркування — те, що переноситься далі.

Другий кейс: той, що не закривається

Студійний портрет, всередині приміщення. Ні вікна. Ні настінного годинника. Ні телефона в кадрі. Об'єкт носить просту чорну футболку, невиразні темні штани, звичайну срібну каблучку — ніщо не несе сезон чи рік. Стіна за спиною пофарбована в середньо-сірий і не має плакатів, календаря, деталей моделі вимикача. Освітлення — софтбокс — могло бути виставлене будь-якого дня будь-якого року.

Найраніший знімок Wayback Machine сторінки, що хостить зображення, — січень 2023, тож фотографія існувала до цього. Ніщо в кадрі далі не звужує. Найкраща чесна відповідь — *між датою найранішої онлайн-копії і сьогодні, далі не перевірено*. Звіт: *колись за останні три роки, не перевірено*. Не кожне питання закривається, і вдавати інакше — гірше, ніж це сказати.

Про етику ставлення людей на таймлайн

Хронологіація фотографії людини несе конкретне значення: *ти був у цьому місці в цей день*. У поєднанні з геолокацією це малює зріз життя. Це легітимний інструмент публічної підзвітності публічних акторів, репортерів, що перевіряють твердження, страхових розслідувачів, що дивляться на шахрайство. Це не інструмент, щоб будувати денний ритм рухів приватної людини.

Та сама дисципліна, що діє в геолокації, діє тут — легітимне питання, мінімальне розкриття, ніякої публікації нічого, що скомпрометувало б безпеку того, хто не є публічним актором. Бракет на вихідні для заперечуваного явлення публічної фігури — це журналістика. Бракет на вихідні для недільних прогулянок колишньої дружини — це сталкінг. Читай свій кадр, перш ніж читати їхній.

Безпечна вправа

Візьми три своїх старих знімки, де знаєш точну дату. Зачисти метадані. Сховай від себе дату — запиши її на картці і поклади картку в шухляду. Тоді обробляй їх хронологічно з нуля: читай повільний годинник, читай швидкий годинник, тягни погодні архіви і пиши свій бракет. Відкривай шухляду лише коли написав. Це найшвидший спосіб відкалібрувати, наскільки тісний бракет можна чесно заявити і де твоє прочитання тебе дурить.

Підсумок

- Кожна вулична картинка несе два годинники: швидкий астрономічний і повільний фенологічний.
- Жоден годинник окремо зазвичай не досить. Змусь їх узгодитися.
- Заморозь походження першим — мітки часу, URL сторінки, рядки «N hours ago» — перш ніж вони дрейфнуть.

- Погодні архіви — найдешевший інструмент виключення, який у тебе є.
- Датоване сміття в кадрі — плакати, телефони, настінні календарі, рахунки матчів — це те, що стискає бракет від місяця до тижня, від тижня до дня.
- Однодоба відповідь рідкісна і потребує події чи астрономічного якоря. Бракет — звичайна чесна розв'язка.
- Відео додає безперервність: рух сонячного світла, дрейф хмар, контрейли проти історії польотів.
- Хронолокація життя приватної людини — це межа. Питай навіть, перш ніж питати коли.

Наступна глава лишає світ кадрів і йде у світ стійок. Від читання фотографії на час — до читання мережі на власника.



РОЗДІЛ П'ЯТИЙ

Домени та історія реєстрації

Кожен домен лишає паперовий слід. Редакція — це завіса, а не стіна.

Рік тому ти читав блог. Не великий — персональний сайт із приблизно тридцятьма постами, одна довга серія, за якою ти стежив, коментарі, що осіли на трьох завідниках. Сьогодні ти вставляєш адресу у свіжу вкладку — і браузер відкидає тебе кудись інде: на лендінг, що продає курс, про який ти ніколи не чув, шрифтом, від якого старий сайт вдавився б. Домен живий. Сайт за ним — чужий.

Хтось володіє тим ім'ям тепер. Хтось володів ним тоді. Між цими двома власниками — паперовий слід: реєстрація, передача, зміна серверу імен, новий поштовий провайдер, можливо, прострочення і перехоплення опортуністом. І під усім цим, похований у снапшоті з 2011-го, який редакційна записка 2018-го так і не повернулася стерти, досі може лежати email — реальний, у відкритому вигляді, який належить людині, що вперше зареєструвала домен, коли ніхто не звертав уваги.

Ти щойно перейшов від роботи з людьми до роботи з інфраструктурою. Інструменти змінюються. Інстинкт — ні. Ти все ще ходиш колом навколо точки посередині, і коло досі підсвічене.

Ідея: домен — це паперовий слід

Домен — це не сайт. Це перше, що треба поправити в голові, бо доти, доки ти цього не поправив, половина того, що йде далі, здаватиметься магією.

Сайт — це те, що видно в браузері: пікселі, текст, зображення, кошик покупок. Домен — це *запис* про той сайт: запис, який веде реєстр, повторює реєстратор, і перевіджує півдюжини публічних сервісів пошуку та сервісів пасивного збору по всьому світу. Щоразу, коли хтось змінює цей запис — новий реєстрант, новий сервер імен, новий поштовий провайдер, нова дата закінчення —

зміна фіксується, і часто *старе* значення теж фіксується, десь, кимось.

Тобі не треба нікуди зламуватися. Ти читаєш слід.

Слід у 2026-му тонший, ніж у 2015-му, бо у 2018-му настала ера редакції, і багато з того, що раніше було відкритим, сховалося. Але *тонший* — не *зник*. Дві речі неможливо сховати: минуле й сусідів — бо снапшоти переживають редакційну зачистку, що прийшла по них; і сусіди — бо домен живе на інфраструктурі, яку ділить із іншими доменами, і сусіди часто розповідають більше, ніж ціль колись мала намір.

Терміни, які ти чутимеш часто

Закріпи їх спершу. Кожна техніка нижче використовує щонайменше два.

- **WHOIS** — публічний запис про те, хто зареєстрував домен і коли. Вимовляється «ху-із». Ти робиш запит, отримуєш текстовий блок.
- **Реєстр і реєстратор.** Реєстр — це орган, що керує доменом верхнього рівня (.com, .io, .de). Реєстратор — це вендор, у якого ти фактично купуєш домен: GoDaddy, Namecheap, невеликий бутік. Один і той самий домен — дві різні компанії за ним.
- **DNS** — Domain Name System, телефонна книга, що перетворює ім'я (example.com) на адресу, до якої може

дістатися комп'ютер (IP).

- Типи записів. **A** — IPv4-адреса, на яку вказує ім'я. **AAAA** — IPv6-адреса. **MX** — куди доставляється пошта для цього домену. **NS** — які сервери імен тримають DNS-записи цього домену. **TXT** — довільні текстові записи, що використовуються для політик і верифікацій, і найгучніший канал витоку з усіх.
- Сервер імен. Сервер, який фактично тримає DNS-записи домену. Кожен домен вказує на один чи більше серверів імен, і ці сервери імен групуються корисним чином.
- Історичний WHOIS. Снапшоти WHOIS-запису, зроблені до ери редакції 2018-го, коли імена й email-и реєстрантів зазвичай були відкритими. Зберігаються комерційними архівними сервісами.
- Reverse IP. Усі інші домени, що обслуговуються з тієї самої IP-адреси, що й ціль. Іноді шум, іноді золото.

Що WHOIS усе ще показує у 2026-му і що перестав показувати

Приблизно до 2018-го живий WHOIS-запит на більшість доменів верхнього рівня давав тобі ім'я реєстранта, email, поштову адресу й телефон у відкритому тексті. Ця ера скінчилася. У Європі з'явився GDPR, політика ICANN у відповідь змінилася, і більшість реєстраторів тепер повертають відредагований запис для особистих полів: «REDACTED FOR PRIVACY», «Data Protected», «See registrar's privacy policy».

Що *таки* повертається у 2026-му для майже кожного домену, який ти запитуєш:

- Реєстратор — вендор.
- Дата створення — вік операції. «Консалтингова фірма», чий домен зареєстровано одинадцять тижнів тому, розповідає щось про себе.
- Дата оновлення — останню зміну запису.
- Дата закінчення — коли він спливе, якщо не поновити.
- Прапорці статусу — clientTransferProhibited, serverHold та їхні родичі. Це замки проти захоплення, які виставляє реєстратор або реєстр — вони блокують несанкціоновані передачі, це не прапорці приватності, і відредагований реєстрант зі статусом «prohibited» — це нормально, а не підозріло. Нудні більшість часу, корисні,

коли раптово змінюються.

- Сервери імен. Це єдине найкорисніше поле, що лишилося в живому WHOIS.

Сервери імен важливі, бо групуються. Два непов'язані хобі-блоги на одному великому DNS-провайдері (ns1.cloudflare.com та його сусіди) не кажуть тобі нічого. Два маловідомі домени, що ділять приватне ім'я сервера імен, яке з'являється лише в дев'яти інших доменів світу, кажуть тобі багато.

Принцип тримається. Те, що виглядає відредагованим, не сховане повністю. Особисті поля на лицьовій стороні запису пішли за завісу, але побічні канали — уподобання реєстратора, вік дати створення, кластеризація серверів імен і, головне, історичний архів — ні.

Історичний WHOIS: email 2011-го, який ніколи не редагували

До ери редакції email-адреси й імена реєстрантів були публічними за замовчуванням для більшості TLD. Навколо цього виросла ціла галузь — сервіси, що тихо записували снапшот WHOIS усього світу щодня і тримали архів. Коли настав 2018-й і поточний WHOIS погас, архів не стер себе заднім числом. Те, що було відкритим до того, досі відкрите — лежить у тих історичних базах.

Це найбільший важіль, якого вчить цей розділ. Якщо домен уперше зареєстровано у 2011-му на `operator@personalemail.com` і відредаговано лише після 2018-го, запис 2011-го досі там — і email теж. Реєстрант, який жодного разу не передавав цей домен, не подумає вичищати те, що записав п'ятнадцять років тому, бо у 2011-му цього ніхто не вичищав. Це і є «один email, який пропустила зачистка», і часто це — вся справа.

Чесне застереження: більшість сервісів історичного WHOIS комерційні й платні, і конкретний вендор, названий у будь-якому посібнику, який ти читаєш — включно з цим, якби я назвав одного — може вже не існувати на момент, коли ти справді спробуєш ним скористатися. Сприймай *форму* як тривалу (снэпшоти до 2018-го існують і доступні для запитів), а *конкретні двері* — як замінні.

Читання DNS як розвідка

Набір DNS-записів для домену — короткий список, публічно доступний для запитів, і — на відміну від WHOIS — його ніколи не редагували. Читай кожен тип записів. Кожен видає щось конкретне.

- **A / AAAA.** IP-адреса, що обслуговує сайт. Це півот у reverse-IP: які ще домени сидять на тому самому хості? На гігантському спільному хості або CDN — тисячі непов'язаних тенантів, майже нульова цінність. На

маленькому VPS із трьома тенантами всі троє можуть належати одному оператору.

- **MX.** Куди доставляється пошта домену. MX-записи, що вказують на google.com або outlook.com, означають, що оператор користується Google Workspace або Microsoft 365 — поширено, слабко саме по собі. MX, що вказує на самостійно розгорнутий поштовий сервер на власному IP оператора, каже тобі, що оператор любить тримати свою пошту, і дає тобі IP для reverse.
- **NS.** Сервери імен. У блоці загального провайдера — марно для кластеризації. На незвичному приватному імені сервера імен — ns1.mycoolprojects.net — можна зробити reverse-NS: кожен інший домен світу, що вказує на той самий сервер імен, часто виявляється іншою власністю того самого оператора.
- **ТХТ.** Найгучніший канал витоку. SPF-записи перераховують кожного відправника пошти, якого домен уповноважив. DKIM і DMARC розкривають поштовий стек у деталях. Токени верифікації — токен [google-site-verification](https://google-site-verification.com), токен [facebook-domain-verification](https://facebook-domain-verification.com), токен Zoom, Atlassian чи Stripe — кажуть, до яких платформ оператор прив'язав цей домен, а самі рядки токенів іноді зв'язують два домени разом у межах одного організаційного тенанта.
- **CNAME.** Аліаси. CNAME, що вказує blog.target.com на особистий Netlify-піддомен оператора або на його

особистий GitHub Pages, — типова випадковість і чистий півот.

Метод, крок за кроком

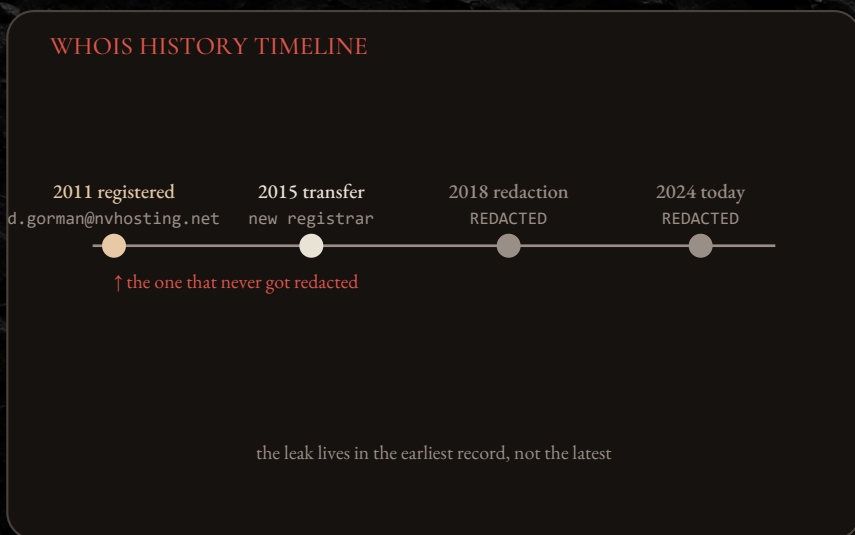
Крок 1 — Читай живий WHOIS. Зроби запит до домену. Запиши: реєстратор, дата створення, дата оновлення, закінчення, прапорці статусу, сервери імен. Не пропускай нічого поверхово.

Крок 2 — Витягни історичний WHOIS. Подивися на *найраніший* запис у базі. Потім пройди хронологічно вперед і відзнач кожен перехід — зміну email реєстранта, зміну імені реєстранта, зміну серверу імен, зміну реєстратора. Кожен перехід — це момент, коли оператор мусив торкнутися запису, і кожен дотик — це момент можливого відкритого сліду. Email 2011-го зазвичай у *найранішому* записі; переходи розповідають історію, що йшла після.

Крок 3 — Читай DNS. Витягни A, AAAA, MX, NS і кожен TXT-запис. Читай TXT-записи особливо — більшість людей лишає там більше себе, ніж усвідомлює.

Крок 4 — Зроби reverse-IP по поточному хосту. Пошукай кожен інший домен, який обслуговується з тієї самої IP. Зважуй результат чесно: на спільному CDN або великому хостинг-провайдері результат reverse-IP — тисячі непов'язаних тенантів, і він не каже нічого; на маленькому

VPS із жменею тенантів найближчі сусіди часто — той самий оператор.



Паперовий слід домену крізь час: створення, переходи, редакційна зачистка й снапшоти до 2018-го, що переживають її в комерційних архівах.

Крок 5 — Reverse-NS. Пошукай кожен інший домен світу, що вказує на ті самі сервери імен. Сервери імен загальних провайдерів (ns1.cloudflare.com і компанія) для цього марні — рівень шуму задовгий. Дивні приватні імена серверів імен — золото; сервер імен, що обслуговує дев'ять інших доменів, і лише ці дев'ять, щойно вручив тобі весь кластер оператора.

Спробуй (2026). Візьми домен, яким ти сам оперуєш. Запитай його живий WHOIS і відзнач кожне поле. Запитай кожен тип DNS-запису.

Прочитай свої TXT-записи очима чужинця. Що вони кажуть сторонньому про те, які платформи ти використовуєш, куди йде твоя пошта і які інші домени твої? Більшість людей вражені відповіддю. Конкретний інструмент запитів, названий у будь-якому тьюторіалі, може вже померти — форма (запитати WHOIS і кожен тип запису зі свіжого термінала або з поважного веб-лукапу) — ні.

Крок 6 — Патерни реєстратора. Звір реєстратор із іншими відомими доменами твого кандидата-оператора. Більшість людей реєструють усе через одного вендора за звичкою. Якщо сім доменів, які ти вже прив'язав до однієї особи, усі в того самого нетипового реєстратора, а цільовий домен — теж у нього, це підпис — слабкий сам по собі, значущий у комбінації.

Крок 7 — Шукай момент, який пропустила зачистка. Прочитай кожен контактний email у кожному історичному WHOIS-записі для цього домену та його сусідів. Прочитай кожен TXT-запис у пошуках токенів верифікації, що ведуть до конкретного ідентифікатора тенанта — токен верифікації Google Workspace зв'язує кожен домен у тому тенанті разом. Одного витоку email або одного спільного токена тенанта часто досить, щоб зробити півот до людини.

Крок 8 — Рангуй. Та сама драбина, що й завжди. Збіг реєстратора сам по собі — слабкий. Збіг реєстратора плюс кластер reverse-NS — помірний. Історичний WHOIS-запис із повним іменем реєстранта й email-ом, який також збігається з контактною інформацією реальної людини десь інде — сильний. Не стакай два помірні й не називай результат сильним; це не так працює драбина, і це не так ти зберігаєш свою репутацію.

Опрацьована справа, з тупиками включно

Клієнт попросив мене атрибутувати дрібного оператора, що тримав скам-сайт про «інвестиційну освіту» на winspiral-partners.io. Сайт продавав «менторську програму» за п'ятизначну суму, чії відгуки були здебільшого стокові фото з вигаданими іменами. Клієнт хотів реальну людину за операцією. Вигадана справа, реальний метод.

Живий WHOIS. Усе, що мене цікавить, за завісою.

```
WHOIS  winspiral-partners.io
-----
Registrar    BigDiscountRegistrar
Created       2023-04-11
Updated       2024-11-02
Expires       2027-04-11
Status        clientTransferProhibited
Registrant    REDACTED FOR PRIVACY
Email         REDACTED FOR PRIVACY
NS1           ns1.cloudflare.com
NS2           ns2.cloudflare.com
-----
personal fields = redacted
```


Усе, що можна прочитати у 2026-му для свіжого домену.

З особистих полів нічого взяти. Великий дисконт-реєстратор, дата створення — квітень 2023-го, загальні сервери імен Cloudflare. Я все одно записую все.

Reverse-IP — тупик. Сайт стоїть за Cloudflare, тож А-запис вказує на edge-адресу Cloudflare. Reverse-IP на адресі Cloudflare повертає тисячі непов'язаних тенантів — український кулінарний блог, португальську юридичну фірму, зламаний WordPress із 2019-го. Слабко, відхилено. Список тенантів спільного CDN — це не кластер; це телефонна книга інтернету.

Історичний WHOIS — тупик. Я запитую історичний архів по winspiral-partners.io. Найраніший запис — 11 квітня 2023. Нічого до того. TLD .io ніколи не був приязний до архівних сервісів так, як був .com, і цей домен просто не існував до дати створення. Немає снапшоту до 2018-го, бо немає домену до 2018-го. Нема з чим працювати.

ТХТ-записи — тупик. Я витягую кожен ТХТ. Загальний SPF (`v=spf1 include:_spf.google.com ~all`), загальний DMARC у quarantine, жодних відмітних токенів верифікації. Google Workspace, стандартна конфігурація, жодного ідентифікатора тенанта, що прив'язав би до чогось іще. Нічого відмітного.

Чотири тупики поспіль. У цій точці багато хто відзвітував би про *недостатній сигнал* і зупинився. Я — ні, бо коло більше за один домен: домен — це одна точка, а точки мають сусідів.

Півот. Прохід пасивним DNS (техніка отримує окремий розділ у Розділі 8; тут прийми на віру) виявив сусідній домен — winspiral-support.com, — що з'явився в тому самому DNS-сусідстві роком раніше. Сайт на тому домені був майже ідентичним клоном сайту .іо, схоже, виведеним із експлуатації й залишеним як редирект. .com було *zareєстровано у 2016-му*, задовго до того, як ера редакції стала універсальною для .com.

Я запустив історичний WHOIS по .com.

```
Historical WHOIS winspiral-support.com
```

```
-----  
2016-08-19 first record  
Registrant Daniel Gorman  
Email d.gorman@nvhosting.net  
Registrar NicheRegistrarLLC  
2018-05-24 redacted (GDPR sweep)  
Registrant REDACTED FOR PRIVACY  
2021-03-02 registrar transfer  
Registrar BigDiscountRegistrar  
2024-11-02 updated  
-----  
2016 record = missed the sweep
```

Снапшот до 2018-го, який оператор так і не повернувся вичистити.

Ось воно. Запис реєстранта 2016-го має ім'я й особистий email. Домен email, nvhosting.net, — це маленький хостинговий бренд, що резолвиться на лендінг однієї людини. Пошук точної адреси виводить публічний профіль LinkedIn на «Daniel Gorman», дрібного крипто-аффіліат-маркетолога, чий банер, до речі, — одне з тих самих стокових фото «ментора» на сайті winspiral-partners.io.

Два підтверджувачі приходять швидко. По-перше, передача реєстратора .com 2021-го перевела його до того самого дисконт-реєстратора, яким сьогодні користується .io — патерн реєстратора по всьому кластеру оператора. По-друге, токени верифікації Google Workspace обох доменів (видимі в TXT) посилаються на той самий ідентифікатор тенанта — обидва домени сидять усередині одного поштового тенанта, і той тенант — nvhosting.net.

Рангуй чесно. Історичний WHOIS-запис 2016-го — це єдиний чистий сигнал самопосилання: заява про власність від першої особи в момент часу. Патерн кластера реєстратора й спільний поштовий тенант *відчуваться* як два додаткові голоси, але обидва насправді — той самий факт, побачений двічі: адміністративні звички оператора. Той, хто купує через одного дисконт-реєстратора й тримає обидва домени в одному тенанті Google Workspace, виражає одне рішення про закупівлю, не два незалежні. Пораховане

правильно, це одне самопосилання плюс один сигнал підтримувальної звички — помірно-до-сильного, не чистий сильний.

Клієнт отримав людину, email і підтверджувальний LinkedIn — і чесну примітку у двох частинах. По-перше, людина, названа в записі 2016-го, — це *реєстрант*, що не обов'язково те саме, що *оператор сьогодні*. Домен може змінити руки. По-друге, два «незалежні» підтверджувачі не повністю незалежні один від одного; звіт маркує їх як сигнали звички оператора, а не як три окремі голоси. Щоб чисто піднятися до сильного, нам був би потрібен сигнал від справді іншого методу збору — збіг контенту у власних текстах Daniel Gorman, фото, яке він опублікував, що з'являється на сайті, публічне зізнання в LinkedIn. Звіт називає, що привело б нас туди.

Друга справа: та, що не закривається

Інший домен, той самий тиждень. Одна сторінка сайту, що звинувачує названу особу в шахрайстві, без автора, без контактів. Клієнт хотів знати, хто це виставив.

Домен зареєстровано свіжо у червні 2024-го, приватна реєстрація з першого дня. Живий WHOIS: повністю відредаговано. Історичний WHOIS: немає нічого старшого за червень 2024-го, бо домену не існувало. Сервери імен: загальні Cloudflare, тож reverse-NS марний. Reverse-IP:

єдиний тенант Cloudflare, та сама марність. TXT-записи: загальний SPF, жодних токенів верифікації, пошта не налаштована (немає MX).

Немає нічого на рівні домену, з чого зробити півот. Кожен побічний канал, якого вчить цей розділ, повертає шум або нічого. Чесний звіт клієнту: *недостатньо сигналу лише на рівні домену*. Слід іде далі в інших шарах — СТ-логи Розділу 6, сусіди пасивного DNS Розділу 8, HTML-відбитки сайту й ідентифікатори аналітики, що теж територія Розділу 8. Домен сам по собі не сказав мені нічого. Це реальна відповідь, і я записую її як таку.

Безпечна вправа

Зроби це на собі, на домені, яким справді володієш. Прочитай живий WHOIS. Прочитай кожен тип DNS-запису. Прочитай свої TXT-записи очима чужинця, шукаючи токени верифікації й деталі поштового стека. Потім напиши короткий абзац: із самих цих записів, що сторонній міг би дізнатися про те, які платформи ти використовуєш, чию пошту маршрутизуєш і які інші твої домени сидять у тому самому сусідстві? Більшість людей вражені тим, скільки себе публікуються-за-замовчуванням у DNS.

Підсумок

- Домен — це не сайт; це *запис* про сайт, і кожна зміна цього запису фіксується.
- Живий WHOIS після 2018-го зазвичай редагує реєстранта, але все ще повертає реєстратора, дати, прапорці статусу і — найкорисніше — сервери імен.
- Історичний WHOIS тримає світ до 2018-го відкритим. Email 2011-го, що його ніколи не вичистили, часто — вся справа.
- Читай кожен тип DNS-запису — A, AAAA, MX, NS, TXT. TXT витікає найбільше.
- Reverse-IP і reverse-NS — це півоти, не відповіді; зважуй за тим, наскільки гучне сусідство.
- Уподобання реєстратора й тенанти токенів верифікації — це сигнали кластера, слабкі на самоті, значущі в комбінації.
- Рангуй на драбині, як завжди: два помірні — це не сильний; один чистий сигнал самопосилання — так.
- Коли рівень домену повертає нічого, скажи це. Є інші шари.

Розділ 6 переходить у наступний — СТ-логи, де кожен TLS-сертифікат, коли-небудь випущений на ім'я, записаний публічно, назавжди.



РОЗДІЛ ШОСТИЙ

Прозорість сертифікатів

Кожен сертифікат, якому довіряють браузери, тепер публікується, назавжди, відкрито.

Команда з нарахування зарплати в компанії середнього розміру проводить п'ятничний день, збираючи по частинах нове staging-середовище. Воно має бути лише внутрішнім. Їхній DNS ніколи не згадує його в публічних зонах; їхній фаєрвол блокує випадкові скани ззовні; ніхто в компанії нікому про нього не казав. Потім їхній оператор за десять хвилин до відходу на вихідні запускає certbot — стандартний інструмент для отримання TLS-сертифіката від Let's Encrypt — на хост-ім'я staging-payroll.corp-example.com, бо HTTPS

простіше, ніж попередження браузера в понеділок уранці.

За кілька секунд це хост-ім'я — публічне. Не через витік, не через неправильну конфігурацію, не через те, що їх хтось сканував. За задумом сучасного вебу. Сертифікат, який оператор щойно запросив, було відправлено в `append-only` лог у мить випуску, і він сидітиме там, доступний до читання будь-кому, фактично назавжди. Стіна встояла. Фаєрвол встояв. Внутрішній DNS лишився приватним. Але *ім'я* — `staging-payroll.corp-example.com` — назовні.

Ти їх не сканував. Ти їх не пробував. Ти прочитав комплаєнс-запис, який індустрія браузерів навмисно зробила обов'язковим. Цей розділ — про той запис.

Ідея: браузери зробили приватність TLS-іменованих хостів неможливою

У середині 2010-х індустрія браузерів вичерпала терпіння з помилково випущеними сертифікатами. Кілька гучних інцидентів — сертифікаційний орган тихо випускає сертифікат для домену, який не мав жодного права підписувати, скомпрометований емітент карбує сертифікати з брендом Google, уряди тиснуть на національні СА — показали, що модель приватної довіри не піддається аудиту. Відповіддю стала прозорість сертифікатів (СТ), формалізована в RFC 6962: мережа append-only публічних логів. Кожен публічно довірений сертифікат має бути опублікований щонайменше в один лог у мить випуску. Якщо сертифіката немає в логах, сучасні браузери відмовляються йому довіряти. На практиці «сучасні браузери» — це політика Chrome із 2018-го та Apple з того самого року; Firefox ніколи не примушував СТ. Разом ринкова частка Chrome і Safari робить СТ фактично обов'язковим для будь-якого сертифіката, призначеного для публічного вебу.

Ця політика має другорядний наслідок, який укладачі знали й прийняли. Будь-яке хост-ім'я, захищене публічно довіреним TLS-сертифікатом, — це хост-ім'я, зафіксоване в публічному лозі. Не «виявне в теорії» — зафіксоване, у пошуковій базі, з міткою часу, назавжди, індексоване

десятками агрегаторів.

Ти не експлуатуєш баг. Ти читаєш комплаєнс-запис. Ця постановка важлива, бо вона й окреслює лінію: усе в цьому розділі — робота з публічним записом; ніщо в цьому розділі не дозволяє тобі *торкатися* жодного хоста, який ти виявиш. Ми до цього повернемося.

Терміни в один рядок

- CA (Certificate Authority) — організація, що підписує сертифікат; Let's Encrypt, DigiCert, Sectigo, GoDaddy та ще приблизно дюжина інших обслуговують майже все.
- СТ-лог — append-only публічний запис кожного випущеного сертифіката; можна шукати, підписатися, і ніколи не видаляти.
- SAN (Subject Alternative Name) — список хост-імен, які покриває один сертифікат; часто десятки, іноді сотні.
- Wildcard — SAN виду *.example.com, що покриває кожен піддомен, не називаючи жодного.
- CN (Common Name) — застаріле поле, що колись тримало основне хост-ім'я; досі часто заповнюється, але тепер важить SAN.
- Precertificate — копія сертифіката, який СА збирається випустити, помічена «отруйним» розширенням, щоб браузері її не приймали, і подана в логи першою, аби лог повернув Signed Certificate Timestamps, що вбудуються у

фінальний сертифікат. Precertificate — це запис, який ти бачиш при пошуку в СТ-лозі; окремого пізнішого запису для справжнього сертифіката немає.

- Emitter (Issuer) — СА, що підписав конкретний сертифікат; один і той самий оператор за рік часто використовує кількох.

Що СТ насправді дає

- Майже повне перерахування *зовні видимих* хост-імен цільової організації — включно з staging, admin, api, dev, payroll, jenkins, git-піддоменами, які оператор не мав наміру рекламувати, але хотів мати на них HTTPS.
- Історичний запис — хост-імена з простроченими, відкликаними чи видаленими сертифікатами все ще з'являються в лозі; піддомен, що перестав резолвитися у 2022-му, досі видно сьогодні як свідчення, що він колись існував.
- Крос-емітентний вигляд — одна компанія рутинно використовує три-чотири СА на staging, продакшн і різні SaaS-обгортки; пошук за доменом об'єднує їх усіх в один список.
- Витоки SaaS-тенантів — SaaS-провайдер випускає per-customer сертифікати (acme-corp.zendesk.com, acme-corp.atlassian.net), і пошук за власним доменом SaaS через SAN виявляє кожного клієнта, чиє ім'я тенанта колись сертифікували.

- Тайминг — precertificate для нового середовища часто видно за години до того, як середовище оголошено публічно, бо оператори роблять TLS до того, як розрізати стрічку.
- Крос-організаційний вигляд спільної інфраструктури — два бренди, що ділять сертифікат в одному списку SAN, недвозначно ділять хостинг.

Чим СТ не є

СТ бачить лише *публічно довірені* сертифікати — ті, яким довірятиме браузер. Організація, що тримає повністю внутрішню РКІ (самопідписані або підписані приватним СА, який вона контролює й роздає власним машинам), у СТ не з'являється взагалі. СТ також не показує, що працює *на* хості, — лише ім'я. Хост-ім'я саме по собі — це відкритий слід, не атрибуція: воно каже, що щось існує за адресою, а не хто за ним стоїть чи що воно робить. Усе в цьому розділі перетворює хост-імена на зачіпки, які пізніші розділи конвертують у людей і в підтверджене використання.

Метод, крок за кроком

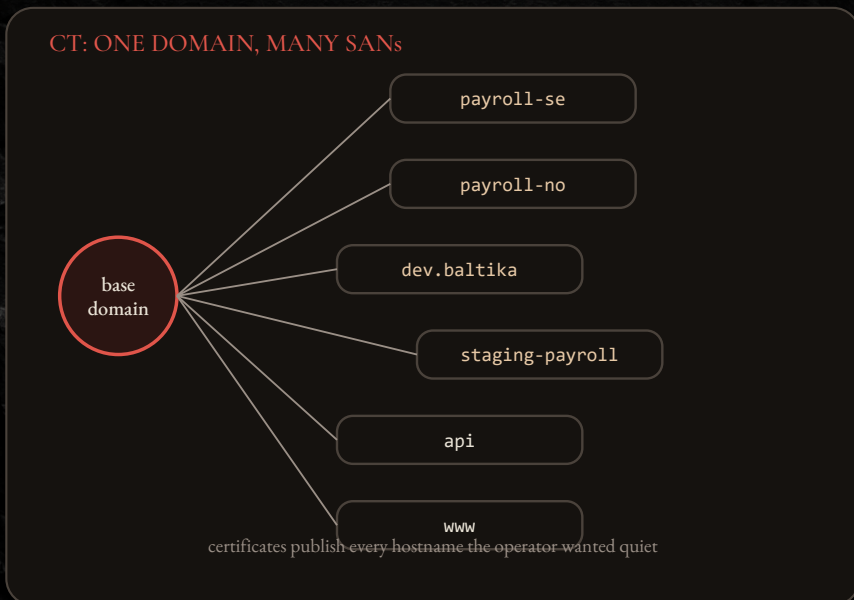
Крок 1 — Заякори домен. З роботи Розділу 5 щодо WHOIS і DNS у тебе вже є базовий домен, який цілф фактично контролює, плюс будь-які аліаси, якими вона володіє (придбання, маркетингові сайти, варіанти доменів країни). Запиши їх. СТ-запити повертають рівно те, про що ти питаєш; пропущений аліас — це пропущена гілка дерева.

Крок 2 — Запитай СТ для базового домену і кожного відомого аліасу. Форма запиту однакова в кожному СТ-пошуковому інтерфейсі — crt.sh і його аналоги приймають доменний вираз і повертають сертифікати, чий SAN-список йому відповідає. Витягни кожне хост-ім'я з кожного SAN у кожному повернутому сертифікаті, дедуплікуй і посортуй за міткою часу першого бачення. Те, що ти маєш тепер, — це історія зовні сертифікованих хост-імен цілі. (Імена інтерфейсів старіють швидко; форма — «запит за доменом, читання SAN-ів» — ні.)

Крок 3 — Читай патерн іменування. Оператори не креативні. admin, api, staging, stage, stg, dev, qa, uat, test, preprod, payroll, internal, intranet, vpn, git, gitlab, jenkins, jira, wiki, mail, smtp, sso, auth, id, admin-<region>, <product>-<env> — це класичний словник патернів витоку. Скупчення їх каже про *форму* внутрішнього середовища ще до того, як ти подивишся на будь-який контент. Шість піддоменів на кшталт jenkins, sonarqube, nexus, git, jira, wiki

окреслюють цілий DevOps-стек без жодного пробу.

Крок 4 — Перевір за DNS. Хост-ім'я, видиме в СТ, яке також резолвиться — має живий **A** чи **AAAA**-запис — досягне просто зараз. Хост-ім'я, видиме в СТ, яке більше не резолвиться, — виведене з експлуатації, але було реальним у якийсь момент. Обидва важать. Живі — це поточна атакована поверхня для захисника чи поточна дослідницька поверхня для дослідника; мертві окреслюють, як середовище виглядало раніше, що часто розповідає більше, ніж те, як воно виглядає сьогодні, бо оператори прибирають продакшн і лишають staging у лозі назавжди.



Базовий домен у корені, віяло SAN-ів від кожного сертифіката, і поділ між гілками, живими в DNS, і лише історичними. Історичні гілки — і є підказка.

Крок 5 — Шукай витоки тенантів. Кожен SaaS-продукт, що дає клієнтам своє хост-ім'я, кладе ці хост-імена в СТ. Візьми SaaS, який цілком імовірно використовує, — helpdesk, wiki, issue tracker, платіжний процесор — і пошукай у СТ домен SaaS. Прогрепай повернуті SAN-списки на ім'я цілі. Сертифікат, що покриває acme-corp.zendesk.com, доводить, що Acme Corp має платний тенант Zendesk. Ніхто в Acme цього не публікував. Ніхто в Zendesk цього не публікував. СТ-лог — так, бо Zendesk мусив це сертифікувати.

Спробуй (2026). Пошукай у СТ-інтерфейсі свій власний домен. Прочитай хронологію сертифікатів, які ти випускав собі за роки. Відзнач staging-хост, про який забув, придбаний бренд, яким і досі володієш, wilddcard від СА, який, ти думав, ти вже перестав використовувати. Це вправа, що навчає ока на патерн витоку; вона ж по ходу закриває кілька твоїх власних витоків.

Крок 6 — Стеж за стрічкою. Деякі сервіси (згадуй як *форму*, не як рекомендацію — конкретні імена змінюються) дають підписатися на домен: кожен новий випуск сертифіката тригерить сповіщення тобі за хвилини. Так дослідники помічають запуски продуктів, придбання й нові регіональні розширення до пресрелізу. Новий SAN, що з'являється під доменом конкурента на ім'я payroll-de о 03:17 у вівторок, — це дані, яких ти інакше ніколи не мав би.

Крок 7 — Рангуй. Хост-ім'я — це *відкритий слід*, не *атрибуція*. Живий admin-піддомен каже, що організація існує й має адмін-інтерфейс; він не називає людину, не доводить використання, не дозволяє жодного наступного кроку. Лише в комбінації з контентом (Розділ 7) або відбитками інфраструктури (Розділ 8) відкритий слід стає зачіпкою, що вказує на людину. Зваж фрагмент на драбині чесно, потім вирішуй.

Опрацьована справа, з тупиками включно

Клієнт із фінансової преси попросив мене перевірити одну конкурентну заяву перед публікацією. Стартап-конкурент розповідав інвесторам, що маленька SaaS-компанія на ім'я Halkstone Labs — публічно описана лише як «фінтех-шоп інструментів» на односторонковому маркетинговому сайті — тихо будує продукт для нарахування зарплати для скандинавського ринку. Сайт Halkstone нічого не казав про payroll і нічого про Скандинавію. Клієнт не хотів контактувати з ціллю і насторожувати її. Хотів знати з відкритих джерел, чи витримує заява конкурента. Вигадана компанія, реальний метод.

Якір. З маркетингового сайту і з WHOIS-проходу Розділу 5 базовий домен був halkstonelabs.com. Жодних очевидних аліасів, жодних придбаних брендів не сплигло. Тож один СТ-запит.

Перший прохід був здебільшого нудний.

```
crt.sh style listing, halkstonelabs.com
-----
47 certificates, 3 issuers
oldest 2021-04, newest 2026-06

SAN samples (dedup):
  www.halkstonelabs.com
  mail.halkstonelabs.com
  api.halkstonelabs.com
  stage.halkstonelabs.com
  status.halkstonelabs.com
  *.halkstonelabs.com   (wildcard, 2024-11)
-----
жодного "payroll" поки не видно
```

Сорок сім сертифікатів, а SAN-список схожий на кожен інший маленький SaaS в інтернеті.

Тупик перший — нудний кластер. `www`, `mail`, `api`, `stage`, `status`. Нічого там не натякало на нову лінію продукту, а тим більше — на `payroll` для скандинавського ринку. Це поширений патерн: шоп із малим слідом тримає малий SAN-список на основному сертифікаті й ротує ту саму жменю.

Тупик другий — `wildcard`. У листопаді 2024-го вони випустили `wildcard`, `*.halkstonelabs.com`. `Wildcard` покриває кожен піддомен, але *не називає* жодного. Тож сам `wildcard`-сертифікат доводить, що оператор передбачав багато піддоменів — маленький, але реальний сигнал — не кажучи тобі при цьому нічого про те, *які саме*. Це

компроміс, на якому побудовані wilddcard-и, і саме це робить їх привабливими для організацій, що розуміють СТ.

Тупик третій — піддомен-привид. Один старший сертифікат, із 2022-го, мав SAN для `dev.halkstonelabs.com`. Обіцяюче. Я відзначив, потім звірив у DNS: `dev.halkstonelabs.com` більше не резолвиться. Сертифікат сплив і не поновлювався. Історично реальний, зараз мертвий — свідчення, що в компанії був dev-середовище в якийсь момент, але живих дверей, до яких можна підійти, немає.

Тупик четвертий — хибнопозитивний пошук тенанта. На здогад, що вони користуються поширеними SaaS-інструментами, я пробіг пошук тенантів по `atlassian.net` і `zendesk.com`. Жодного `halkstonelabs` ні там, ні там. Або вони використовують ці продукти під іншим ім'ям тенанта, або взагалі не використовують. Відсутність у СТ — не доказ відсутності в реальності; тенант може існувати під ім'ям, якого я не вгадав, — поширений трюк реєструвати тенант під проєктним кодовим ім'ям, що не має нічого спільного з батьківським брендом. Відзнач нуль, іди далі.

Тупик п'ятий — однойменна колізія. Сортуючи повернуті сертифікати за емітентом, один запис виділявся: сертифікат, випущений маловідомим регіональним СА на `halkstone.labs` — без `s`, інший TLD, і з SAN-ами, що вказують на бутіковий винний магазин на півдні Франції. Однойменні колізії — правило, не виняток, у результатах СТ, бо лог індексує

кожен рядок, який кожен СА колись підписав. Я викинув винний магазин і пішов далі. Урок: перевір, що базовий домен, який ти запитував, і базовий домен, який отримав, збігаються точно, ще до того, як щось зараховувати.

Тоді лог виплатив. Сортуючи SAN-список за міткою часу першого бачення, три записи з останнього місяця скупчилися разом.

```
Sorted-by-first-seen SAN readout
-----
2026-06-24  payroll-no.halkstonelabs.com
            precertificate, Let's Encrypt
2026-07-02  payroll-se.halkstonelabs.com
            precertificate, Let's Encrypt
2026-07-11  payroll-uat.halkstonelabs.com
            full cert, Let's Encrypt
-----
"no" = Норвегія, "se" = Швеція,
uat = user acceptance test — реальний трек
```

Три сертифікати, три тижні, одна історія.

Читай патерн чесно. payroll-no і payroll-se — сильні натяки: no і se — це ISO-коди країн для Норвегії та Швеції, і жодне інше іменування продуктової лінії в SAN-історії Halkstone не використовує цей суфіксний патерн. payroll-uat — це вкид: user acceptance testing — це стадія, яка існує лише тоді, коли реальний продукт достатньо близький до реальних клієнтів, щоб виправдати клієнтське тестове середовище. Ти не піднімаєш UAT для повітря.

Звірка з DNS: усі три резольвляться, на IP у тому самому хостинг-блоці, що й решта інфраструктури halkstonelabs.com. Тож середовища не просто сертифіковані — вони живі. Я їх не відкривав. Я не надіслав жодного запиту до жодного з трьох хостів поза резолюцією імені. Це була лінія.

Що я звітував. Заява конкурента підтверджується публічним відкритим слідом СТ: Halkstone Labs тримає продуктову лінію рауголл із норвезьким і шведським варіантами плюс робочим UAT-середовищем, уперше сертифіковану за останні чотири тижні. Свідчення — публічний запис і відтворне; клієнт може перевірити самостійно, не контактуючи з ціллю. Я чесно позначив wildcard і сертифікат-привид dev як фонові сигнали, а не як виплату, і зауважив, що СТ каже нам форму й тайминг, але не *зміст* — чи продукт за тиждень чи за шість місяців до запуску для клієнтів, це питання, на яке СТ відповісти не може.

Клієнт запустив матеріал. Історія витримала.

Друга справа: та, що не закривається

Інший мікрокейс, оборонний підрядник. Клієнт попросив те саме: перерахувати зовні видиме середовище через СТ і накидати форму. СТ-пошук повернув рівно один сертифікат: wildcard на маркетинговому домені, випущений мейнстрімовим СА, що покриває маркетинговий сайт і аліас www. І все. Ні staging, ні admin, ні jenkins, жодних витоків тенантів у жодному SaaS, який я пробував.

Причина проста для здогаду й неможлива для обходу: цей підрядник тримає повністю внутрішню РКІ. Кожен внутрішній хост підписано приватним СА, роздатим на власні машини. Жоден із цих сертифікатів ніколи не потрапляє в публічний лог, бо вони не публічно довірені й ніколи такими не задумувалися. СТ був спроектований, щоб зробити *публічну* довіру придатною до аудиту; про приватну довіру він за задумом не каже нічого.

Чесний звіт клієнту: *СТ тут не дає нічого. Ця ціль не витікає через СТ. Переходь до Розділу 7 для контент-орієнтованих кутів або прийми межу*. Не кожен метод виплачує на кожній цілі, і зрілість РКІ цілі — сигнал сам по собі, вартий того, щоб його записати.

Примітка про етику

Виявлення внутрішньо виглядного хост-імені не дозволяє тобі його пробувати. Читання СТ-лога — робота з публічним записом; відкриття TSP-з'єднання до `admin.corp-example.com`, надсилання HTTP-запиту, запуск port-скана чи спроба облікових даних — це інша категорія дії і в більшості юрисдикцій регулюється законами про несанкціонований доступ, яким байдуже, що хост-ім'я було легко знайти. Зупинись на імені. Хост-ім'я заходить у твої нотатки як факт про відкритий слід цілі; воно не стає дверима, у які ти заходиш. Винятки вузькі й формальні: опублікований скоуп bug-bounty, що перераховує хост; авторизований pentest-енгейджмент; або дослідницька угода в скоупі — завжди в письмі, завжди конкретна. Без цього етична лінія проходить рівно на межі між читанням лога й дотиком до хоста, а юридична лінія часто проходить у тому самому місці.

Безпечна вправа

Обери відомий SaaS-продукт — helpdesk, issue tracker, платіжний процесор — чиї клієнти отримують своє хост-ім'я. Пошукай у CT домен продукту і прочитай патерни SAN. Відзнач конвенцію іменування (<customer>.product.com, або <region>-<customer>.product.com, або навпаки), wildcard-и, які вендор випускає собі, і зрадливо внутрішньо звучні хост-імена, які вендор забув, що виставлені назовні. Ти вийдеш із робочим оком на патерн витоку і сильною підозрою, що більша частина SaaS-ринку тихо опублікувала свій список клієнтів, ніколи не маючи такого наміру.

Підсумок

- Прозорість сертифікатів перетворює кожен публічно довірений TLS-сертифікат на постійний, пошуковий публічний запис — політикою браузерів, а не витоком.
- Будь-яке хост-ім'я, захищене публічно довіреним сертифікатом, — це хост-ім'я в публічному лозі; ти читаєш комплаєнс-запис, ти не атакуєш ціль.
- Список SAN на одному сертифікаті часто називає десятки хост-імен; класичні витоки — admin, staging, dev, payroll, jenkins, git і решта DevOps-словника.
- Wildcard-и ховають піддомени за *; вони сигналізують широту, не називаючи імен.

- Precertificate і мітки часу першого бачення дають помітити нові середовища за години до публічного оголошення.
- Витоки SaaS-тенантів — пошук у СТ власного домену SaaS виявляє per-customer хост-імена тенантів, які клієнт ніколи не оголошував.
- СТ мовчить про внутрішню РКІ; ціль, що підписує все приватним СА, дає СТ нічого.
- Хост-імена — це *відкритий слід*, не *атрибуція*.
Зупинись на імені; не торкайся хоста без письмової авторизації.

Розділ 7 повертається від інфраструктури назад до людей: як *контент*, поданий на цих хост-іменах, — фавікон, копірайт у футері, ID аналітики, ім'я автора в HTML-коментарі — несе людський відбиток, який хост-ім'я саме по собі приховує.



РОЗДІЛ СЬОМИЙ

Від інфраструктури — назад до людини

*У серверів немає імен. Їхні оператори не в змозі втриматися й
таки залишають одне.*

Є сайт, що продає фейкові прес-релізи. Виглядає як стрічка новин — шапка, дата, підпис, у якому значиться лише «staff». Немає сторінки «About». Немає імпринту. Домен — свіжа реєстрація, WHOIS повністю прихований приватністю, хостинг за великим CDN. Фронтальний пошук вмирає ще на порозі.

Але на вкладці браузера є фавікон — маленький помаранчевий квадрат зі стилізованою літерою М. І цей самий фавікон, байт у байт ідентичний, сидить у вкладці, коли ти відкриваєш ще три сайти, які зовні не мають нічого спільного: магазин добавок, блог «оглядів криптовалют» та фейкову місцеву газету одного містечка в іншій країні. І два з цих чотирьох несуть у вихідному коді сторінки один і той самий Google AdSense publisher ID — рядок, що починається з pub- і прив'язує рекламний акаунт до єдиної Google-ідентичності. І цей AdSense ID виринає ще на п'ятому сайті — маленькому кулінарному блозі з підписом автора та реальним ім'ям.

Цей розділ — завіса. Все, що було до нього, стосувалося інфраструктури — доменів, DNS, сертифікатів, хостів. Все, що йде після, як тільки ти переходиш завісу, знову стає про людину, і саме там перебирає естафету Том 2. Сам півот — це те, чого вчить цей розділ.

Ідея: оператори лишають відбитки на своїх інструментах

Сервер — анонімний. Людина, що його налаштовує, — ні.

У кожного оператора є звички. Є аналітичний акаунт, який вони завжди вставляють, бо це той, від якого пам'ятають логін. Є файл фавікону, який вони тягають від проєкту до проєкту, бо колись зробили один і більше не завдавали собі

клопоту робити інший. Є тема WordPress, до якої вони завжди тягнуться, бо купили ліцензію у 2021-му, і тепер кожен новий сайт починається з тієї самої теки. Є патерн часу комітів, який зраджує години, коли вони насправді сидять за клавіатурою, і мова, якою написані їхні коментарі, яку жоден конфіг не приховає.

Будь-яка з цих звичок сама по собі — слабкий сигнал. Фавікон може повторюватися, бо обидва оператори завантажили ту саму безкоштовну іконку. AdSense ID може збігтися, бо хтось помилково вставив старий сніпет. Тему WordPress купують тисячі людей. Кожна звичка окремо не доводить нічого.

Дві-три звички, що збігаються в незалежних джерелах — збіг фавікону, збіг аналітичного ID, збіг часового поясу комітів, жодну з яких не можна списати на ту саму випадковість, — це вже інше. Саме це будує цей розділ.

Класи операторських відбитків

- Аналітичні ID. GA4 measurement ID (G-XXXXXXXXXX), старі теги Universal Analytics (UA-XXXXXX-Y), AdSense publisher ID (pub-XXXXXXXXXXXXXXXXXX), Facebook Pixel ID, лічильники Yandex.Metrika. Той самий ID на двох сайтах означає той самий *акаунт* на боці вендора, а акаунт належить одному логіну. Це один із найсильніших операторських сигналів, який ти взагалі знайдеш на інфраструктурному шарі. І один із найчастіше переоцінених: спільний сніпет GA може називати *будівельника*, а не власника — молодшого підрядника, який використовує той самий тег у неспоріднених клієнтів, або партнерську мережу, де десяток маркетологів вставляють один і той самий AdSense ID. Ранжуй знахідку спершу як «той самий акаунт», і лише коли другий незалежний сигнал підтвердить, підвищуй до «той самий оператор».
- Відбитки фавікону та зображень. Фавікон — це файл. Файли гешуються. Якщо два нібито неспоріднені сайти віддають *ті самі байти* на /favicon.ico, це майже ніколи не збіг — це одна й та сама людина розгортає одну й ту саму теку. Та сама логіка поширюється на будь-який маленький ресурс, що йде з шаблоном сайту: логотип у шапці, плейсхолдер-зображення, JavaScript-файл із характерним коментарем.

- **Комбінації тех-стеку.** Сам WordPress — звичайна річ. WordPress плюс конкретна платна тема плюс конкретний набір плагінів, які підвантажуються в одному й тому самому порядку, — часто вже унікальні для оператора. Інструмент, що класифікує тех-стеки, корисний для окремих ознак, але ідентифікує саме комбінація.
- **Історичний WHOIS-email.** Розділ п'ятий уже докладно на цьому спинявся. Сучасний WHOIS прихований, але домен, що існував до середини 2018-го, зазвичай має публічний email реєстранта, зафіксований в одній з історичних баз, і цей email часто — реальна адреса оператора.
- **Публічний git та метадані комітів.** Якщо хоч якась частина коду сайту, або сусідній проект, яким оператор пишався, лежить у публічному репозиторії, історія git видає email комітера, мову повідомлень комітів і часовий пояс кожного коміту. Репозиторій, коміти якого купчуються між 21:00 і 02:00 у UTC+3, розповідає тобі й у якій частині світу живе оператор, і яку частину доби він вважає робочою.
- **Витоки на сторінках помилок.** Погано налаштований nginx повертає стандартну сторінку, що називає внутрішній хостнейм. Забутий ендпойнт `mod_status` на сервері Apache перелічує всі віртуальні хости, які він обслуговує — іноді включно з сайтами, які оператор не хотів мати на тій самій машині. Файл `.env`, забутий у

webroot, трапляється не так рідко, як хотілося б.

- Адреси звітів DMARC. Скринька у DMARC TXT-запису домену — `ua=mailto:...` — це куди збираються звіти автентифікації пошти, і людина, що це налаштовувала, зазвичай направила їх на свою власну адмін-адресу.
- Заголовки контакт-форм і пошти. Сирий вивід контакт-форми або заголовок Reply-To листа, який вона генерує, іноді несе реальну скриньку оператора, а не публічний alias сайту.

Незалежність, ще раз

Том 2 дав тобі правило драбини — слабкий, помірний, сильний, підтверджено — і попереджав, що стек не-незалежних сигналів — найшвидший спосіб бути впевненим не в тому. Це правило працює тут без змін.

Збіг фавікону і збіг тех-стеку на *тому самому сайті* — це два ракурси одного налаштування. Одна тека одного оператора породила обидва. Це один сигнал у двох плащах, а не два незалежні голоси.

Збіг фавікону на сайті А і збіг аналітичного ID на сайті В — це два незалежні голоси. Різні файли, різні вендори, різні режими провалу. Коли вони збігаються — збігаються чесно.

Та сама пастка, яку ти вчився помічати в розділі про граф ідентичностей, є й тут. Питай про кожну пару: чи могли

вони розійтися й не розійшлися. Якщо так — рахуй. Якщо ні — рахуй один раз.

Є ще тонший варіант пастки. Спільний аналітичний ID між маркетинговим сайтом компанії та її власним сайтом підтримки — це один оператор, нудно й правильно. Спільний аналітичний ID між сайтами абсолютно неспоріднених індустрій — магазин добавок, місцева новинна замітка, огляди кухонної техніки — з більшою ймовірністю є спільним *розробником*, а не спільним *власником*. Перш ніж записувати знахідку, постав питання спростування: *яка альтернативна історія породила б той самий відбиток?* Якщо «один фрилансер, що збудував усі три» пасує так само добре, як і «один оператор, що керує всіма трьома», у тебе ще немає оператора.

Метод, крок за кроком

Крок 1 — Якір. Промов півот-точку вголос. У тебе є домен, хостнейм, URL. Запиши його. Все, що йтиме далі, — це спиця з цього центра, і якщо ти згубиш центр, то почнеш перемішувати знахідки з різних цілей.

Крок 2 — Витягни вихідний код сторінки. Відкрий сайт у браузері та подивись сирий код головної та двох-трьох підсторінок. Витягни кожен ідентифікатор, що виглядає як тег: аналітичні ID, ID контейнерів tag-manager, ID пікселів, токени верифікації сайту, хостнейми в src скриптів, імена

таблиць стилів, характерні імена класів. Не читай сторінку задля того, що вона каже. Читай її задля того, що її код випадково зізнається.

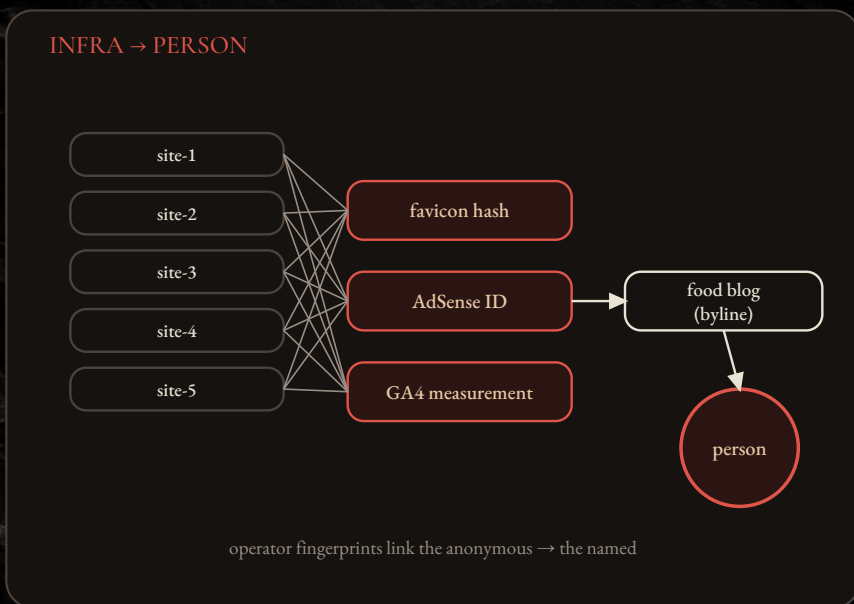
Крок 3 — Порахуй геш фавікону. Завантаж `/favicon.ico` і порахуй його геш. Домовленість, яку використовують інфраструктурні пошуковики, — MurmurHash3 від base64-закодованих байтів; MD5 або SHA-256 сирого файлу теж підійдуть для крос-перевірки. Тоді пошукай інші хости, що віддають файл із тим самим гешем. Shodan і Censys, станом на 2026 рік, обидва індексують геші фавіконів і дозволяють запитувати за ними — перевір актуальний синтаксис запиту, перш ніж на це покладатися.

Крок 4 — Пошукай аналітичні ID деінде. Візьми кожен ID, який ти витягнув на кроці 2, і пошукай точний рядок у ширшому вебi. Google знайде деякі. Спеціалізовані сервіси, що індексують вихідний код сторінок на предмет tracking ID, знайдуть більше. Один AdSense або GA ID, що з'являється на другому, нібито неспорідненому домені — це один із найсильніших операторських сигналів на інфраструктурному шарі, бо ID за визначенням належить одному вендорському акаунту.

Крок 5 — Прочитай слід WHOIS ще раз, уже з новим контекстом. Ти вже робив це в розділі п'ятому саме заради цього. Зроби ще раз, тепер із метою: email, який ти знайдеш у записі до 2018 року, — це кандидат для перевірки проти всіх

інших знахідок.

Крок 6 — Шукай власні недогарки оператора. Забери humans.txt, security.txt, robots.txt, sitemap.xml. Спробуй contact.html, about.html, team.html, imprint.html. Будь-що з іменем. Далі перевір архів на предмет версій цих сторінок до того, як оператор їх вичистив, — матеріал із першого розділу застосовується напряду.



Один якірний домен у центрі, зі спицями до кожного класу відбитків: аналітичні ID, геш фавікону, tech-стек, історичний WHOIS, витоки на сторінках помилок, адреса DMARC, заголовки контакт-форми, публічний git. Кожна спиця закінчується маленьким кластером інших хостів чи ідентифікаторів, де повторюється той самий відбиток. Кластери накладаються там, де два незалежні відбитки

приземляються на той самий другий хост, — ці накладення й є найсильніші точки атрибуції, а до людини ти доходиш, ідучи від накладень назовні.

Крок 7 — Півот у крос-платформну роботу. Тієї миті, коли будь-який із цих кроків дає ім'я, email-адресу або особистий соцмедіа-хендл, ти перетнув завісу. Все, чого ти навчився в Томі 2 — робота з графом ідентичностей, робота над узгодженням сигналів — тепер застосовується до людини на іншому боці. Передавай півот у цей інструментарій; не намагайся превчати це тут.

Спробуй (2026). Візьми особистий сайт чи блог, який ти сам ведеш. Відкрий його код і випиши кожен аналітичний ID, піксель, токен верифікації та сторонній скрипт, який він підвантажує. Завантаж його фавікон і порахуй MurmurHash3 base64-закодованого файлу. Тепер пошукай у favicon-hash-індексі інші хости з тим самим гешем і пошукай у вебі кожен аналітичний ID. Подивись, що сторонній може дізнатися про тебе з одного лише півоту. Тоді холодно вирішуй, які з цих відбитків ти хочеш лишити на місці, — а які змінити завтра.

Крок 8 — Крос-референс публічного коду. Візьми характерний рядок із коду сайту — незвичне ім'я CSS-класу, написаний вручну JavaScript-коментар, шматок PHP, що не

виглядає скопійованим з туторіалу, — і пошукай точний рядок на великих сайтах хостингу коду. Влучення в особистий репозиторій — це вся гра: історія git оголює email комітера, часовий пояс кожного коміту та мову повідомлень комітів. Навіть влучення у форк може вивести на людину, якій було не байдуже настільки, щоб форкнути.

Крок 9 — Ранжуй на драбині. Запиши, одним абзацом, що є *відкритим слідом*, а що — *атрибутовано*. Відкритий слід: інфраструктура, яку ти бачиш. Атрибутовано: людина, про яку ти тепер стверджуєш, що вона цим керує, і на якому щаблі впевненості — слабкий, помірний, сильний, підтверджено. Якщо твої докази зупиняються на «одному збігу фавікону і одному спільному вендорському тенанті», у тебе є зачіпка, а не знахідка. Скажи це саме такими словами. Читач, який не розрізнить одне від одного, сприйме твою зачіпку як твій висновок, і саме твоя проза, а не його неухважність, це дозволила.

Пропрацьований кейс, з глухими кутами включно

Бриф був маленький і неромантичний. Міська рада напередодні місцевих виборів помітила п'ять сайтів у форматі новин, що публікували скоординовані матеріали про одного кандидата. Усі п'ять сайтів з'явилися в шеститижневому вікні. Усі п'ять писали одним голосом. Рада хотіла знати, хто ними керує.

Я почав там, де починається будь-який півот: WHOIS усіх п'яти. Кожен запис до останнього прихований реєстратором приватністю. Зареєстровані через одного й того самого масового реєстратора — так, але в цього реєстратора мільйони клієнтів, у кращому разі слабкий сигнал. Глухий кут.

Далі DNS. Кожен із п'яти доменів вказав свої сервери імен на Cloudflare. Reverse-IP був марний — адреси, які я бачив, належали спільному edge, за яким сидять мільйони неспоріднених сайтів. Глухий кут.

Certificate Transparency, за схемою розділу шостого. У кожного домену — сертифікат Let's Encrypt. Кожен сертифікат ніс лише власний хостнейм сайту та www. — жодного витoku адмін-піддоменів, жодних staging-середовищ, жодного випадкового SAN з іменем оператора. Глухий кут.

Контакт-форма на кожному сайті йшла, на рівні HTML, на адресу contact@ в одному й тому самому загальному Google Workspace тенанті. Ззовні я бачив, що тенант існує; хто ним володіє — не бачив. Глухий кут.

Чотири незалежні напрямки, чотири порожні. Ось як компетентно анонімізована операція виглядає ззовні — не в тому, що ти не помітив чогось хитрого, а в тому, що фронтальний шлях справді закритий.

Прорив прийшов зі вкладки браузера.

Я помітив, гортаючи ці п'ять сайтів в одному вікні, що маленькі значки на вкладках виглядають однаково. Не схоже — ідентично. Я зберіг /favicon.ico кожного сайту, порахував MurmurHash3 base64-закодованих байтів і отримав те саме число п'ять разів поспіль.

```
favicon-hash.txt
site1.example.tld  -1893478234
site2.example.tld  -1893478234
site3.example.tld  -1893478234
site4.example.tld  -1893478234
site5.example.tld  -1893478234
default apache icon 1094239847 (not ours)
default nginx icon  -0038284712 (not ours)
```

П'ять сайтів, той самий файл фавікону, байт у байт. Це не стандартне з шаблону і не двоє людей, що завантажили одну й ту саму безкоштовну іконку. Це одна тека, розгорнута п'ять разів.

Я перейшов до вихідного коду. Три з п'яти сайтів вбудовували той самий AdSense publisher ID.

```
adsense-matches.txt
site1 pub-6602934871052210
site2 pub-6602934871052210
site3 pub-6602934871052210
site4 (no ads)
site5 (no ads)
```

AdSense publisher ID — це не спільна бібліотека. Це платіжний ідентифікатор, прив'язаний до одного

Google-акаунта. Три сайти, що його несуть, означають одного оператора, який спрямовує три об'єкти на власний рекламний дохід.

Зупинися тут, бо саме на цьому полі вже палилося раніше. Спільний аналітичний або AdSense ID — це відомий сигнал і відомий хибнопозитив. У 2020-му Bellingcat і The Grayzone обмінялися публічними суперечками саме про такий тип знахідок — чи доводить спільний Google-акаунт між кількома виданнями скоординоване володіння, чи лише спільну сантехніку. Жодна сторона не виграла ту суперечку повністю; урок пережив її. Сприймай збіг ID як сильну зачіпку, а не як вердикт. Перш ніж написати «один оператор», шукай другий незалежний сигнал — збіг фавікону, перетин контенту, незвичний спільний хостинговий відбиток. Два голоси, кожен з яких міг би не збігтися і не збіглися, — це знахідка. Один голос — це зачіпка.

Я запустив цей самий publisher ID як текстовий пошук у ширшому вебi. Він влучив у шостий сайт — невеликий, сонний кулінарний блог, зареєстрований у 2019-му, не пов'язаний темою з жодним із п'яти, що ніс ID у футері кожної сторінки з рецептом. У блозі був підпис автора: «Ірина Петренко». Розповсюджене ім'я в регіоні — поки що зачіпка, не знахідка.

Поточна сторінка «About» блогу мала два речення й не видавала нічого. Я витяг ту саму сторінку з архіву з тримісячним інтервалом до першого захоплення. Версія 2019-го була балакучішою — абзац про автора, посилання на Twitter-хендл, місто.

Тепер я перетнув завісу. Від Twitter-хендла й далі все з Тому 2 застосовувалося: робота з графом ідентичностей, крос-платформне підтвердження, півоти в бік родини, коли прямий акаунт стих. Ця робота — не тема цього розділу, і я не буду її тут повторювати. Півот сам по собі — ось точка.

Ранжуй чесно. На рівні *оператора* — «одна людина або одна дуже маленька команда керує всіма п'ятьма цими дезінформаційними сайтами» — знахідка сильна: три незалежні голоси (збіг геша фавікону в п'яти, збіг AdSense ID у трьох, повторення AdSense ID на шостому атрибутуваному сайті), кожен із яких міг би повернутися інакше й не повернувся. На рівні *особи* — «а ця людина — Ірина Петренко з міста Х» — знахідка помірна лише на інфраструктурних доказах. Передача в Том 2 підняла її вище. Рада отримала звіт, у якому назвали щабель, а не лише ім'я.

Другий кейс: той, що не закривається

Наступна ціль виглядала як така сама робота — і не була.

Один сайт, один домен, скоординована поведінка в соцмедіа навколо нього. WHOIS: повністю прихований, свіжа реєстрація 2024-го. DNS: Cloudflare, generic. CT: один сертифікат Let's Encrypt, один SAN. Вихідний код сторінки: жодних аналітичних ID, жодного пікселя, жодного tag manager, жодних токенів верифікації. Фавікон: стандартна браузерна кулька — файл узагалі не віддається, тож немає геша для збігу. Немає humans.txt. Немає security.txt. Немає публічного git-репо, який я міг би прив'язати. Кожна адмін-поверхня доступна лише через внутрішній центр сертифікації, який публічні CT-логи ніколи не бачили. DMARC-запис присутній, rua=mailto: вказує на dmarc@ у сервісі приватного пересилання.

Кожен клас відбитків у цьому розділі був або відсутнім, або generic. Ця ціль була збудована тим, хто читав таку книгу, як ця. На інфраструктурному шарі окремо у мене не було, від чого відштовхнутися, — і чесний звіт саме це й каже, саме такими словами. Є спокуса, коли ціль закривається так чисто, вигадати ще один маленький сигнал, щоб виправдати вже витрачені години. Опирайся цьому. Чисте «нічого» — це справжня знахідка; сфабриковане «щось» — це знахідка, що вб'є кар'єру. Контр-робота проти такої добре загартованої цілі — це те, з чого починається Том 4.

Коли це не людина — коли це команда

Не кожна інфраструктурна операція належить одній особі. Спільний фавікон і спільний тех-стек на десяти сайтах можуть означати одного оператора з десятима проєктами — або одне маленьке веб-агентство, що зібрало десять сайтів для десяти різних клієнтів з одного домашнього шаблону.

Підказка зазвичай в аналітиці, але лише якщо читати уважно. Агентство часто вставляє власний GA або AdSense ID кожного клієнта в сайт цього клієнта, тож ці ID не повторюватимуться у всіх десяти. Але деякі агентства використовують один свій Google-акаунт для *частини* клієнтів — свіжіших або тих, хто на сервісі підтримки, — а для інших кодять теги руками. Патерн, який ти бачиш в агентства, нерівний: GA4 ID, що збігаються в частині пар і не збігаються в інших, у спосіб, що не вибудовується під тему чи географію. Один оператор, що керує десятима фронтами, дає рівну, нудну згоду — ті самі ідентифікатори всюди.

Інші сигнали розводять ці два випадки. Різні дизайн-системи у «тому самому» кластері — один сайт на сучасній компонентній бібліотеці, інший ще на темі 2018-го — куди типовіше для агентства, що обслуговувало різних клієнтів роками, ніж для одного оператора, що ліпить десять фронтів у спринт. Метадані часу комітів, які змішують часовий пояс у нібито пов'язаних репозиторіях, вказують туди ж; одиничні оператори не переселяються спонтанно між проєктами.

Кредити у футері з посиланням «site by *studio-name*», навіть у маленькому сірому тексті, — це те, що агентства лишають на сайтах клієнтів, які не заплатили за прибирання кредита. Реєстрантські email у WHOIS на домені самого агентства, а не на кожного клієнта, — ще один. Будь-які два з цих сигналів разом — і правильна атрибуція — *агентство*, а не особа.

Коли інфраструктурні відбитки збігаються, а ідентифікатори на рівні акаунтів розходяться, твоя атрибуція — до *агентства*, а не до якогось одного клієнта. Скажи це на драбині саме такими словами. Атрибуція спільного налаштування агентства до конкретного клієнта — це фальшива розв'язка, і поганий звіт, який юрист розбере за десять хвилин. Варто сказати прямо: атрибуція до агентства — *все ж таки* справжня атрибуція. Вона називає актора — реальний бізнес із реальним персоналом, банківським рахунком і причиною побудувати сайт. Просто називає іншого актора, ніж читач сподівався почути. Подавай знахідку як знахідку; не розтягуй її під бажану відповідь читача.

Безпечна вправа

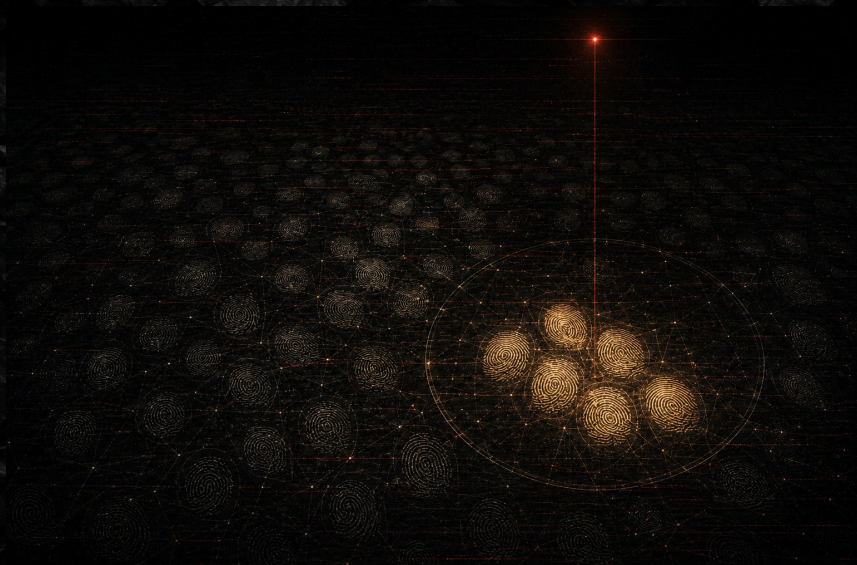
Візьми три власні сайти чи блоги — будь-що, що ти сам ведеш. Для кожного інвентаризуй кожен операторський відбиток зі списку цього розділу: аналітичні ID, геш фавікону, комбінацію теми й плагінів WordPress чи CMS, історичний WHOIS-email, якщо домен достатньо старий, будь-який публічний git-репозиторій, що несе код сайту, сторінки помилок, які течуть внутрішніми хостнеймами, адресу звітів DMARC, заголовки контакт-форм. Тепер вирішуй, один відбиток за раз, який ти готовий лишити на місці, а який хочеш змінити до завтра. З тієї години ти навчишся більше, ніж із будь-якого читання.

Підсумок

- Сервер не ідентифікує сам себе. Людина, що його налаштувала, зазвичай ідентифікує — через інструменти, які вона використовує повторно.
- Класи відбитків для перевірки: аналітичні ID, геші фавіконів, комбінації тех-стеку, історичні WHOIS-email, публічні git-метадані, витоки на сторінках помилок, адреси звітів DMARC, заголовки контакт-форм.
- Незалежність усе ще править. Збіг фавікону і збіг стеку на одному сайті — це один сигнал. Збіг фавікону на одному сайті й збіг аналітичного ID на другому — це два.

- Найсильніший операторський сигнал на цьому шарі — той самий ідентифікатор рівня акаунта — AdSense, GA, Pixel — який з'являється на нібито неспоріднених сайтах.
- Wayback — твій порятунок, коли поточну сторінку вже вичистили. Старі сторінки «About» — там, де оператори колись були необережні.
- Цей розділ — завіса. Тієї миті, коли в тебе є ім'я, email-адреса або особистий хендл, робота стає роботою Тому 2.
- Коли відбитки належать агентству, атрибулуй до агентства. Не відмивай спільний шаблон в особисту ідентичність.
- Деякі цілі побудовані так, щоб перемогти кожну техніку тут. Скажи це прямо; не фабрикуй впевненості, якої не заробив.

Розділ восьмий переходить від цих активних відбитків до пасивних слідів, які домен лишає в DNS з часом — до історії резолюцій, що переживає обережне прибирання оператора.



РОЗДІЛ ВОСЬМИЙ

Пасивний DNS і відбитки

Інтернет має пам'ять. Просто не підписує її.

Хостинг-провайдер рекламує себе особливому типу клієнтів. Без логів. Без перевірок особи. Без історії. Заплати чимось невідслідковуваним, підніми машину, знеси її, піди — ніхто, каже пітч, не дізнається, що ти там був. Зсередини панелі керування провайдера пітч правдивий.

Він правдивий лише зсередини провайдера. Того дня, коли клієнт уперше вказав хостнейм на машину, публічний резолвер десь у світі залогував DNS-запит і пізніше опублікував його в агрегаторі, що зберігає запис невизначено

довго. Три місяці по тому, коли клієнт тихо переїхав до другого провайдера, інший резолвер побачив перехід. І шість місяців потому, коли він підняв дзеркало на третьому провайдері й виписав свіжий TLS-сертифікат, скан-індекс опублікував *відбиток* TLS-стеку цього сертифіката — 62-символьну форму, що збіглася, точно, з відбитком першого сервера в першого провайдера.

Провайдер клієнта дотримав обіцянки. Інтернет зберіг свою власну пам'ять.

Ідея: інтернет має пам'ять

Дві пам'яті, не одне й те саме.

Перша — пасивний DNS, скорочено *pDNS: історія* DNS-резольцій у всьому світі. Оператори великих публічних резолверів і дослідницькі колектори логують відповіді, які їхні резолвери віддають, агрегують логи з сенсорів і публікують — безкоштовно з ліміт-рейтами або платно за обсяг. Що ти отримуєш — це часовий ряд: цей хостнейм резолвився в цю IP між датою X і датою Y, у попередню — до того, і взагалі не існував до першого спостереження. Ти не робив запит на ціль. Його зробили чийсь інші користувачі, і відповідь була записана.

Друга — це скан-індекс. Щодня жменька проєктів сканує видимий інтернет — кожному IPv4-адресу, кожен поширений порт — і фіксує, як кожен хост виглядає на мережевому

шарі: відкриті порти, TLS-сертифікати, HTTP-заголовки, стартові сторінки, фавікони. Публікують як запитуваний індекс за кожним відбитком, який вони захоплюють. Деякі зберігають історичні скани, даючи кожному хосту приблизний часовий ряд на місяці й роки.

Разом pDNS і скан-індекси дають тобі часову історію та корпус відбитків усього видимого інтернету, і при цьому ти не надіслав ані пакета своїй цілі.

Що дає пасивний DNS

- **Історична резолюція.** Цей хостнейм вказував на цю IP в такі-то дати. Зміна хостинг-провайдера — це датований перехід, видимий місяці або роки потому.
- **Зворотна історія.** Ця IP була ціллю *цих* хостнеймів у часі. На маленькому, тихому IP-блоку зворотна історія — це кластер об'єктів оператора; на величезному спільному хості — тисячі неспоріднених орендарів.
- **Трасування міграції.** Ти можеш побачити, як оператор переїжджає — стара IP згасає, коли вичерпуються кеші, нова згасає в бік появи — і прив'язати міграцію до календарного вікна. Це вікно стає відбитком саме по собі.
- **Виявлення кластерів.** Хостнейми, що всі вказували на ту саму незвичну IP протягом того самого тижня, особливо на маленькому VPS з трьома орендарями на коробці, — майже завжди один і той самий оператор. Що

рідкісніша IP, то щільніший кластер.

- Хостнейми-привиди. Імена, що резолвилися раз, більше ніколи, але лишаються в рDNS-запису назавжди. Ідеально, щоб перелічити забуті тестові середовища цілі — хостнейм, що жив вихідні у 2019-му, резолвився тридцять разів і відтоді мертвий.

Чим рDNS не є

Пасивний DNS бачить лише те, що логували публічні резолвери. Ціль, що тримає свій рекурсивний резолвер, або направляє запити через DNS-over-HTTPS чи DNS-over-TLS у стек, що не бере участі в рDNS-проекті, значною мірою невидима — запити ніколи не торкалися логуючого резолвера. Покриття нерівне за регіоном і роком; старіші дані з дірками, деякі ccTLD представлені ледве.

Комерційний рDNS несе найглибші архіви й платний. Безкоштовні тарифи існують, але жорстко лімітують, з короткою ретенцією. І перше, і друге приходять і йдуть. Сприймай *форму* як тривалу (хтось десь логує відповіді резолверів), а *конкретні двері* — як тимчасові.

Що дають скан-індекси

- Огляди відкритих портів. Кожен хост у видимому інтернеті, каталогізований за відкритим портом і банером, який він повернув, — коротким рядком, який сервіс віддає при першому з'єднанні, як-от рядок версії SSH чи привітання поштового сервера.
- Відбитки TLS-сертифікатів. Відбиток JARM TLS-стеку сервера кластеризує ідентичні налаштування. Два сервери з одним JARM запускають те саме TLS-ПЗ, налаштоване однаково, на тому самому порту.
- Відбитки HTTP-заголовків. Рядок Server, набір користувацьких X--заголовків, сигнатури фреймворків, запечені у сторінки помилок. Рідкісна комбінація — це кластерний сигнал.
- Геші фавіконів по всьому корпусу сканів. Розділ сьомий використовував фавікон у масштабі одного сайту; тут ти питаєш індекс про кожен хост в інтернеті, що віддає точно той самий фавікон, і отримуєш увесь перелік об'єктів оператора за секунди.
- Історичні знімки сканів. Деякі індекси зберігають минулі скани, тож запит по IP повертає приблизний часовий ряд — які банери вона віддавала пів року тому, який сертифікат використовувала рік тому, коли змінився її заголовок Server.

Типи відбитків, якими ти справді користуватимешся

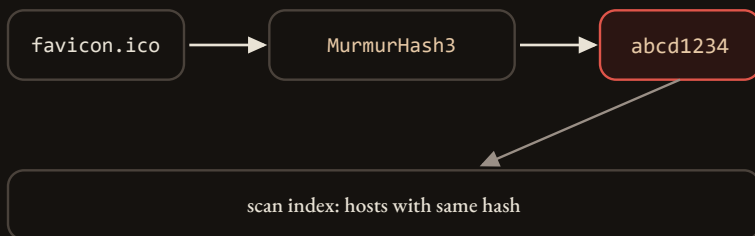
Імена змінюються; форми нижче переживають свої інструменти. Вивчи, чим кожен відбиток є, перш ніж вчитися, де його шукати.

- **Геш фавікону.** Файл іконки сайту, прогнаний через MurmurHash3 і закодований як коротке знакове ціле. Кожен сервер, що віддає байт-ідентичний фавікон, дає той самий геш — майже досконалий операторський сигнал.
- **JARM.** 62-символьний відбиток поведінки TLS-handshake сервера — як сервер відповідає, коли клієнт пропонує різні опції handshake. Однакові JARM означають однакову конфігурацію TLS-стеку. Поширені JARM (стандартний nginx, стандартний Apache) не означають нічого; рідкісний JARM — близький до підпису.
- **JA3 / JA4 / JA4S.** JA3 — старіший клієнтський TLS-відбиток (handshake, як його надсилає клієнт). JA4 — його наступник ери 2023-го з чистішими властивостями і кращою стійкістю до тривіальної рандомізації. JA4S — серверний варіант, і на відміну від JA3, JA4S напругу корисний для OSINT, бо твоя ціль зазвичай сервер. Там, де скан-індекс його підтримує, надавай перевагу JA4S над старішим JARM для свіжо-налаштованих стеків; JARM усе ще робочий кінь для величезного бек-каталогу хостів,

уже відзначених ним. Імена змінюються; *форма* — «поведінка TLS цього сервера, стиснута в короткий рядок» — це те, що переносить.

- **HTTP-заголовок Server.** Короткий рядок, який веб-сервер надсилає, ідентифікуючи себе. Часто бреше або нічого не каже (сам nginx — нічого не вартий), але рідкісне користувацьке значення — `werkzeug/2.0.1 Python/3.9.6` на саморобній адмін-панелі — щільно кластеризується по серверах оператора.
- **Геш HTML-title / meta.** `<title>` стартової сторінки або геш блоку `<meta>`. Там, де погано налаштовані сторінки статусу течуть — сканер бачить `Welcome to nginx!` поруч із забутою [Redacted] Panel v1.03 на ендпойнті статусу, який оператор мав намір закрити файрволом, — title стає підписом.
- **Набори X--заголовків.** Користувацькі HTTP-заголовки, завжди з префіксом X-, які нестандартне ПЗ додає до своїх відповідей. Конкретна комбінація в конкретному порядку часто унікальна для однієї збірки одного операторського стеку.

FAVICON HASH FINGERPRINT



one file, one hash, many hosts → one operator

Один файл фавікону, прогешований MurmurHash3, стає одним коротким рядком; скан-індекс шукає кожен хост у видимому інтернеті з точно цим рядком і повертає весь перелік властивостей оператора — той самий трюк, що й у Розділі сьомому, запущений у масштабі інтернету.

Метод, крок за кроком

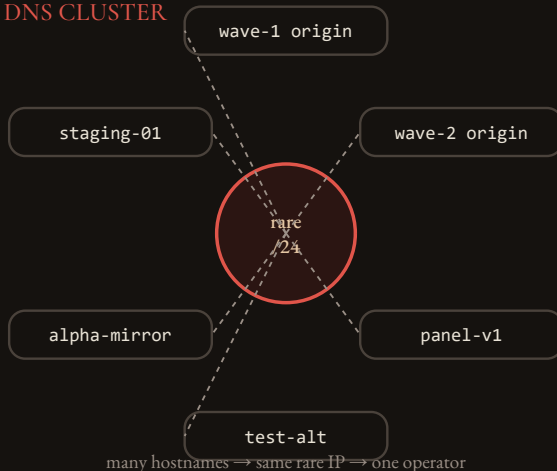
Крок 1 — Заякори домен або IP. З розділів п'ятого й шостого в тебе є базовий домен, його зовні сертифіковані хостнейми та історичні хостнейми, які більше не резолвяться. Кожен якір множить рDNS-поверхню.

Крок 2 — Витягни рDNS-таймлайн. Для кожного хостнейма попроси рDNS-сервіс кожен історичний запис A, AAAA, CNAME і NS, який він бачив. Помічай кожен перехід — день, коли змінився A-запис, день, коли переїхали сервери імен, день, коли з'явився CNAME. Кожен перехід — датована мить.

Крок 3 — Розверни рDNS на кожній історичній IP. Візьми IP з кроку 2 по одній і запитай у рDNS зворотнє: які *інші* хостнейми вказували на цю IP в тому самому вікні? На гігантському спільному хості ти отримаєш тисячі неспоріднених орендарів — шум. На маленькій, рідкісній IP, куди в час тенансі оператора вказувала жменька хостнеймів, спів-орендарі — це майже завжди інші об'єкти того самого оператора.

Крок 4 — Запитай скан-індекси щодо поточних та історичних IP. Витягни скан-індексний запис по кожній: відкриті порти, банери, TLS-сертифікати, JARM, HTTP-заголовки, HTML-title, фавікони. Читай холодно. Помічай усе незвичне — дивний рядок Server, нестандартний порт, що обслуговує HTTP, сторінку статусу, яка не мала б бути публічною, title, що читається як приватна адмін-панель.

PASSIVE DNS CLUSTER



Один цільовий хостнейм угорі; pDNS розгортає його історичні IP по одній осі, а зворотний pDNS на кожній рідкісній IP розкидає вбік кластер спів-орендованих хостнеймів. Скан-індексний запис по кожній IP висить збоку як маленький стек відбитків. Кластер — це не один сигнал; це ґратка.

Крок 5 — Відзніми TLS-стек оператора. Візьми JARM сервера оператора й запитай скан-індекс про кожен інший хост з тим самим JARM. JARM, що поділяють дванадцять мільйонів хостів, означає «стандартний nginx» — марно. JARM, що поділяють 47 хостів, — це кандидат-кластер, кожен хост — зачіпка, яку слід підтвердити pDNS-сусідством та іншими відбитками.

Спробуй (2026). Візьми відомий публічний сервіс — великий новинний сайт — і прочитай його JARM у

скан-індексі. Порахуй, скільки інших хостів його поділяють. Це буде шести- чи семизначне число: рівень шуму для цього JARM. Тепер зроби те саме для маленького self-hosted-сервісу. Число буде набагато меншим — рідкість — це те, що робить JARM діагностичним. Конкретна назва скан-індексу в будь-якому тьюторіалі, ймовірно, до цього моменту вже мертва; вправа (порахувати JARM, полічити збіги, відчувати рідкість) — ні.

Крок 6 — Порахуй геш фавікону і пошукай у скан-індексі. Та сама техніка, що в розділі сьомому, але замість того, щоб грепати кілька кандидат-сайтів, ти питаєш індекс про кожен хост із цим гешем фавікону. Рідкісний геш, що повертає три IP на трьох різних провайдерах, — це кластер, який ти жодним іншим способом не знайшов би. Точний рецепт у Python REPL — очікуй, що застаріє, страхуйся відповідно — `mmh3.hash(base64.encodebytes(open('favicon.ico','rb').read()))`; зауваж, що `encodebytes` вставляє новий рядок кожні 76 символів, і це навмисно, більшість скан-індексів це очікують. У запиті до скан-індексу сьогодні це виглядає як `http.favicon.hash:-1246753918` (синтаксис Shodan, знаковий 32-бітний int). Різні індекси використовують різні конвенції знака і різні ключі запитів; *форма* — «дай мені кожен хост, що віддає точно цей фавікон» — це те, що переносить.

Крок 7 — Кластеризуй результати. Кандидат-сусідній хост із кроку 5 — це один сигнал. Якщо той самий хост також з'являється у зворотній історії рDNS з кроку 3 на одній із рідкісних IP оператора — це два сигнали, що збігаються. Якщо його фавікон з кроку 6 теж збігається — це три. Драбина з розділу сьомого правила: незалежні сигнали, які згоджуються, заробляють *сильний*, коли їх важко пояснити будь-якою альтернативною гіпотезою. Збіги відбитків майже завжди незалежні від збігів рDNS — JARM виміряв сканер, рDNS-запис залогував резолвер, — тож вони стекуються чисто.

Крок 8 — Ранжуй чесно. Кластери відбитків спокусливі. Поширений JARM збігається з мільйонами nginx-установок і не доводить нічого; стандартний фавікон WordPress збігається з мільйонами блогів і не доводить нічого. Рідкісний JARM, який поділяють 47 хостів, — золото; рідкісний фавікон, який поділяють три, — близько до самопосилання. Перш ніж рахувати будь-який збіг відбитків як сигнал, спитай, скільки хостів у всьому інтернеті його поділяють. Мільйони — це взагалі не сигнал. Десятки — вартують того, чого вартує розділ роботи.

Пропрацьований кейс, з глухими кутами включно

Команда threat intelligence з платіжної фірми принесла мені дві фішингові хвилі того самого місяця. Хвиля перша била по їхніх роздрібних клієнтах фейковою сторінкою входу; хвиля друга йшла по їхніх бізнес-банківських клієнтах косметично іншим набором. Різні домени, різні реєстратори, різні дизайни. Питання було вузьке: один оператор за обома хвилями чи два? Кейс вигаданий, метод — справжній.

Глухий кут WHOIS. Обидві хвилі використовували домени, зареєстровані через дискаунтні реєстратори з приватністю ввімкненою від першого дня, реєстратори різні. Історичний WHOIS не повертав нічого старішого за поточну реєстрацію — обидва домени свіжі, створені за тижні до своєї хвилі. У розділі п'ятому нічого не було.

Глухий кут Cloudflare. Обидві хвилі сиділи за Cloudflare. Reverse-IP на edge Cloudflare повертає сотні тисяч неспоріднених орендарів. Повністю фронтовано, жодного півоту.

Глухий кут прозорості сертифікатів. Обидва домени тримали чисті сертифікати Let's Encrypt, виписані тієї миті, коли фішинговий сайт вставав. У жодного сертифіката не було спільного SAN з іншим; жодного спільного wildcard, жодного спільного тенанта.

Глухий кут поштових записів. У обох були TXT-записи для загальних Google Workspace-тенантів і MX-записи, що вказували на Google, з різними ідентифікаторами тенантів на кожному. Жодного SPF-збігу, що зв'язав би їх.

Чотири глухі кути. Це приблизно та точка, у якій новачок звітує про недостатній сигнал і зупиняється. Це, у цьому кейсі, було точкою, де справжня робота почалася.

Півот. Я витяг рDNS-таймлайн обох хостнеймів. Обидва показували edge-IP Cloudflare від дня, коли хостнейм уперше резолвився, і нічого більше — за винятком того, що у двогодинному вікні того дня, коли домен другої хвили встав, перш ніж оператор устиг поставити перед ним Cloudflare, хостнейм на короткий час резолвився *напрямую* на origin-IP на маленькому європейському VPS-провайдері. І тижнем раніше, на хвилі першій, ідентична помилка конфігурації протекла прямою origin-резолуцією — на іншу IP у тому самому /24 того ж маленького провайдера.


```
pDNS timeline, both waves
-----
wave-1 paylink-secure-verify.top
      2026-05-14 09:12 A 203.0.113.44
                        (EU VPS, small)
      2026-05-14 10:47 A 104.21.x.x
                        (Cloudflare edge)
      2026-05-14 10:47 ... stays Cloudflare
wave-2 business-pay-portal.top
      2026-05-30 14:03 A 203.0.113.61
                        (EU VPS, same /24)
      2026-05-30 15:58 A 172.67.x.x
                        (Cloudflare edge)
-----
two brief origin-leaks, same /24,
weeks apart
```

Дві помилки Cloudflare, тижні один від одного, обидві течуть origin на сусідні адреси в одного маленького провайдера.

Обидві origin-IP були сусідніми адресами в /24, що належав маленькому європейському реселеру з, можливо, двома тисячами клієнтів усього. Не збіг; оператор забув поставити фронт перед своїм справжнім хостом на дві години у два різні дні.

Відбитки на origin-IP. Я запитав скан-індекс щодо обох. Обидва запускали ту саму версію nginx на тому самому нестандартному порту, обидва мали той самий JARM. Цей JARM був вкрай рідкісним — індекс показав його рівно на 47 інших хостах у видимому інтернеті. Не мільйони. Сорок сім.


```
scan-index summary, JARM cluster
-----
JARM 2ad2ad0002ad2ad0002ad2ad...
matches 49 hosts total (both origins
        plus 47 others)
common? no — near-zero baseline
common characteristics:
- nginx 1.21.4 on port 8443
- self-signed cert, CN=proxy
- HTTP header set:
    Server: nginx
    X-Frame-Options: DENY
    X-Panel-Build: 1.03
- favicon hash 1173925469
-----
X-Panel-Build is not a standard header
```

Саморобний конфіг reverse-проху на рідкісному порту, з користувацьким заголовком і характерним фавіконом — відбиток стеку одного оператора.

Я читав скан-запис кожного з 47 хостів по одному. Два віддавали байт-ідентичний фавікон, який віддавали фішингові сторінки першої й другої хвиль, геш 1173925469. Один, у тиху неділю, віддавав стандартну стартову сторінку Welcome to nginx! — і поруч з нею публічно досяжний ендпойнт статусу, чий HTML-title читався [Redacted] Panel v1.03. Цей title збігався з рядком X-Panel-Build з JARM-кластера і збігався з приватною фішинг-панеллю, рекламованою на відомому кримінальному форумі раніше того року.

Складай чесно. Перше, витік pDNS-origin у тому самому рідкісному /24 для обох хвиль — помірний сам по собі, бо спільний маленький VPS незвичний, але не остаточний. Друге, JARM, поділений лише з 47 хостами, особливо з відповідним заголовком X-Panel-Build, — помірний-до-сильного. Третє, геш фавікону, поділений між двома фішинговими сторінками й двома хостами JARM-кластера, — незалежний, сильний. Четверте, сторінка статусу, чий title розкрив точну версію панелі й збігся з названим приватним фішинг-набором, — незалежний, майже діагностичний сам по собі. Чотири незалежні сигнали, чотири різні методи збору, всі згоджуються. Я звітував сильний на рівні операторського кластера: той самий оператор за обома хвилями, запускає той самий приватний набір, на інфраструктурі, яку йому ненадовго не вдалося приховати — двічі.

Клієнт закинув це у свій внутрішній fraud-граф. Я записав застереження, яке завжди включаю: відбиткові кластери на мережевому шарі ідентифікують *інструменти й інфраструктуру*, а не людину. Двоє колег, що ділять набір і хостингову звичку, виглядають на JARM-шарі так само, як одна людина сама. Розділ дев'ятий закриває цей розрив.

Другий кейс: той, що не закривається

Інший кейс, той самий тиждень. Добре відпрацьований противник, малообсягова колекторська операція. Фронтовано великим CDN і лишається фронтованим; жодних вікон витоку origin у pDNS за рік історії. TLS термінується на CDN, тож JARM, який я бачив, був CDN-івським, поділеним із мільйонами хостів. Фавікон — простий стандартний. Заголовки generic. Стартові сторінки не несли жодних користувацьких title.

Кожен відбиток був або відсутнім, або надто поширеним, щоб щось довести. Зворотний pDNS на історичних IP повертав щільні кластери неспоріднених орендарів на спільних хостах. Цей оператор зробив усе правильно на мережевому шарі, і кластеризувати не було чого.

Чесний звіт, один абзац: *атрибуція з сигналів мережевого шару окремо неможлива. Їхній opsec на інфраструктурному шарі компетентний; нічого в pDNS чи скан-індексах не підіймається над рівнем шуму. Інший шар — поведінка контенту, людське tradecraft, часові патерни на публікованому матеріалі — це наступне місце, де дивитися.* Не кожен метод виплачує. Сказати це чесно — частина методу.

Про купівлю даних, які тобі не треба було купувати

Комерційні rDNS та скан-індексні сервіси легально купувати, і для серйозної інфраструктурної роботи ти зрештою купиш принаймні один. Розумій, звідки прийшли дані, перш ніж пропускати роботу через них.

Пасивний DNS — це живе питання згоди. Дані агрегуються з потоків логів публічних резолверів — Google Public DNS, 1.1.1.1 Cloudflare, університетських та корпоративних резолверів і довгого хвоста менших колекторів. Деякі з цих резолверів публікують прозору opt-in політику приватності, яка каже «твої запити можуть ділитися з дослідниками безпеки». Багато — ні. Коли ти запитуєш rDNS-індекс про «кожен хост, у який example.com коли-небудь резолвився», ти читаєш базу даних, побудовану частково з DNS-запитів звичайних користувачів — запитів, про які вони не знали, що їх зберігають, продають і роблять шуканими роками потому. Це незручний ґрунт. Його не робить зручним той факт, що ім'я домену в запиті публічне; *сам факт запиту*, прив'язаний до резолвера і мітки часу, — це поведінкові дані про когось. Купівля не відмиває цього.

Дані скан-індексів — менш обтяжливі. Видимий інтернет сканується за правом бути видимим — ти читаєш те, чим сервер самої цілі вирішив відповісти, — але ліцензійні умови

все ж різняться, і деякі скан-індекси перерозповсюджують похідні відбитки хостів, що оператор не очікував бути закаталогізованим.

Якщо ти працюєш у регульованому середовищі — корпоративний due diligence з ЄС, журналістика з юристом, safeguarding, будь-яке змагальне провадження — прочитай заяву постачальника про джерела даних повністю, спитай конкретно про згоду й правову підставу на боці rDNS (не на боці скан-індексу; це різні питання), отримай відповідь у письмовому вигляді й тримай її в матеріалах справи поруч із запитами, які ти запускав. Спитай юриста своєї організації, де межа для твоєї юрисдикції, *перш ніж* пропускати клієнтський договір через платний rDNS API, — не після. Сервіс легально купувати; чи є використання захисним у твоїй юрисдикції, і чи є джерело захисним у суді, — це вже на тобі.

Безпечна вправа

Візьми домен, яким ти особисто володієш, — хобі-сайт, запасний проєкт, старий блог. Витягни безкоштовну рDNS-історію для нього. Прочитай слід кожної IP, у яку він коли-небудь резолвився, кожного сервера імен, який він використовував, кожної міграції між хостами, про які ти забув. Якщо домен достатньо старий, слід довший, ніж ти пам'ятаєш. Більшість людей вражені, скільки їхньої власної хостингової біографії видно кожному, хто здогадається подивитися.

Підсумок

- Інтернет тримає дві пам'яті: пасивний DNS, часову історію DNS-резолуцій, залоговану публічними резолверами, і скан-індекси, корпус відбитків видимого інтернету з регулярних сканів.
- рDNS дає історичні резолуції, зворотну історію на IP, вікна міграції, виявлення кластерів на рідкісних IP і хостнейми-привиди, які резолвилися раз і ніколи не поновлювалися.
- рDNS мовчить щодо приватно-рекурсивних налаштувань та DoH/DoT-стеків, які ніколи не торкалися логуючого резолвера; комерційне покриття глибше за безкоштовне.

- Відбитки, якими ти справді користуватимешся, — це геш фавікону, JARM (і JA4S, де індекс його підтримує), HTTP-заголовок Server, HTML-title або геш meta і рідкісні набори X-заголовків. JA3 — старіший клієнтський родич, здебільшого для захисників.
- Кластери відбитків спокусливі; поширений JARM не доводить нічого, а рідкісний JARM — це підпис. Сигнал — це рідкість, а не збіг.
- Читай ліцензування й походження будь-яких рDNS-даних чи скан-даних, які ти купуєш, — правова підстава джерела на тобі, а не на вендорі.
- Атрибуція на мережевому шарі ідентифікує кластери операторських інструментів, а не людей; деякі цілі роблять цей шар правильно й не дають тобі нічого.

Розділ дев'ятий — це капстон: один кейс, який стягує кожен шар цієї книги разом, від кільця навколо крапки через роботу з людьми, домени, сертифікати, контент, стек сигналів і все з цього розділу, у єдиний шлях від початкового імені до захищеної знахідки.



РОЗДІЛ ДЕВ'ЯТИЙ

Повна тверда ціль

Один кейс, усі техніки, чесні межі.

Усе в цьому томі було по одному інструменту за раз. Кеш. Видалений акаунт. Фотографія. DNS-запис. Техніки при чистому світлі, одна за одною — так, як книжка й мусить учити.

Справжня робота з твердою ціллю приходить не в такому порядку. Вона приходить одним клубком: шість доменів і псевдонім, і редакція, яка питає, чи безпечно називати людину. Техніки виходять із сумки в міру того, як цього просить справа, а не за списком розділів.

Цей розділ — один кейс, пройдений від початку до кінця. Я збираюся використати кожен шар із Розділів

Першого–Восьмого, не зупиняючись, щоб перевчати жоден з них — якщо тобі треба перевірити, що таке СТ-логи чи пасивний DNS насправді, попередні розділи нікуди не поділися. Тут ти побачиш *форму* розслідування твердої цілі, з тупиками включно, і те, як воно чесно заробляє собі місце на драбині.

Я покажу тобі, що не спрацювало, з такою ж ретельністю, як те, що спрацювало. Чиста версія цього кейсу вмістилася б на серветці. Чесна версія — це причина, чому в нас є цілий розділ.

Бриф

Балтійська слідча редакція кружляє навколо однієї історії вже чотири місяці. Напередодні місцевих виборчих циклів 2024 і 2025 років у Латвії та Естонії мережа маленьких, правдоподібно названих сайтів «локальних новин» — сільські вісники, районні щоденники, один, що публікує лише протоколи шкільних рад — надійно піднімає певний набір наративів у певному темпі. Кожен сайт виглядає як незалежний. У кожного в підвалі — поштова скринька. Кожен написаний тим, що читається як компетентна місцева говірка. Мережу публічно приписують, у кількох раніших блокнотах репортерів, єдиному оператору, відомому лише під псевдонімом «Torrey».

Редакторка обережна. Вона не запустить матеріал, який називає Torrey, доки атрибуція не досягне щонайменше сильного щабля — три незалежні, нескладувані сигнали, без вимоги до самопосилання — і хоче, щоб тупики були перелічені поряд із висновками, тим самим шрифтом, аби її юрист міг прочитати весь текст.

Наш бриф, від неї, в одному листі: *Torrey — це одна людина, одна команда чи міраж, а якщо людина, то хто?* Письмовий звіт про атрибуцію в кінці, чесно ранжований, з усім, що ми не робили, теж записаним.

Оце й уся просьба. Ми не маємо інтерв'ювати, контактувати чи провокувати ціль. Ми не маємо ні в що логінитися ні під ким. Ми тут, щоб уважно читати відкритий веб і сказати одну тверду правдиву річ у кінці.

Скоуп, одним рядком

Тільки відкриті джерела. Жодного контакту з ціллю, жодного контакту з будь-ким поруч із ціллю, жодного зондування будь-якого хоста поза читанням записів, які інтернет уже відкриває кожному, хто питає. Кожен екран, у який ми дивимося, ми архівуємо; кожне твердження, яке ми робимо, приземляється на драбині разом із доказом поруч.

Якір

Редакція дає нам шість доменів. Це публічні точки входу мережі — сайти, з якими Torrey публічно асоціювали в ранішніх блокнотах, жоден з них не оскаржується. Ось звідки ми починаємо і, наскільки це стосується скоупу, звідки нам дозволено починати.

- kalnina-vesti.lv — село Kalniņa, «локальні новини»
- riga-vidzemes-nedela.lv — щотижневик внутрішнього передмістя Риги
- daugavgriva-hronika.lv — хроніка портового району
- tallinn-mustamae-teataja.ee — репортер району Mustamäe
- tartu-annelinn-uudised.ee — новини кварталу Annelinn
- parnu-raekula-teataja.ee — щотижневик району Pärnu. (В display-формі — естонські ä/ü; у кожному DNS- або СТ-запиті домен резолвиться як xn--prnu-raekla-teataja-gwb62c.ee — форма ACE/punycode. У книзі задля читаності використано display-форму; реальний запит іде в ACE-формі.)

Дві категорії: чотири латвійські, два естонські. Усі шість зареєстровано між 2019 і 2022 роками, згідно з поверхневою відповіддю WHOIS, яку може витягти будь-хто. Кожен публікує з буденною каденцією. У кожного шапка, яка не називає редактора. Кожен каже, у своєму власному підвалі,

що він незалежний, підтримується громадою і позапартійний.

Ми записуємо шість імен у нотатці кейсу з трьома колонками — *твердження, доказ, щабель* — і нічого не потрапляє до звіту, доки не заробить собі щабель.

Шар 1 — Поверхня нічого не каже

Перший прохід — це прохід, який компетентний читач зробив би за вечір. І перший прохід каже майже нічого.

Живий WHOIS на всіх шести повертає ту саму форму: реєстрант заредаговано, адмін заредаговано, тех заредаговано, попереду проксі приватного сервісу. Два записи .lv йдуть через один латвійський проксі приватності; інші два — через інший. Два записи .ee — через естонський сервіс. Різні проксі, жодного спільного рядка реєстранта, жодної спільної адреси.

```
whois - kalnina-vesti.lv (live)
-----
registrant: [privacy-proxy]
admin:      [privacy-proxy]
tech:       [privacy-proxy]
created:    2020-04-14
updated:    2023-11-02
name-server: ns1.cloudflare.com
name-server: ns2.cloudflare.com
-----
```

живий публічний WHOIS, редаговано в джерелі

Контент обережний. Він не очевидно партійний і не очевидно скоординований. Два місяці головних сторінок читаються як журналістика маленького містечка — ремонт доріг, шкільні свята, м'який редакційний матеріал про муніципальну прозорість. Наративи, за які хвилюється редакція, там є, але посіяні легенько, в абзаці за три статті нижче, раз на пару тижнів.

Кожен підвал містить ту саму форму контакту: поштова скринька, hello@ на власному домені сайту, тенант Google Workspace позаду поштового обміну. Поштові скриньки — різні адреси в різних містах. Нічого не римується.

Кожен сайт сидить за Cloudflare. Кожен сертифікат — Let's Encrypt, дев'яностоденна ротація, wildcard там, де є. Жодні два не ділять IP спереду. Жодні два не ділять поштовий сервер. DNS виглядає, побіжно, ніби шість непов'язаних людей зробили шість непов'язаних сайтів.

Такий настрої. Ціль читала книжку, схожу на цю. Ніщо на поверхні ні в чому не зізнається. А отже, поверхня — не те місце, на якому варто провести день.

Шар 2 — Інфраструктурні відбитки

Розділи Сьомий і Восьмий — це те, як ти лізеш *за* поверхню, яку відполірували. Ми починаємо тягти.

Перше, що варто перевірити, — це сама *сторінка*. Cloudflare спереду не може приховати того, що *рендерить* origin — фавікони, аналітичні теги, маркери фреймворків, форму HTML. Ми фетчимо шість головних сторінок і гешуємо кожен фавікон.

```
favicon hash – all six network domains
-----
kalnina-vesti.lv           -1246753918
riga-vidzemes-nedela.lv   -1246753918
daugavgriva-hronika.lv    -1246753918
tallinn-mustamae-tea.ee   -1246753918
tartu-annelinn-uud.ee     -1246753918
parnu-raekula-tea.ee      -1246753918
-----
```

tmh3 від favicon.ico, побайтово ідентичні

Шість незалежних локальних сайтів не відвантажують випадково один і той самий фавікон побайтово. Це один сигнал. Його не досить — шаблонна крамниця могла роздати той самий ассет шістьом клієнтам — але це твердий старт.

Ми дивимось код. Усі шість несуть той самий вимірковальний ідентифікатор GA4: **G-9K2D4X7QH1**. Ідентифікатори GA4 прив'язані до тенанта; вони належать одній властивості Google Analytics, керованій одним акаунтом Google. Шість «незалежних» сайтів, які звітують до однієї аналітичної панелі, — це другий сигнал, і цей уже важче відмахнути. Шаблонна крамниця ділиться CSS. Вона

не ділиться аналітичним тенантом клієнта.

Один із шести — `kalnina-vesti.lv` — містить файл `humans.txt` у корені, який, схоже, залишили випадково. Файл порожній, окрім єдиного рядка коментаря: `# built by МО, 2020`. Два ініціали. Ми їх занотовуємо і рухаємось далі — самі по собі ініціали ще нічого не заробляють, але вони скоро стануть у пригоді.

Тепер ідемо за Cloudflare. Пасивний DNS на шести доменах показує очікувану історію А-записів Cloudflare для більшості тижнів. Але на єдиних вихідних у листопаді 2023 року два з шести — `daugavgriva-hronika.lv` і `pärnu-raeküla-teataja.ee` — коротко резолвили на не-Cloudflare адресу, маленького європейського VPS-провайдера, автономну систему з діапазону AS200000, перш ніж у понеділок повернутися назад. Хтось ротував сертифікат чи перезапускав проксі, і на сорок вісім годин origin залишився оголеним.

Ми тягнемо записи `scan-index` на цю origin-IP за ті вихідні. Обидва домени обслуговувалися з того самого хоста, на тому самому порту, з тим самим TLS-стеком. Відбиток JARM збігається побайтово.


```
scan-index — weekend of 2023-11-04
-----
host    [origin IP redacted]
443/tcp
  jarm   2ad2ad0002ad2ad00042d42d0000..
  cert   CN=daugavgriva-hronika.lv
  cert   CN=xn--prnu-raekla-teataja-gwb62c.ee
  server nginx/1.24.0
-----
```

сторонній інтернет-скан-індекс, історичний

Два з шести мережевих сайтів фізично колокуються на одному маленькому VPS. У поєднанні з фавіконом і тенантом GA4 у нас є три справді незалежні сигнали, що вказують на єдиного оператора за мережею. Атрибуція *кластера оператора* тепер сидить на сильному. Torrey — не міраж. Torrey — це одна рука. Чия саме, ми поки не знаємо.

Шар 3 — Видалена кімната

Наступне підняття походить із чогось, що Torrey зробив за роки до того, як Torrey існував.

Ідентифікатор GA4, який ми зняли, — G-9K2D4X7QH1 — це твердий ідентифікатор. Ми шукаємо його в публічному коді та корпусах сторінок, і він з'являється на сьомому сайті: baltika-kaleidoscope.eu. Гастрономічно-трєвел-блог. Нічого відверто політичного. Інша тема, інший візуальний шаблон, інша мова підвалу.

Поточна версія блогу не має підпису автора. Але машина Wayback (Розділ Перший) захопила сторінку About

одинадцять разів між 2019 і 2024 роками. Шість із цих захоплень — усе до червня 2022-го — містять підпис: Mikelis Ozoliņš, мешканець Jūrmala, контакт mik.ozolins@yandex.ru. Захоплення червня 2022-го — перше, де підпис та e-mail стерто.

web.archive.org — /about (2021-08-12)

"About the author"

"Mikelis Ozoliņš — Jūrmala-based writer
on food, travel and coastal culture.

Reach me: mik.ozolins@yandex.ru"

архівована сторінка, захоплено 2021-08-12

Хтось стер підпис у середині 2022-го — а це приблизно тоді, коли мережа Torrey почала публікуватися в каденції, і приблизно тоді, коли компетентний оператор витягав би старі ідентичнісні артефакти з поверхневого вебу.

З кешем самим по собі можна сперечатися — захоплення Wayback є одним джерелом. Тож ми шукаємо цитати з екосистеми (знову Розділ Перший). Маленький латвійський агрегатор локальних новин у оглядовому матеріалі 2020 року про ресторани Курземського регіону цитує повний абзац із поста на baltika-kaleidoscope.eu, з атрибуцією: «*як пише Mikelis Ozoliņš у своєму літньому щоденнику, [цитований абзац]*». Підпис і місто. Незалежний сайт. Не дзеркало.

Це вже територія Розділу Другого — реконструкція видаленої ідентичності з кільця навколо неї. Прохід FOAF по сторінці About до 2022 року дає ще два підтвердження: пост «друга блогу» від естонської кулінарної письменниці 2021-го, яка звертається до «Mikelis» на ім'я і дякує за рекомендацію ресторану в Юрмалі, і гілка коментарів на конкурентному латвійському блозі, де «Mikelis O.» з'являється в підписі під коментарем, надісланим із того самого yandex.ru e-mail, що видно на сторінці About.

Отже, людина існує: Mikelis Ozoliņš, Jūrmala, кулінарний блогер, активний 2019–2022, потім стертий. І тенант GA4 цієї людини, все ще живий і непереіменований, тепер вимірює мережу Torrey. Це не доказ — це дуже сильний потяг. Спільний аналітичний тенант через стертий особистий блог і мережу анонімних політичних сайтів — це дводжерельний голос за єдиного оператора за обома.

Шар 4 — Фотографія

Тепер ми йдемо туди, де живуть Розділи Третій і Четвертий.

Один із постів Mikelis 2021 року на baltika-kaleidoscope.eu — захоплений чисто в трьох снапшотах Wayback — несе фотографію без підпису та без видимих EXIF. Композиція дивна: смужка тротуару, верх низької білої будівлі в кутку кадру, шматок блілого зимового неба та один пластиковий шезлонг на явно готельному балконі. Знімок читається як

пост «я десь тут», а не як гастрономічне фото — саме тому його варто хронолокувати: він *дає* модель пересування Mikelis.

Спершу геолокація. Видно в кадрі:

- Фрагмент вивіски через дорогу, кирилицею, видно лише три літери: ...рор...
- Ще одна вивіска, далі, латинкою в стилі готельного бренду, частково: ...ISON
- Специфічний зварювальний малюнок поруччя балкона — вузькі вертикалі кожні ~90 мм, атипічний крок для європейських готельних забудов
- Кут сонця і тінь балкона зверху ставлять фасад будівлі приблизно на південний-південний схід

Кирилиця на вуличній вивісці плюс фрагмент бренду Radisson плюс архітектура балкона — це достатньо мала перетинка, щоб перевірити проти короткого списку.

Готельні бренди латинкою з властивостями в кириличних країнах: Білорусь, Росія, частина Центральної Азії. Зимове світло, пальмо-суміжні насадження, видимі вздовж тротуару, і специфічний крок звареного балкона звужують далі. Street view уздовж Курортного проспекту в Сочі показує готель із саме таким малюнком балкона й лінією видимості вивісок, яка розв'язує фрагмент ...рор... до вуличного знаку Курортный через дорогу.

Ми не заявляємо більше, ніж бачимо. Геолокація така: майже напевно конкретний готель на Курортному проспекті в Сочі. Впевненість: сильна, із залишком, що інший готель бренду Radisson деінде на Чорноморському узбережжі міг би нести схожу балконну специфікацію. Названий залишок, не відкинутий.

Тепер дата. Дисципліна Розділу Четвертого. Кут сонця на цьому південно-південно-східному фасаді, з огляду на широту Сочі, стискається до ранку пізньої зими — приблизно з кінця січня до кінця лютого. На даху навпроти видно тонкий шар паморозі, який виживає в тіні, що в Сочі ставить нас у холоднішу половину цього вікна. А на автобусній зупинці через дорогу, на краю кадру, фрагмент концертної афіші читається достатньо, щоб прочитати «Зимний джаз» та двоцифровий день. Цей фестиваль, за публічними подієвими архівами, проходив у певні дати лютого 2021 року.

Отже: Mikelis, у лютому 2021-го, був у Сочі. Це саме по собі не є атрибуційним висновком. Це *патерновий* факт — юрмальський кулінарний блогер їздив на російський чорноморський курорт у міжсезонний місяць — і редакція скористається ним пізніше. Для нашого розділу це хронолокований якір: у видаленої ідентичності була фізична, датована присутність.

Шар 5 — Історичний WHOIS

Тепер Розділ П'ятий і голос, який зв'язує обидві сторони кейсу.

Живий WHOIS на baltika-kaleidoscope.eu заредаговано. Історичний WHOIS на тому самому домені, з до-GDPR архіву, датованого 2017 роком, повертає чистий e-mail реєстранта: ozolins.m@inbox.lv. Інший e-mail, ніж mik.ozolins@yandex.ru, видимий на сторінці About, — але та сама людина, у латвійського мейл-провайдера, у правдоподібній формі «прізвище-перше».

Цей єдиний запис не робить роботу сам. Роботу робить те, що виринає, коли ми тягнемо історичний WHOIS на домени *мережі Torrey* — конкретно на два, що коротко злили свій origin у Шарі 2, daugavgriva-hronika.lv і raepnu-raekula-teataja.ee. Обидва спочатку зареєстровано в 2017 році, за три роки до того, як вони понесли бодай одну статтю, під тим самим ozolins.m@inbox.lv. Обидва записи повторно закрито за проксі приватності у 2018-му, коли реєстри .lv та .ee почали виконувати запити на GDPR-подібну редакцію.


```
historical whois (pre-GDPR archive)
-----
domain    daugavgriva-hronika.lv
created   2017-05-22
registrant-email  ozolins.m@inbox.lv
registrant-name   M. Ozolins
registrant-city   Jurmala
-----
```

архівований знімок реєстру, 2017

Та сама форма запису з'являється для `pārnu-raekūla-teataja.ee`, датованого трьома місяцями пізніше. Два з шести доменів мережі Torrey у їхній до-редакційній формі зареєстровано під особистим e-mail Mikelis Ozoliņš, з юрмальської адреси, за три роки до того, як мережа почала публікуватися.

Це не один голос. Це два незалежні реєстраційні записи в різних національних реєстрах, які збігаються один з одним і з до-редакційним записом самого гастрономічного блогу. Потяг дуже жорсткий. Це саме по собі не доводить, що Mikelis керує мережею *зараз* — домен може тихо перейти з рук у руки, і WHOIS 2017 року не є заявою про 2024-й. Але в поєднанні зі збігом тенанта GA4 і відбитком кластера оператора це є вагомим третім канатом.

Шар 6 — СТ і забутий staging

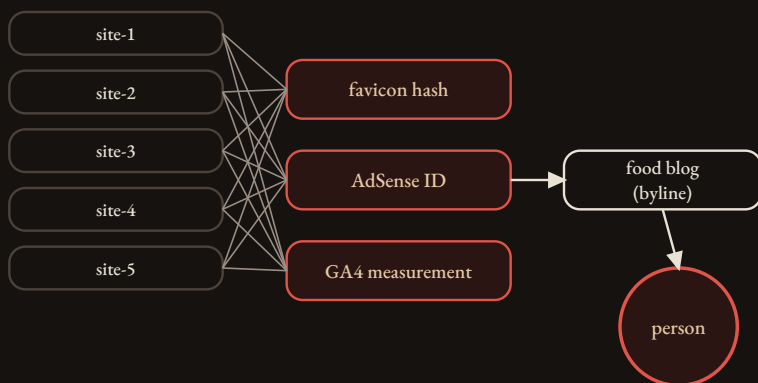
Розділ Шостий. Прозорість сертифікатів (СТ) пам'ятає те, що оператор забув приховати.

Ми тягнемо СТ для шести живих доменів Torrey. Нічого екзотичного — Let's Encrypt сертифікати на apex і www, дев'яностоденна ротація, жодних wildcard, які зливали б піддомени. Чисто.

Ми тягнемо СТ для baltika-kaleidoscope.eu. І ось де починають говорити *звички* оператора. У серпні 2020-го СТ реєструє видачу пресертифіката для dev.baltika-kaleidoscope.eu — піддомен розробки, який, імовірно, давно вже прибрано. Патерн стандартний: префікс dev.. Що цікавіше, це *суфіксний* патерн на другому пресертифікаті двома тижнями пізніше: dev-uat.baltika-kaleidoscope.eu. Суфікс -uat — це особиста конвенція. Не помилка, не рідкість в абстракті, але звичка *конкретної* людини.

Ми перевіряємо історію СТ мережових доменів на той самий відбиток. І на одному з них — tartu-annelinn-uudised.ee — запис СТ від січня 2022-го показує пресертифікат для dev-uat.tartu-annelinn-uudised.ee. Той самий префікс. Той самий суфікс. Та сама конвенція, на сайті, поверхневий WHOIS якого нікого не називає.

INFRA → PERSON



operator fingerprints link the anonymous → the named

Пість доменів мережі Torrey угорі, baltika-kaleidoscope.eu збоку праворуч, і чотири незалежні мости між ними: спільний тенант GA4 через усі сім; два origin Torrey, колокованих на одному VPS за JARM; два домени Torrey, які ділять до-2018 e-mail реєстранта з гастрономічним блогом; та звичка іменування dev-uat., повторена між гастрономічним блогом і одним мережесвим сайтом.

Відбиток оператор-звички сам по собі м'який. Він стає твердим, коли сидить усередині кейсу, де три інші мости вже несуть вагу. Він нічого не рухає сам; він рухає щабель драбини на один обережний виїмок, коли все інше вже на місці.

Шар 7 — Крос-платформне закриття

Нам не потрібен Том 2, щоб зробити атрибуцію. У нас достатньо. Але редакція хоче знати, що чоловік за e-mail — це чоловік у позначеній фотографії — *обличчя на імені*.

ozolins.m@inbox.lv — це півот у стилі Тому 2. Реверс цього e-mail через публічний веб, з використанням того самого крос-платформного інструментарію, яким користується будь-хто в цьому ремеслі, повертає три збіги, які переживають верифікацію:

- Сплячий акаунт Twitter/X, востаннє активний у 2019 році, з біо, що посилається на baltika-kaleidoscope.eu, і відображуваним іменем «M. Ozoliņš».
- Сторінка профілю на латвійському сайті бізнес-довідника — самопублікація для послуг фрилансера-копірайтера, контакт ozolins.m@inbox.lv, місто Jurmala, ім'я Mikelis.
- Особистий блог десятирічної давнини на латвійській блог-платформі, активний 2010–2013, з кількома автопортретними фотографіями.

Автопортретний блог — це те, що пускає обличчя на драбину — обережно. На публічній сторінці Facebook, що належить юрмальській торгово-промисловій палаті, фотографія 2018 року з невеликої бізнес-події підписана трьома іменами, одне з яких — «Mikelis Ozoliņš».

Найсильніший зв'язок між тією фотографією та особистим e-mail — це біо в Twitter/X: сплячий акаунт, чие біо явно посилається на baltika-kaleidoscope.eu і чие відображуване ім'я збігається з «М. Ozoliņš». Це першостороннє твердження акаунта під власним контролем Mikelis, яке пов'язує його ім'я з гастрономічним блогом. Це та нога, на якій стоїть візуальна атрибуція.

Видима фізична позначка з лівого боку шиї — маленька родимка (пігментний невус), видима на трьох автопортретах 2011 року в особистому блозі та на фотографії торгової палати 2018 року — є допоміжним підтвердженням, а не незалежною ногою. Родимка — не діагностична біометрика; під перехресним допитом компетентний опозиційний експерт розкатає її за десять хвилин. Вона важить лише як перевірка узгодженості поверх самопосилання з біо Twitter та патерну «спільне ім'я і місто». Ми називаємо це своїм іменем у звіті.

Індивідуальна атрибуція тепер стоїть на трьох справді незалежних ногах:

- До-2018 історичний WHOIS на двох доменах мережі Torrey під особистим e-mail Mikelis, що збігається із власним до-редакційним записом гастрономічного блогу.
- Спільний тенант GA4 між мережею Torrey і гастрономічним блогом, з відбитком оператор-звички СТ, який переноситься між ними.

- Публічне самопосилання акаунта Twitter/X між «М. Ozoliņš» і baltika-kaleidoscope.eu, підкріплене (а не несене) фотографією юрмальської торгової палати та перевіркою узгодженості за родимкою.

Щабель індивідуальної атрибуції: сильний. Не підтверджено — Mikelis ніколи публічно не заявляв про керування *самою мережею Torrey*, і редакції знадобилося б або самопосилання, яке називає властивості Torrey, або першосторонній документ, щоб посунути цей останній щабель.

Тупики, які зазвичай не показують

Шість ниток, які нікуди не привели, перелічені поіменно, щоб звіт був чесним:

- Реверс зображення на фотографії з готельного вікна. Повернув нуль візуально схожих зображень у кожному інструменті реверс-пошуку, який я пробував. Фотографія була занадто ідіосинкратичною, щоб її десь перепостили, і занадто простою, щоб бути стоковим кропом. Геолокацію довелося робити руками з фрагментів вивісок та архітектури балкона, а не за збігом.
- Чотири з шести origin Torrey ніколи не злилися. Лише два з шести доменів коротко ротувалися з Cloudflare у листопаді 2023-го. Решта чотирьох залишалися непрозорими весь час. Ми можемо вказати на кластер, але не можемо побачити машину, на якій живуть чотири з

шести насправді.

- **Адреси поштових скриньок.** Усі шість поштових скриньок у підвалі при ближчому огляді резолвлять до єдиного спільного сервісу пересилання пошти, що позиціонує себе для малого бізнесу. Ним користуються сотні клієнтів. Адреси — не доказ чогось про оператора; вони доказ того, що оператор найняв компанію з пересилання пошти.
- **Звіти DMARC на baltika-kaleidoscope.eu.** Публічний DNS показує запис DMARC із вказівником `rua=mailto:`, але призначення — це поштова скринька з приватним переадресуванням на сервісі, що спеціалізується на агрегації DMARC. Слід вмирає на переадресаторі. Жодного реєстранта, жодних метаданих, видимих зовні.
- **Ширина кластера JARM.** Відбиток JARM, який ми зняли на `origin VPS` у Шарі 2, на момент скану має приблизно 6400 хостів, що збігаються, у корпусі інтернет-широкого сканування. Це широкий кластер. Він став корисним лише після фільтрації за автономною системою та країною хостингу — той самий JARM у тій самій AS у тій самій маленькій європейській юрисдикції звузив короткий список до двох хостів. Без цього фільтра сам відбиток нічого б не сказав.
- **Ризик тезка з торгової палати.** «Mikelis Ozoliņš» — не найрідкісніше ім'я в Латвії. Фотографія торгової палати 2018 року могла легко бути іншим Mikelis Ozoliņš — те

саме ім'я, те саме місто, непов'язане життя. Що закрило залишок на *індивідуальній* атрибуції, — це власне біо акаунта Twitter/X, що посиляється на *baltika-kaleidoscope.eu* — першостороннє самопосилання — з родимкою як допоміжною візуальною перевіркою узгодженості. За відсутності самопосилання в Twitter візуальна частина залишилась би *помірною*, і кейс поїхав би на щабель нижче; родимка сама — це підкріплення, а не атрибуція.

Тупики — це інвентар. Кейс без них був прикрашений, а не розслідуваний.

Що звіт насправді каже

Письмовий звіт про атрибуцію, на одну сторінку, доставлений редакторці та її юристу:

*«Найсильніші незалежні докази вказують на Мікеліса Озолінша, мешканця Юрмалі (Латвія), як на оператора мережі Torrey — шести сайтів "локальних новин" у Латвії та Естонії. Щабель атрибуції: сильний. Поточний контроль Мікеліса не підтверджено. Записи WHOIS 2017 року встановлюють його як реєстранта двох мережесив доменів станом на 2017 рік; живі реєстрації заредаговано, а домен може тихо перейти з рук у руки. Його авторство пов'язаного гастрономічного блогу *baltika-kaleidoscope.eu* — це першостороннє самопосилання (біо Twitter/X); його реєстрація доменів Torrey — це історичний запис, а не*

теперішньо-часова заява про контроль.

Незалежні сигнали: (i) до-2018 історичний WHOIS на двох із шести доменів Torrey під ozolins.m@inbox.lv, який також є до-2018 реєстрантом baltika-kaleidoscope.eu і з'являється у незалежних публічних довідниках під повним іменем Мікеліса; (ii) спільний вимірювальний ідентифікатор GA4 G-9K2D4X7QH1 через усі шість сайтів мережі Torrey та гастрономічний блог — виміряно як один акаунт Google, все ще живий і непереіменований з моменту запуску блогу в 2019 році, а не просто перевикористаний сніпет; (iii) спільний геш фавікону -1246753918 (знакова 32-бітна конвенція Shodan) і збіг відбитка JARM на origin через два origin Torrey, що коротко злилися з Cloudflare у листопаді 2023-го, обидва колоковані на одному VPS; (iv) відбиток оператор-звички CT — конвенція іменування піддоменів dev-uat. — спільна між гастрономічним блогом і одним мережевим сайтом.

Чого ми не підтвердили: (a) що Мікеліс зберігає теперішньо-часовий операційний контроль над мережею — жодної першосторонньої заяви, жодного самопосилання, що називає властивості Torrey, і жодного документа на цей рахунок не було спостережено; (b) що мережа Torrey — це сольна операція, а не маленька команда, що використовує акаунт Google та хостингові звички Мікеліса. Щоб посунути висновок із сильного до підтвердженого, знадобилося

б публічне самопосилання, першосторонній документ, який називає Мікеліса поточним оператором, або позитивне підтвердження на запис від самого Мікеліса — жодного з яких ми не шукали. Щоб послабити висновок до помірного, знадобилися б правдоподібні свідчення передачі домену між 2017 роком і сьогоднішнім для двох зареєстрованих доменів Torrey, або свідчення того, що спільний тенант GA4 адмініструє хтось інший, а не Мікеліс».

Лінія, яку ми не перетнули

Ми не зондували жодного хоста. Кожен фетч був читанням публічної сторінки чи публічного запису. Ми не намагалися дістатися адмін-панелі, сторінки логіну чи будь-якого не-посилального ендпоінту на жодному з семи доменів.

Ми не логінилися в жодну платформу під ніким, окрім читача, який дивиться на відкритий контент. Ми не створювали акаунтів, щоб побачити приватні профілі, і не приєднувалися до жодної закритої групи.

Ми не контактували з Мікелісом. Ми не контактували з жодним другом, колегою чи членом сім'ї Мікеліса. Ми не використовували його співучасників торгової палати 2018 року як спосіб тріангулювати його поточне місцезнаходження.

Ми не публікували і не включали до звіту приватну домашню адресу, попри те що геолокація окремої фотографії 2019

року з блогу звузила б її до однієї юрмальської вулиці.
Адреса не була проханням; ідентичність була.

Професіонал — це той, хто знає, коли зупинитися.

Підсумок

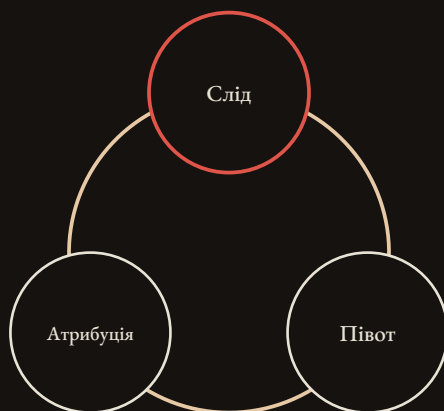
- Використовуй кожен шар, який потребує кейс, і не більше; техніки — для питань, а не для показу.
- Незалежні сигнали мають бути *насправді* незалежними — три факти, що приходять через один акаунт, — це одне джерело, а не три голоси.
- Історичні записи (WHOIS до 2018-го, захоплення Wayback, СТ-логи, історія pDNS) — це те, що дозволяє тобі побачити, що оператор стер.
- Cloudflare ховає origin лише доти, доки origin ні разу не забуде ховатися.
- Відбитки оператор-звички — конвенції піддоменів, аналітичні ідентифікатори, геші фавіконів — самі нічого не рухають і важать багато, коли три інші мости вже несуть вагу.
- Тупики — це інвентар. Перелічуй їх поіменно у звіті; не ховай їх.
- Хронолокація часто є висновком, а не оздобою — патерн *коли* може важити для історії більше, ніж *де*.

- Завершуй кожен кейс письмовим звітом, який може прочитати юрист клієнта, зі твердженнями, доказами, шаблоном і *не-зробленим* в одному документі.
- Щабель має відповідати доказу. Сильний — це не підтверджено, а підтверджено вимагає першосторонньої зв'язки, яку жодна кількість наклеювання замінити не може.

Цикл, востаннє

Навіть у такому масштабі форма роботи залишалася тією ж, якою вона є завжди. Мережа анонімних фронтів відкрила відбиток (фавікон, GA4, JARM). Кожен відбиток півотнув до нової поверхні (стертий блог, злитий origin, ргесертифікат CT). Кожен півот годував драбину атрибуції на один щабель. Нічого не пропущено, нічого не перескочено.

ЦИКЛ



одна зачіпка, кружляй колом, поки не вкаже на людину

Відкритий слід — до півоту — до атрибуції — той самий цикл, що й у першому кейсі Тому 1, на більшому радіусі й проти цілі, яка справді намагалася сховатися.

Гортай сторінку. Том 4 — про перетворення цієї навички на ремесло.

Що ти можеш зараз

— і що буде далі.

Зупинися на секунду і подивися, як далеко ти зайшов.

У Томі 1 ти навчився тягти одну нитку. У Томі 2 ти навчився плести нитки з багатьох платформ в одну впевнену людину.

У Томі 3 ти навчився читати місця, де ніхто не збирався залишати нитку, — видалений акаунт, безпідписну фотографію, лог сертифікатів, невдало сконфігурований origin. Ти вивчив, що «зникло» — це майже завжди «зміщено», і що світ зберігає записи, про які оператор не думав, коли ставив запис.

Дещо змінилося для тебе і в цій книзі. Ти перестав потребувати, щоб ціль співпрацювала. У Томах 1 і 2 більшість роботи полягала в тому, щоб читати те, що людина виклала у відкрите. Тут більшість роботи полягала в читанні того, що людина *намагалася приховати*, — і робити це без дотику до замка, без логіну, без обходу, користуючись нічим, крім уважно прочитаних публічних записів. Це набагато холодніше відчуття. Посидь із ним. Це те відчуття, про яке говорять професіонали, коли кажуть, що робота не завжди буває веселою. Це відчуття, яке відділяє професіонала від ентузіаста.

Тримайся звичок, а не інструментів

Платформи будуть змінюватися. Cloudflare буде змінюватися. Вендори історичного WHOIS будуть зливатися чи вмирати. З'являться нові скан-індекси. Ніщо з цього не має значення. *Форма* роботи не змінюється: назви легітимне питання, заякорися на тому, що маєш, пройди записами, які світ уже й так зробив публічними, чесно порахуй незалежні сигнали, зваж кожную знахідку на драбині і візьми тільки те, що потрібно для питання. Навчись цьому — і кожен новий інструмент буде просто ще одними дверима в той самий метод.

Де тримати заточку

- Працюй сам, у стилі складної цілі. Видали старий блог. Потім спробуй реконструювати його ззовні. Потім закрій кожную дірку, яку знайшов. Найкраща вправа в цьому томі.
- STF і верифікаційні виклики. Хороші тепер включають раунди хроолокації, геолокації і півоту по інфраструктурі. Це найбезпечніший спосіб зробити око швидшим.
- Івенти пошуку зниклих людей (як-от Trace Labs) — значущі, обережні, поряд з людьми, які роблять це роками, всередині жорсткого правила без контакту.

- **Читай захисників.** Інший бік того, чого ти щойно навчився, — це asset-management і робота з attack-surface. Їхні розбори власних витоків читаються як твої кейс-нотатки навпаки — і вони вчать тебе, які витoki мають значення, а які — ні.

Міст до Тому Четвертого

Ця книга була про поховані місця. Том 4 — Професіонал — про те, як перетворити навичку на ремесло, за яке тобі можуть платити і за яке тобі можуть довіряти. Звіти рівня рішень. Ланцюг збереження доказів. Перевірка ангажементів. Контр-OSINT — як ціль захищається саме від того, чого ти щойно навчився. Автоматизація, на яку реально можна покластися. І чесна етика працюючого слідчого, а не хобіста.

Поки що ти вмієш читати місце, яке не хоче бути прочитаним, і чесно знаєш, що ти можеш і чого не можеш про нього сказати. Це багато. Тримай нотатки, тримай дисципліну. Побачимося в Томі 4.

— Єгор

Додаток А — Робочий інструментарій (2026)

Форма інструментів, які досі працюють, і як про них думати.

Цей додаток називає *форми* інструментів, а не рекомендує конкретні сервіси. Будь-який згаданий тут сервіс може зникнути, стати платним або гіршим до того часу, як ти це читатимеш. Важлива форма — розуміння, *до якого класу інструменту* ти тягнешся, підказує, що шукати, коли поточний помре.

Архіви й кеші

- **Загальні веб-архіви.** Wayback Machine (web.archive.org) — робоча конячка: показує повну хронологію знімків, підтримує пошук за шаблоном URL (web.archive.org/web/*/example.com/*). Побратим: archive.today / archive.ph (одноразові знімки, важче цензурувати, корисно, коли Wayback заднім числом заблокований). Національні веб-архіви — UK Web Archive, португальський Arquivo.pt, Library of Congress — часто зберігають локальний контент, який глобальні архіви пропустили.
- **Залишки кешів пошуковиків.** Оператор cache: у Google фактично мертвий станом на 2024. Кеш Bing ще ледве живий. Не будуй метод на жодному з них.

- Спільнотні кільця знімків. Малі архіви, що ведуть дослідники чи активісти, іноді зберігають цілі субкультури (чан-борди, згаслі форуми). Форма: шукай домен плюс «archive» або «mirror» плюс вузьке нішеве слово.

Зворотний пошук зображень і геолокація фото

- Рушії зворотного пошуку зображень. Google Images, Yandex, Bing Visual Search, TinEye. Yandex часто найсильніший для фото-місця. Подавай *цілеспрямовані кропи* (табличка, характерний куточок) — повнокадровий зворотний пошук зазвичай видає шум.
- Рушії пошуку облич. Сервіси форми PimEyes існують, але вони комерційні, юридично чутливі (GDPR, ВІРА) і виходять за межі більшості особистих робіт. Використовуй тільки в межах авторизованої взаємодії з задокументованою законною підставою.
- Калькулятори сонця/тіні. Веб-застосунки форми SunCalc (обчислюють азимут сонця в задану дату й локацію). Надзвичайно корисні для хронолокації.
- Історичні архіви погоди. OpenWeather, Meteostat і державні метеорологічні служби публікують погодинні архіви погоди, які можна запитати для кандидатної дати й локації.
- Історичні супутники. Sentinel Hub, часовий повзунок Google Earth, публічні брифінги Planet. Побачиш, коли

між прольотами з'явився будмайданчик.

- Прогулянки street-view. Google Street View, Yandex Panoramas, Baidu Map, Mapillary, KartaView.

Використовуй той, у кого є покриття регіону — Mapillary заливає спільнота, і часто це єдине джерело в менш покритих зонах.

Домени, DNS і WHOIS

- Живий WHOIS. Вивід whois від реєстратора, плюс who.is, фронтенди форми whoiscologne.io. Читай кожне поле, особливо сервери імен.
- Історичний WHOIS. WhoisXMLAPI, DomainTools, SecurityTrails і подібні. Комерційні й платні; безкоштовні тарифи жорстко лімітують. Це той єдиний важіль, який найімовірніше дасть тобі email реєстранта до 2018 року, — вартий грошей, якщо кейс справжній.
- DNS. dig, nslookup або веб-фронтенди на кшталт mxtoolbox.com. Читай A, AAAA, MX, NS, TXT, CNAME — кожен тип запису говорить щось своє.
- Пасивний DNS. SecurityTrails, RiskIQ / Microsoft Defender Threat Intelligence, VirusTotal (безкоштовний тариф несподівано придатний), Farsight DNSDB (корпоративний, золотий стандарт).

Прозорість сертифікатів

- Інтерфейси пошуку СТ. crt.sh (Sectigo, безкоштовний, робоча конячка), пошук сертифікатів у Censys, СТ-пошук Google. Читай кожен SAN у кожному сертифікаті; звертай увагу на прекертифікати.
- СТ-монітори. Підпишись на домен і отримуй сповіщення про кожен новий сертифікат. Сервіси форми [certstream](https://certstream.digicert.com/) роблять це в реальному часі.

Індекси сканування

- Shodan — класика. Кожен відкритий порт у видимому інтернеті, з можливістю запитів і фільтрами за відбитками.
- Censys — чистіші дані сертифікатів і TLS, сильна підтримка JARM.
- ZoomEye — китайський скан-індекс, часто має покриття, яке західні пропускають.
- BinaryEdge і Onyphe — додаткові скан-корпуси, які варто знати.
- FOFA — китайський, пошук за гешем фавікону — один із найсильніших.

Інфраструктурні відбитки

- Гешування фавікону — MurmurHash3 від сирих байтів фавікону, закодований у base64 (з переносами кожні 76 символів, що навмисне і має значення), — це формат, який приймає більшість скан-індексів. У Python REPL: `import mmh3, base64; mmh3.hash(base64.encodebytes(open('favicon.ico','rb').read()))`. У Shodan сьогодні: `http.favicon.hash:-1246753918` (знаковий 32-бітний int; інші індекси мають інші угоди про знак і різні ключі запитів — несе саме форма).
- JARM — 62-символьний серверний відбиток TLS-стека. Опенсорсний інструмент від Salesforce; скан-індекси показують JARM нативно. Досі робоча конячка для величезного бек-каталогу вже відбитих ним хостів.
- JA4S — наступник світу JARM з 2023-го, серверний і напряму OSINT-релевантний. Надавай перевагу над JARM для свіжо налаштованих стеків, де індекс його підтримує; у решті випадків — JARM. JA4 (клієнтський) і JA3 (старіший клієнтський) існують і використовуються переважно захисниками для ідентифікації сімей шкідливих програм.
- Відбитки HTTP-заголовків — Wappalyzer, BuiltWith, Whatweb. Виявляють фреймворки, CDN, CMS, аналітичні стеки.

Пошук за ID аналітики

- Пошук за Google Analytics ID — SpyOnWeb, DNSlytics, сервіси форми Analyzer. Подаєш UA- або G-ID — отримуєш інші сайти, що його несуть. Також працює для AdSense pub-, ID Facebook Pixel, лічильників Yandex.Metrika.

Кілька слів про вартість

Половина форм вище має безкоштовні вхідні двері, половина — за платним шлагбаумом. Не плати з власної кишені за комерційного вендора заради випадкової цікавості. Якщо кейс справжній — платний клієнт, легітимний журналістський суспільний інтерес, задокументоване питання захисту — вартість це рядок бюджету. Інакше залишайся на безкоштовному тарифі й приймай його межі.

Додаток В — Шаблони

Копіюй, встав, використовуй. Написано для реальних кейсів.

Це робочі каркаси. Заповни, видали те, що не підходить, залиш те, що підходить.

В.1 Обсяг в один рядок

Перед першим півотом напиши це. Якщо не можеш — у тебе цікавість, а не кейс.

```
I am looking into [subject] for [client / editor / self] to answer
[specific legitimate question] on the basis of [lawful basis
: contract,
public interest, safeguarding, own footprint]. In scope: [what].
Out of scope: [what]. Stop conditions: [what would end this]
.
```

scope: one line

В.2 Картка звіту з геолокації

Photo: [URL / hash / where it came from, and when I got it]
Capture-time claim (if any): [what the source said]
Provenance chain: [how I got the file – screenshot? reupload
? original?]

Excludes (naked-eye pass, no tools):

- [element] → excludes [region / hemisphere / country]
- ...

Concentrates (highest-signal elements only):

- [element] → concentrates on [region]
- [element] → concentrates on [region]

Targeted reverse-image / street-view / satellite work:

- [what I looked at, what returned]

Confirmed location: [address or coordinate range]

Independent axes confirming: [1, 2, 3]

Rung: weak / moderate / strong / confirmed

Uncertainty note: [what I could not confirm]

geolocation card

В.3 Картка звіту з хронолокації

Photo / video: [reference]

Fast-clock signals (astronomical):

- Sun direction: [reading]
- Shadow-to-object length ratio: [reading]
- Moon phase (if visible): [reading]

Slow-clock signals (seasonal / weather):

- Foliage: [state]
- Snow / frost / rain traces: [state]
- Weather archive for candidate date at candidate location: [match / conflict]
- Manmade calendar signals: [poster, TV screen, wall calendar]
- Fashion / tech dating cues: [phone, car, streetwear]

Date bracket: [narrowest defensible range]

Rung: weak / moderate / strong / confirmed

Uncertainty note: [what I could not narrow]

chronolocation card

В.4 Таблиця сліду WHOIS і DNS

Кожен рядок — це твердження, яке комусь іншому доведеться перевіряти за рік, після того як живий запис змінився. Спершу зберігай, потім цитуй.

Domain: [name]
Examiner: [your name]
Examined on: [YYYY-MM-DD, timezone]
Tool versions: [whois client X.Y, dig X.Y, passive-DNS provider + query date]

Live WHOIS

- Registrar: [name]
- Created: [YYYY-MM-DD]
- Updated: [YYYY-MM-DD]
- Expiry: [YYYY-MM-DD]
- Status flags: [list]
- Nameservers: [list]
- Registrant: [redacted / name]
- Source classification: primary (registry) / secondary (aggregator) / broker
- Preservation: [Wayback URL | Perma.cc ID | archive.today ID] captured [YYYY-MM-DD HH:MM]
- Downloaded artifact SHA-256: [hash], stored at [case-file path]

Historical WHOIS

- Earliest record: [date] – [registrant email / name if any]
Source: [provider + product], classification: [primary / secondary / broker]
Preservation: [snapshot ID + timestamp], SHA-256: [hash]
- Transition 1: [date] – [what changed]
Source, classification, preservation, hash: [as above]
- Transition 2: [date] – [what changed]
Source, classification, preservation, hash: [as above]

DNS today

- A / AAAA: [IP list] – resolver [name], captured [YYYY-MM-DD HH:MM]
- MX: [mail hosts]
- NS: [nameservers]
- TXT: [records, especially verification tokens]
- CNAME: [aliases]
- Preservation: [dig +short output stored at path], SHA-256: [hash]

Passive DNS

- IP history for [domain]: [chronology]
- Reverse-history for [current IP]: [related hostnames if any]
- Provider: [name], query date: [YYYY-MM-DD], classification : broker
(pDNS is always a broker view; cite the provider, not "the internet")
- Preservation: exported JSON at [path], SHA-256: [hash]

Notable signals: [what stands out]

Not preserved / could not preserve: [what, and why]

whois trail

В.5 Карта інфраструктурного півоту

Target site(s): [list]

Fingerprints observed:

- Favicon hash: [value] → matched on [N] other hosts (source: [scanner + date])
- GA4 / UA / AdSense ID: [value] → matched on [sites] (source, date)
- JARM: [value] → matched on [N] hosts (source, date; note cluster width)
- HTTP Server / X- headers: [notable strings]
- Historical WHOIS emails: [leaked addresses]
- humans.txt / security.txt: [content]

Independent votes for one operator:

1. [signal] on [sites] – why independent of votes 2 and 3
2. [signal] on [sites] – why independent of votes 1 and 3
3. [signal] on [sites] – why independent of votes 1 and 2

Attribution:

- Operator-cluster rung: [weak / moderate / strong / confirmed]
- Person rung: [weak / moderate / strong / confirmed]
- Residual namesake / agency ambiguity: [what would move this]

infra pivot

В.6 Звіт про атрибуцію жорсткої цілі

Письмовий результат. Коротко — краще, ніж довго: клієнт має прочитати за п'ять хвилин і мати змогу діяти. Кожне твердження несе своє джерело, класифікацію й спосіб збереження. Звіт має змусити тебе назвати те, що ти *не* підтвердив; звіт, який лише перелічує знахідки, — маркетинговий документ, а не докази.

Subject: [name / handle / cluster]
Prepared by: [examiner name and role]
Prepared on: [YYYY-MM-DD]
Prepared for: [client / editor / internal file]
Report version: [v1.0 – increment on any material change; keep a changelog line]
Changelog: [v1.0 initial; v1.1 corrected X per Y on YYYY-MM-DD]

Classification and handling

- Distribution: [Confidential – client only | Restricted – named recipients | Internal]
- Handling: [encrypt at rest, no forwarding without written approval, retention window N months]
- Do not quote in external publication without written approval from [name]

Lawful basis for this work

- [Contract with named client dated YYYY-MM-DD | Legitimate interest of the publisher in matter of public concern | Safeguarding | Regulated DD under [regime]]. All processing of personal data is limited to what is necessary for the stated question.
- Jurisdictions in scope: [list]
- Data-subject rights (where the subject is in the EU/UK): the subject may request access, rectification, or erasure of personal data held by [controller name] at [contact]. Requests to be handled per [controller]'s privacy notice dated [date].

Question answered

- [One plain sentence. The question the client asked, not the question that was easiest to answer.]

Attribution – shippable hedged sentence

- Write the finding as a single sentence a lawyer will pass.
Model:

"The strongest independent evidence points at [X] as the operator of

[Y] as of [date range]. Current control by [X] is not confirmed. No

first-party statement or self-link has been observed."

- Rung: [weak / moderate / strong / confirmed]

- What "confirmed" would require (and why we are not there):
[specific evidence – a first-party document, a self-link, an on-record statement – that would move the finding one rung]

Independent signals supporting the attribution

For each: what it is, why it is independent of the others, the source and its classification, and how it is preserved.

1. [signal]

- Source: [name], classification: primary / secondary / broker

- Preservation: [Wayback | Perma.cc | archive.today] ID [X], captured [ts]

- Artifact SHA-256: [hash], stored at [path]

- Independence: [why this is not the same fact as signals 2 and 3]

2. [signal] – as above

3. [signal] – as above

What we did not confirm (mandatory)

- [Specific fact 1 the reader might assume is confirmed and is not.]

- [Specific fact 2. Current control. Present-tense operation . Intent. Funding.

Any adjacent person. Any allegation the evidence does not carry.]

- Namesake / agency residual: [what alternative explanation survives, and what would rule it out]

Out of scope / not attempted

- [List. This is not weakness, it is discipline. Contacts not made, hosts not probed, private data not sought, adjacent persons not investigated.]

Method summary

- [Three-line paragraph. No tool-name catalogue; the client does not need it. Name the categories of source used (registry records, certificate transparency, archived captures, public directories) so a reviewer can reason about coverage.]

Data provenance (per cited fact)

- Every claim in this report is listed in the case file with:
 - : source URL,
 - source classification (primary / secondary / broker), capture timestamp,
 - preservation snapshot ID, and SHA-256 of any downloaded artifact.
- Case file: [path or secure link], SHA-256 of the case-file manifest: [hash]

Examiner sign-off

- I confirm the findings above reflect the evidence in the case file as of the date of this report, that no material contradictory evidence has been omitted, and that I have named the limits of the work honestly.
- Signed: [examiner name], [date]
- Reviewed by: [second examiner or supervising analyst], [date]

attribution report

В.7 Мова, яку прийме юрист

Речення атрибуції — саме те місце, де компетентну роботу найчастіше переписує редактор або наздоганяє лист від адвоката. Патерн майже завжди однаковий: знахідка була захищеною; речення — ні. З'єднай кожну відхилену форму з прийнятною й тримай пару поруч із клавіатурою.

Впевненість в атрибуції - Rejected: *X operates the network.* - Accepted: *The strongest independent evidence points at X as the operator of the network. Current control by X is not confirmed.*

Оператор vs реєстрант - Rejected: *X owns the domains.* - Accepted: *X was the registrant of two of the six domains in pre-2018 WHOIS records. Present-day registration is behind a privacy proxy; current ownership is not confirmed from public records.*

«Підтверджено» vs «сильно» - Rejected: *We confirmed that X runs the site.* - Accepted: *The finding sits at the "strong" rung on our internal ladder — three independent, non-collapsible public signals. It is not "confirmed"; a first-party self-link or on-record statement would be required for that.*

Особа vs організація - Rejected: *X is behind the campaign.* - Accepted: *The operator-cluster evidence points at a single hand behind the network. The evidence does not distinguish between X acting alone and X acting on behalf of an organisation; the residual is named and not resolved.*

Твердження в теперішньому часі з історичних записів -
Rejected: *X controls the infrastructure.* - Accepted: *X was named in registry records dated [YYYY]. A domain can change hands without a public record; we make no claim about control after [YYYY] beyond what the signals in section [N] carry.*

Обмовка «ми не підтвердили X» - Rejected (omission):
[report lists only findings, no negative statement]. - Accepted:
We have not confirmed, and this report does not assert: (i) that X currently operates the network; (ii) any funding relationship; (iii) any intent behind the network's editorial choices; (iv) the involvement of any person named adjacent to X in the source material.

Суміжні особи - Rejected: *X's associate Y is also involved.* -
Accepted: *Y appears in one 2018 photograph with X. The photograph places them in the same room on one date. It carries no attribution weight for the network and Y is out of scope for this report.*

Правило під усім цим: пиши таке речення, яке готовий буде зачитати вголос на допиті. Якщо будь-яке слово в ньому йде далі за докази у файлі кейсу — виріж це слово.

Додаток С — Червоні лінії

Одна картка. Перечитуй щороку.

Ніщо в цій книзі не вимагає, щоб ти перетинав червону лінію. Якщо техніка спокушає тебе через неї — ти вибрав не ту техніку. Майже завжди є спосіб відповісти на законне питання без цього скорочення.

Тут не всі лінії. Це ті, до яких читач тому з найімовірніше підійде впритул.

Доступ

- Не логінитися туди, куди не маєш права. Читати публічний знімок — нормально. Вгадувати пароль, відтворювати старий cookie або використовувати злитий credential для входу в живий акаунт — це несанкціонований доступ у більшості юрисдикцій (CFAA у США, Computer Misuse Act у Британії, порушення GDPR ст. 32 деінде).
- Не обходити paywall, robots-файли чи ліміти запитів силою. robots.txt — не *правовий* бар'єр у більшості юрисдикцій, але зловживання лімітами чи обхід явного контролю доступу сервісу — швидкий шлях до цивільної відповідальності, а часом і до кримінальної. Якщо оператор прямо попросив автоматичних читачів не заходити — не заходь.

- Не зондуй хостів, які ти перелічив. Знайти адмінський піддомен у СТ — це робота з публічним записом. Витягнути сторінку логіну на цьому піддомені — це вже запит. Спробувати на ньому credentials — несанкціонований доступ. Перелічуй; не торкайся.

Походження даних

- Розумій, що купуєш. Комерційний pDNS, історичний WHOIS і дані скан-індексів — усе це походить із десь-агрегованих логів. Хтось із вендорів отримав згоду операторів резолверів, хтось ні. Якщо працюєш у регульованому середовищі — питай.
- Не використовуй дані з витоків, щоб залогінитися. Пароль з витоку доводить, що акаунт існував. Використати цей пароль, щоб потрапити в живий акаунт, — злочин майже скрізь. Дивись том 2, розділ 5.
- Цитуй кожне джерело в кожному звіті. Кожне твердження має URL і час захоплення. Якщо джерело платне або під NDA — цитуй вендора за назвою, не за внутрішнім ідентифікатором.

Люди

- Людина — не мета. Том 3 робить дуже легким сповзання з *оператора на родину оператора, сусідів, орендодавця, дитину на задньому плані геолокованого фото*. Не сповзай. Збирай те, що відповідає на питання, і зупиняйся.
- Ніколи не геолокуй приватний дім, щоб опублікувати адресу. Навіть якщо це беззаперечно. Навіть у розслідуванні на основі витоку. Публічний інтерес майже ніколи не потребує точних координат.
- Ніколи не хронолокуй пересування людини, щоб опублікувати їх. Візерунок приватного життя — не публічний запис. Якщо кейс вимагає — скажи клієнту; не публікуй.
- Виняток для домашнього насильства / переслідування / високого ризику. Якщо тебе просять знайти когось, хто навмисно лишив старе життя, — відмовся. Крапка. Всередині safeguarding-служб є професіонали, які роблять це правильно. Ти не з їхнього числа після книги.

Етика викриття

- Публічний інтерес — не те саме, що публічна цікавість. Тест на публічний інтерес у ньюзрумі питає: чи шкода об'єкту пропорційна шкоді для суспільства, якщо це лишиться прихованим? Тест на цікавість питає: чи можу я це дізнатися? Перший виправдовує публікацію; другий — ніколи.
- Мінімальне розкриття. Публікуй лише те, що відповідає на питання. Якщо ти знайшов весільне фото, щоб підтвердити місце проживання, — називай місце проживання, а не весілля.
- Ти не остання перевірка. Якщо звіт іде до клієнта, який може діяти на його підставі — слідчого репортера, корпоративного DD, safeguarding-офіцера — очікуй, що вони додадуть свої перевірки. Це не недовіра; це процес.

Лінія, яку ти проводиш сам

Над усіма правилами: той, хто знає, коли зупинитися, а не той, хто знайшов найбільше. Якщо ти не можеш одним простим реченням сказати, чому йдеш за цією ниткою, — не йди. Читай кожну картку цього додатку на початку кожного кейсу. Це хвилина. Це рятує кар'єри.

Додаток D — Забери назад

Усе, що ти щойно навчився читати, — застосуй проти себе.

Кожен розділ цієї книги вчив тебе читати слід. Цей додаток — фінальна вправа: прочитай *свій* слід і закрий там, де можеш. Половина стає м'язовою пам'яттю після першого разу; інша половина — звичка обслуговування.

Роби це двічі на рік. Коли стає тривожно — нова робота, публічний виступ, переїзд у нове місто, стурбованість власною безпекою — роби того ж тижня знову.

Архіви (Розд. 1)

- Пошукай у Wayback Machine кожен домен, яким ти колись володів. Прочитай таймлайн. Якщо щось незручне — попроси видалення з Wayback (частину запитів вони поважають). Якщо щось гірше — розумій: «попросив і забув» замало, сторонні дзеркала все ще можуть це нести.
- Пошукай точними цитатами рідкісні фрази, які ти писав. Подивись, що зберегли треті сторони. Все, що тебе здивує, — це сигнал для наступного розділу.

Видалені профілі (Розд. 2)

- Випиши кожен акаунт, який ти коли-небудь створював. Старий MySpace, ICQ, Xanga, LiveJournal, померлі форуми, вікі ігрового клану з 2011. Пошукай кожен за нікнеймом і за email.
- Реверс-зображення аватарки, яку ти використовував у кожному. Одна й та сама аватарка на двох акаунтах, які ти вважав розділеними, — це скорочення, яке ти лишив для будь-кого.
- Прочитай залишок соціального графа. На платформах, де досі видно спільних друзів, побач, що чужак міг би вивести про твою мережу.
- Опт-аути з data-broker. People-search сайти тримають знімки роками. Кожен американський сайт має сторінку опт-ауту — більшість недружні, всі працюють з часом. Є консолідовані сервіси, які зроблять це замість тебе; не рекомендація, просто зауваження.

Фотографії (Розд. 3 і 4)

- Знімай EXIF з усього, що постиш. Більшість соцплатформ зараз чистять, але блоги й хмарні шери часто ні.
- Читай свої опубліковані фото як геолокатор. Номер будинку в кутку. Відбиття в дзеркалі. Характерне дерево. Прибирай або обрізай.

- Те саме для хронолокації. Візерунок постів завжди по вівторках з того самого кафе поміщає тебе у звичку. Якщо звичка важить для твоєї безпеки — зламай її.
- Особлива обережність з дітьми. Фото шкільної нашивки, маршрут до школи, форма у сімейному кадрі — будь-що з цього це хронолокація ранку вівторка дитини. Не постити.

Домени (Розд. 5)

- Прочитай власний живий WHOIS. Для кожного свого домену подивись, що публічно. Якщо твій email реєстранта до 2018 року — історичний WHOIS досі має його, професійний супротивник знайде його там.
- Прочитай власний DNS. MX-записи видають твого mail-провайдера; TXT-записи видають твій тенант Google Workspace чи Microsoft 365; SPF видає кожного sender'a, якому ти дозволив надсилати. Ніщо з цього не таємниця; важливо розуміти, що воно про тебе каже.
- Перенеси персональні домени на privacy-enabled реєстрацію, якщо ще ні. Витік 2011 вже стався — але з 2026 вперед може бути тихо.

Сертифікати (Розд. 6)

- Пошукай у СТ свої домени. Прочитай кожен SAN у кожному серті. Якщо забутий staging там — цей хостнейм публічний назавжди. Прибери хост, якщо мертвий; переведи на приватний СА (поза СТ), якщо живий і справді внутрішній.
- Обережно з wildcard-сертами. Wildcard SAN захищає все, але сам *факт* наявності wildcards на домені каже професіоналу, що ти маєш піддомени, які варто називати.

Інфраструктурні відбитки (Розд. 7 і 8)

- Проведи інвентаризацію операторських відбитків. Чи всі твої особисті сайти носять один і той самий фавікон? Той самий GA-ID? Той самий tag manager? Якщо так, а сайти не мають бути пов'язаними — розв'яжи.
- Різись стеком між ідентичностями, які не мусять з'єднуватися. Два сайти, які ти планував тримати нарізно, не повинні ділити ту саму платну WordPress-тему, той самий файл аватарки, ті самі імена CSS-класів.
- Перевір свій JARM. Якщо селф-хостиш — прожени JARM-інструмент проти власного edge. Якщо відбиток рідкісний — супротивник знайде кожен інший хост з тим самим налаштуванням.

Звички

- Password manager, 2FA скрізь. Це звичка з тому 1; досі найбільше єдине зниження поверхні атаки. Не опціонально.
- Синхронізація контактів вимкнена. Двобічний РУМК пов'яже твою дослідницьку ідентичність із реальною першого ж разу, коли обидва застосунки прочитають адресну книгу. Дивись том 2.
- Компарменталізуй. Дослідницький браузер — не твій особистий браузер. Дослідницький телефон — не особистий. Дослідницький хендл — не той, яким ти колись користувався.
- Коли тебе вже шукають. Якщо ти знаєш або підозрюєш, що за тобою стежать чи переслідують, — не проганяй цей чеклист на своїх звичних акаунтах: сам візерунок раптового укріплення є сигналом. Змінюй усе одразу, з чистого пристрою, за один сеанс. Або звернись до safeguarding-фахівця; в цьому немає сорому.

Лінія

Ти не закриєш кожну дірку. І не мусиш. Тобі треба достатньо тертя, щоб випадковий супротивник здався, і достатньо дисципліни, щоб серйозному довелося попрацювати. Читай кожен розділ цієї книги як інструкцію з власного захисту. Тоді закрий, що можеш, живи з тим, чого не можеш, і повертайся до роботи.

Глосарій

Прості визначення кожного терміна, який ця книга вживає більше одного разу. Гортай будь-коли.

- **AdSense ID / pub-id** — ідентифікатор паблішера Google для рекламних доходів, у форматі pub-1234567890123456. Коли один pub-id з'являється на двох різних сайтах, платять до одного гаманця — тому це один із найсильніших сигналів атрибуції на драбині.
- **Anchor / якір** — та одна відома точка, від якої ти стартуєш розслідування. Домен, фото, хендл, номер телефону. Все інше в кейсі досягається стрибками від якоря.
- **Атрибуція** — третій хід у петлі. Перетворення «це належить якійсь людині» на «це належить *тій* людині» — назвати оператора за слідом.
- **Autonomous System (AS)** — шматок інтернету під маршрутним контролем одного оператора, ідентифікується AS-номером на кшталт AS13335. Корисно для групування IP за тим, хто ними реально керує, а не за тим, чиє ім'я в WHOIS.
- **Банер** — короткий рядок, який сервіс віддає тієї миті, коли ти відкриваєш до нього з'єднання. Номери версій, назви ПЗ, іноді хостнейми. Безкоштовна ідентифікація,

без логіна.

- **Час зняття** — мітка часу, коли зроблено знімок, а не коли ти на нього дивишся. У кожної архівної сторінки, кожного сканування, кожного скріншота вона є. Цитуй її, або доказ тихо гниє.
- **Прозорість сертифікатів (СТ)** — публічна append-only лог-система, у яку записується кожен довірений TLS-сертифікат. Зробила перелічення піддоменів тривіальним і вбила ідею, що хостнейм може лишатися секретним.
- **Хронолокація** — датування зображення за тим, що в кадрі. Кут сонця, листя, вивіски, сніг, дорожні роботи, плакат з датою. Відповідає на «коли», а не «де».
- **clientTransferProhibited** — EPP-статус на домені, що не дозволяє переносити його до іншого реєстратора без розблокування. Це антизахоплювальний замок, і не більше. Він не приховує реєстранта, і його наявність нічого не каже про власника.
- **CNAME** — DNS-запис, що вказує один хостнейм на інший хостнейм замість IP. `www.example.com` CNAME на `example.com` — класика. Іди ланцюгом — ціль-alias часто розкриває орендаря хостингу.
- **Драбина впевненості** — чотири щаблі, на яких ця книга оцінює сигнали: слабкий, помірний, сильний, підтверджено. Слабкий сигнал — натяк; підтверджений

— самопосилання або квитанція. Все у звіті має бути десь на драбині позначене.

- **DKIM** — DNS-опублікована криптографічна підписова система, що доводить: пошту справді відправив хтось, авторизований на цей домен. Записи TXT `s1._domainkey` — це DKIM.

- **DMARC** — DNS-запис політики, що каже приймаючим поштовим серверам, що робити, коли перевірки SPF або DKIM провалилися — доставити, у карантин чи відхилити. Публікується на `_dmarc.example.com`.

- **DNS** — телефонна книга, що перетворює хостнейми на кшталт `example.com` на IP-адреси. Майже кожна техніка у Т.3 або запитує DNS, або читає його історичну тінь.

- **DoH / DoT** — DNS-over-HTTPS і DNS-over-TLS. Два способи шифрування DNS-запитів, щоб мережевий спостерігач не бачив, які хостнейми ти резолвив. Важить для гігієни дослідження, не для того, що можна запитати.

- **Dork** — пошуковий запит, побудований з операторів — `site:`, `inurl:`, `filetype:`, `intitle:`. Добре сформований dork перетворює пошуковик на цільовий індекс.

- **EXIF** — блок метаданих усередині файлу фото. Виробник і модель камери, об'єктив, витримка, іноді GPS-координати і серійник телефона. Зачищай з усього, що публікуєш; читай на всьому, що отримуєш.

- **Відкритий слід (exposure)** — перший хід у петлі: слід суб'єкта, який уже лежить на видноті. Ти не створюєш відкриті сліди, ти їх помічаєш.
- **Favicon** — маленька іконка, яку браузер показує у вкладці для сайту. Зазвичай віддається з `/favicon.ico`. Перевикористовується на різних властивостях суб'єкта частіше, ніж він розуміє.
- **Геш фавікону** — MurmurHash3 сирих байтів файлу фавікону, закодований у base64. Сканіндекси дозволяють шукати за цим гешем — один фавікон може ідентифікувати кожен хост, що віддає той самий файл.
- **Відбиток (fingerprint)** — повторюваний ідентифікатор, отриманий з конфігурації. Те саме налаштування — той самий відбиток на різних IP і хостнеймах. JARM, JA3, геші фавіконів — усе відбитки.
- **FOAF (friend-of-a-friend)** — техніка, що йде через мережі інших людей, щоб досягти суб'єкта. Суб'єкт може закрити профіль; публічний весільний альбом його двоюрідного брата — ні.
- **GA4 (Google Analytics 4)** — нинішній аналітичний маяк Google, ідентифікований measurement ID виду `G-XXXXXXXXX`. Два сайти з тим самим measurement ID мають одного власника.
- **GDPR** — регуляція приватності ЄС, яка змусила реєстраторів редагувати персональні дані WHOIS у

2018-му. Це причина, чому «чому цей WHOIS порожній» майже ніколи не є зловісною відповіддю.

- **Геолокація** — визначення *де* зроблено зображення за тим, що в ньому видно. Скайлайн, пагорби, дорожні меблі, мова на вивісках. Відповідає на «де»; хронолокація — на «коли».
- **Історичний WHOIS** — знімки WHOIS-записів до нинішнього — часто до GDPR-редакції. Домен, що анонімний сьогодні, у 2015-му міг нести повне ім'я й email.
- **Нор / півот** — другий хід у петлі: перетворення одного сліду на наступний. Від домену до його сертифіката до іншого домену. Від хендла до email до другого хендла. Кожен кейс — це ланцюг стрибків.
- **HTTP-заголовок** — метадані, що йдуть з HTTP-запитом чи відповіддю — Server, Set-Cookie, X-Powered-By, і десятки інших. Читай їх; вони зливають стек, орендаря і іноді внутрішні хостнейми.
- **ICANN** — некомерційна організація, що керує політикою доменних імен на вершині дерева. Встановлює правила, яких мають дотримуватись реєстратори й реєстри.
- **Незалежність (сигналів)** — два сигнали рахуються як два голоси лише якщо надійшли з окремих джерел. Три сторінки того самого скрапера, що повторюють один

витік, — це один сигнал, не три.

- **JARM** — 62-символьний відбиток того, як TLS-сервер відповідає на набір проб-хендшейків. Два сервери з однаковим JARM майже напевно тримають той самий стек, налаштований однаково.
- **JA3 / JA4 / JA4S** — формати відбитків для *клієнтської* сторони TLS-хендшейка (JA3, JA4) і *серверної* (JA4S). Використовуються для групування трафіку й інфраструктури за ПЗ, що стоїть за ними.
- **Витік / брич (leak / breach)** — дамپ даних користувачів, зроблений публічним без згоди платформи. Історично одне й те саме слово вживається для обох; став їх як докази, цитуй джерело й дату і ніколи не перепублікуй сирі записи.
- **MurmurHash3** — швидка некриптографічна геш-функція. Використовується сканіндексами для відбитку фавіконів; не використовується для нічого критичного до безпеки.
- **MX-запис** — DNS-запис, що називає поштовий сервер, відповідальний за домен. Каже тобі, чи компанія тримає власну пошту, чи використовує Google Workspace, Microsoft 365 чи щось рідше.
- **Сервер імен (NS)** — DNS-сервер, що реально тримає записи для домену. Два домени, що ділять маловідомий сервер імен, часто ділять оператора.

- Пасивний DNS (pDNS) — архів історичних DNS-резолюцій, зібраних публічними резолверами роками. Дозволяє запитати «на що цей хостнейм резолвився у березні 2019-го» задовго після того, як запис змінився.
- Фенологія — сезонний цикл рослин. Розкриття бруньок, листоблиск, цвітіння, сенесценція. У вуличному фото стан рослинності звужує вікно зняття до кількох тижнів.
- Precertificate — версія TLS-сертифіката, надіслана в СТ-логи до того, як фінальний лист підписано. Це те, що робить виявлення піддоменів через СТ можливим фактично в реальному часі.
- Провенанс / походження — звідки шматок доказу і як він до тебе дійшов. Кожне твердження у звіті має нести своє походження; твердження без походження не можна захистити.
- Punycode / ACE-форма — ASCII-кодування, яке DNS використовує для інтернаціоналізованих доменних імен, з префіксом xn--. xn--80akhbyknj4f — це испытание у дготовій формі DNS. Стеж за лукелайками.
- Ранжування (на драбині) — акт присвоєння сигналу слабкий, помірний, сильний або підтверджено, перш ніж ти пишеш звіт. Ранжуй у процесі збору; не відкладай.

- Редакція (WHOIS) — пост-GDPR практика приховування імені, email і адреси реєстранта за плейсхолдерним текстом чи псевдонімом сервісу приватності. Стандарт, не підозріло.
- Реєстратор vs реєстр — реєстратор — це вендор, у якого ти купуєш домен (GoDaddy, Namecheap, Cloudflare). Реєстр — авторитет, що керує самою TLD (Verisign для .com, Nominet для .uk). Різні ролі, часто плутають.
- Дослідницький акаунт — див. *сок-акаунт*.
- Дослідницький браузер — див. *робочий браузер проти дослідницького*.
- Reverse-IP / reverse-DNS — запит «які ще хостнейми резолвилися на цей IP» (reverse-IP) чи «який хостнейм цей IP заявляє в PTR-записі» (reverse-DNS). Два різні запити, обидва корисні, легко сплутати.
- RFC 6962 — специфікація, що визначає логи прозорості сертифікатів. Цитуй її, коли хтось стверджує, що CT опціональний; це не так.
- robots.txt — текстовий файл на /robots.txt, де сайт ввічливо просить краулерів не індексувати певні шляхи. Це рекомендаційно. Шляхи, які він називає, часто найцікавіші на сайті.
- SAN (Subject Alternative Name) — список хостнеймів, для яких один TLS-сертифікат чинний. Сертифікат з

example.com, dev.example.com, staging.internal.example.com у SAN щойно безкоштовно назвав тобі три піддомени.

- **Сканіндекс** — пошуковий каталог кожного хоста, видимого у публічному інтернеті, який тримають сервіси Shodan, Censys чи FOFA. Ти його запитуєш; сам не скануєш.
- **SCT (Signed Certificate Timestamp)** — квитанція з СТ-логу, що доводить надсилання сертифіката до нього, вбудована в сам сертифікат. Це те, що браузері перевіряють для контролю прозорості.
- **Самопосилання (self-link)** — першоджерельна заява про володіння. Власний сайт суб'єкта, що лінкує на хендл. Найсильніший сигнал на драбині для атрибуції.
- **Знімок (snapshot)** — збережена копія сторінки в конкретний момент. Знімки Wayback Machine, знімки archive.today, твої власні скріншоти. Завжди записуй час зняття поруч.
- **Сок-акаунт** — чиста дослідницька ідентичність, окрема від реальної дослідникової. Ще називається дослідницький акаунт. Використовується для будь-чого, що потребує логіна чи взаємодії.
- **SPF** — DNS TXT-запис, що перелічує, яким поштовим серверам дозволено надсилати пошту нібито з домену. Розкриває поштову інфраструктуру і, іноді, сторонніх

орендарів.

- Піддомен — ім'я ліворуч від базового домену. `dev.example.com`, `mail.example.com`. СТ-логи, DNS-брутфорс і пасивний DNS — способи їх перелічити.
- TLS / SSL — криптографічний шар під HTTPS. TLS — сучасна назва; SSL — старіша; вживають їх взаємозамінно. Кожен придатний до відбитку хендшейк у цій книзі живе тут.
- TLD — top-level domain — остання мітка хостнейма. `.com`, `.eu`, `.io`, `.рф`.
- TXT-запис — вільний DNS-запис. Тримає SPF, DKIM, DMARC і кожен верифікаційний токен SaaS, який домен коли-небудь налаштовував. Один з найпротічніших записів у DNS.
- UA-ID (застарілий Google Analytics) — старіший ідентифікатор Google Analytics, виду `UA-XXXXXX-Y`. Виведений з експлуатації у 2023-му, але досі видимий у архівованих сторінках; досі чинний для історичної атрибуції.
- Верифікаційний токен — випадковий рядок, який сторонній сервіс просить опублікувати в DNS, щоб довести володіння доменом. TXT-записи набиті ними. Кожен називає сервіс, який використовує оператор.
- Wayback Machine — сервіс історії веб-сторінок Internet Archive за адресою `web.archive.org`. Стандартний перший

стоп для «як ця сторінка виглядала раніше».

- WHOIS — публічний запис про те, хто зареєстрував домен, коли, через якого реєстратора, до якого терміну. Після 2018-го персональні поля зазвичай відредаговані; операційні — ні.
- Wildcard-сертифікат — TLS-сертифікат, чий SAN — *.example.com, чинний для кожного безпосереднього піддомена. Зручно для оператора і тихо ворожо до перелічення.
- Робочий браузер проти дослідницького — твій щоденний Chrome, залогінений у твої справжні акаунти, — робочий браузер. Чистий профіль без куки, без синхронізації, без розширень, яких ти не обирав, — дослідницький браузер. Ніколи їх не плутай.

Якщо слово, яке ця книга використовує більше двох разів, тут відсутнє, — це баг, повідомляй. Глосарій росте з читачем.